

Evidence pack

Every answer in this round, with the passages it is drawn from.

Customer	Northwind Traders (journey)
Review	rev-556261438508
Round	1 (rev-556261438508-r1)
Framework	caiq
Data residency	us
Review state	awaiting_human
Questions	312
Answered	312
Answers with citations	135 of 312
Sendable	92
Approved by a human	0
Generated	2026-08-17T18:02:57+00:00
Produced by	attestor-control-plane attestor-control-plane-00008-9m2 · attestor-505506 · us-central1

Release rule

Every question is listed and nothing is omitted. An answer marked approved was signed off by a named human. An answer marked drafted with citations is grounded in retrieved evidence and was not individually reviewed — the passages it relies on are listed beside it, with the document, section and relevance score, so the claim can be checked rather than trusted. An answer marked held, no evidence, quarantined or rejected must not be sent to a customer as an answer.

No — no supporting evidence found	172
Yes — drafted with citations, not individually reviewed	92
No — held for a human	43
No — quarantined by the guardrail	5

Answers and evidence

1. Are passwords subject to a forced rotation schedule?

security · Q1 · Vendor Security Review row 2

No, passwords are not subject to a periodic forced rotation schedule. In alignment with NIST SP 800-63B guidance, Kestrel Data enforces password rotation only upon evidence of compromise. Where passwords are used, they must have a minimum length of 14 characters and are checked against the Have I Been Pwned breached-password corpus at the time of creation (Access Control Standard, Section 9. Password requirements).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.62

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — Access Control Standard — relevance 0.60

Access Control Standard

Document ID: KD-SEC-002 · **Version:** 3.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.1, CC6.2, CC6.3 · ISO 27001:2022 A.5.15, A.5.16, A.5.18, A.8.2

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 3. Role-based access — relevance 0.59

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 2. Multi-factor authentication — relevance 0.59

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 1. Identity provider — relevance 0.56

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`).

Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

2. Are confidentiality obligations imposed on personnel, and do they survive termination?

legal · Q2 · Vendor Security Review row 3

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

3. Do you offer a single-tenant or dedicated instance deployment?

engineering · Q3 · Vendor Security Review row 4

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

4. Do you scan source code for committed secrets?

security · Q4 · Vendor Security Review row 5

Yes. Kestrel Data scans for secrets on every commit using Gitleaks at the pre-commit stage alongside GitHub secret scanning with push protection, as outlined in the *Vulnerability Management Policy* (Section 2, "Scanning coverage").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 2. Scanning coverage — relevance 0.62

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.53

5. Responsible disclosure

Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

****Kestrel does not currently operate a paid bug bounty programme.**** Reports are handled through the responsible disclosure process above

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[3] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.52

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[4] cloud-security-posture-standard — 4. Drift detection — relevance 0.52

4. Drift detection

Configuration drift is detected three ways:

1. ****Terraform Cloud drift detection**** runs every 24 hours against all 19 production workspaces and opens a PagerDuty ticket on any difference. Mean drift events per month in 2025: 1.4, nearly all from AWS-side attribute defaults changing.

2. ****AWS Config**** evaluates 147 rules continuously across every account, with the confo

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[5] vulnerability-management-policy — 4. Penetration testing — relevance 0.52

4. Penetration testing

An independent penetration test is commissioned **annually** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

5. Has your organisation been subject to a regulatory enforcement action?

legal · Q5 · Vendor Security Review row 6

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

6. Were any exceptions noted in your most recent SOC 2 report?

security · Q6 · Vendor Security Review row 7

No exceptions were noted in Kestrel Data's most recent SOC 2 Type II report. For the report period covering 1 January through 31 December 2025 (issued on 14 March 2026 by Prescient Assurance LLP), the independent auditor issued an unqualified opinion with no exceptions noted across the in-scope Trust Services Criteria of Security, Availability, and Confidentiality (cited from `soc2-control-matrix`, Section: "SOC 2 Control Matrix").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.70

SOC 2 Control Matrix

Document ID: KD-SEC-012 · **Version:** 2.1

Report period: 1 January - 31 December 2025 · **Report issued:** 14 March 2026

Auditor: Prescient Assurance LLP · **Opinion:** Unqualified, no exceptions noted

Trust Services Criteria in scope: Security, Availability, Confidentiality

Privacy and Processing Integrity are **not** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] risk-management-and-governance — 9. Exceptions — relevance 0.68

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] access-control-standard — 5. Customer data access — relevance 0.66

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] risk-management-and-governance — Risk Management and Security Governance — relevance 0.66

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] soc2-control-matrix — Complementary user entity controls — relevance 0.66

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

7. Do you operate a bug bounty programme?

security · Q7 · Vendor Security Review row 8

Kestrel Data does not currently operate a paid bug bounty programme. Instead, vulnerability reports are handled through a responsible disclosure process. Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt`, commits to acknowledging submissions within two business days, and ensures that researchers acting in good faith under the published policy will not be pursued legally (*Vulnerability Management Policy*, Section 5, "Responsible disclosure").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.67

5. Responsible disclosure

Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

****Kestrel does not currently operate a paid bug bounty programme.**** Reports are handled through the responsible disclosure process above

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 4. Penetration testing — relevance 0.57

4. Penetration testing

An independent penetration test is commissioned ****annually**** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[3] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.57

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] vulnerability-management-policy — 2. Scanning coverage — relevance 0.57

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[5] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.56

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

8. Provide your data retention schedule.

legal · Q8 · Vendor Security Review row 9

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

9. Have you experienced a customer data breach in the last 3 years?

security · Q9 · Vendor Security Review row 10

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

10. Please confirm: Were any exceptions noted in your most recent SOC 2 report?

security · Q10 · Vendor Security Review row 11

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

11. For each applicable system: Describe the data flow for customer data through your platform.

engineering · Q11 · Vendor Security Review row 12

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

12. Describe the security controls applied to your cloud service provider accounts.

security · Q12 · Vendor Security Review row 13

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

13. How is uptime measured, and by whom?

engineering · Q13 · Vendor Security Review row 14

Uptime is measured as the percentage of minutes in a calendar month during which the service is available, calculated using the formula:
$$\text{Uptime \%} = \frac{\text{Total Minutes} - \text{Downtime Minutes}}{\text{Total Minutes}} \times 100$$
 Downtime is defined as any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Rather than relying on internal instrumentation, measurement is conducted by an independent third party, Checkly, across 7 global locations at 30-second intervals. This monitoring data is available to customers upon request (*availability-sla*, Section 2. Definitions).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] availability-sla — 2. Definitions — relevance 0.66

2. Definitions

****Uptime**** is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

****Downtime**** is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporus/engineering/availability-sla.txt

[2] availability-sla — 4. Service credits — relevance 0.61

4. Service credits

| Monthly uptime | Credit (% of monthly fee) |

|---|---|

| Below 99.9% but at or above 99.0% | 10% |

| Below 99.0% but at or above 95.0% | 25% |

| Below 95.0% | 50% |

Credits are the sole and exclusive remedy for failure to meet this SLA. A claim must be submitted within ****30 days**** of the end of the affected month, with supporting detail. Credits are applied to the nex

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] availability-sla — 5. Historical performance — relevance 0.59

5. Historical performance

| Year | Measured availability | Months below 99.9% | Credits issued |

|---|---|---|---|

| 2025 | 99.97% | 0 | 0 |

| 2024 | 99.94% | 1 (March, 99.87%) | 1 customer, 10% |

| 2023 | 99.91% | 1 (August, 99.82%) | 3 customers, 10% |

gs://attestor-505506-corporus/engineering/availability-sla.txt

[4] availability-sla — 1. Commitment — relevance 0.59

1. Commitment

Kestrel commits to ****99.9% monthly uptime**** for the Kestrel Insight platform on the Enterprise and Growth tiers.

The ****Starter tier carries no availability commitment.**** It is offered on a reasonable efforts basis and is excluded from service credits.

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] availability-sla — 3. Exclusions — relevance 0.57

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.

- Emergency maintenance to address a security vulnerability, notified as soon as practicable.

- Customer configuration, customer code, or customer exceeding documented rate limits.

- Failure o

gs://attestor-505506-corporus/engineering/availability-sla.txt

14. Will you provide an SBOM on request?

engineering · Q14 · Vendor Security Review row 15

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

15. Where is your service status published?

engineering · Q15 · Vendor Security Review row 16

Service status is published at `status.kestreldata.com`, which is hosted by Statuspage on infrastructure independent of Kestrel Data's own environment to prevent shared failure domains. The status page provides per-component status for both the US and EU instances, details on current and historical incidents, and notices for scheduled maintenance. Customers can subscribe to updates via email, SMS, RSS, and webhooks (`service-operations-and-support`, Section 1, "Status page").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] service-operations-and-support — 1. Status page — relevance 0.71

1. Status page

Service status is published at `status.kestreldata.com`, hosted by Statuspage on infrastructure independent of Kestrel's own — a status page that shares a failure domain with the service is worthless during exactly the event it exists for. The page shows per-component status for the US and EU instances, current and historical incidents, and scheduled maintenance. Customers may s

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] availability-sla — 2. Definitions — relevance 0.63

2. Definitions

Uptime is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

Downtime is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] availability-sla — 5. Historical performance — relevance 0.60

5. Historical performance

Year	Measured availability	Months below 99.9%	Credits issued
2025	99.97%	0	0
2024	99.94%	1 (March, 99.87%)	1 customer, 10%
2023	99.91%	1 (August, 99.82%)	3 customers, 10%

gs://attestor-505506-corporus/engineering/availability-sla.txt

[4] availability-sla — Availability Service Level Agreement — relevance 0.59

Availability Service Level Agreement

Document ID: KD-ENG-007 · **Version:** 3.0 · **Owner:** Aaron Feldstein, General Counsel
Effective: 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.59

Service Operations, Maintenance and Support

Document ID: KD-ENG-009 · **Version:** 2.2 · **Owner:** Dana Whitfield, VP Engineering
Approved: 23 January 2026 · **Next review:** 23 January 2027
Maps to: SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

16. Do you run simulated phishing exercises? Provide the most recent click rate.

security · Q16 · Vendor Security Review row 17

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

17. How long do backups containing deleted customer data persist?

engineering · Q17 · Vendor Security Review row 18

Backups expire automatically on their standard retention cycle. When customer data is deleted or a tenant purge runs following termination, historical backups containing that data persist for a maximum of 35 days before expiring (`backup-restore-procedure`, Section 6, "Backup deletion"; `cloud-exit-and-portability-plan`, Section 6, "Customer's own exit from Kestrel"). Kestrel does not surgically remove individual tenant data from existing historical backup images (`backup-restore-procedure`, Section 6, "Backup deletion").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 6. Backup deletion — relevance 0.72

6. Backup deletion

Backups expire automatically. When a customer terminates and the tenant purge runs, backups containing that data expire on the normal cycle, a maximum of **35 days** later. Kestrel does not selectively surgically remove a tenant from historical backup images, and says so rather than implying otherwise.

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.67

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 1. What is backed up — relevance 0.66

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | **35 days** |

| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[4] cloud-exit-and-portability-plan — 6. Customer's own exit from Kestrel — relevance 0.62

6. Customer's own exit from Kestrel

Distinct from Kestrel's exit from AWS, and more likely to be what a reviewer is asking about. A customer may leave at any time and take their data with them:

* full self-service export of all customer-uploaded datasets in their original format, plus account identity data and usage events as JSON or CSV;

* the same through the public API, with no volume charge

gs://attestor-505506-corpus/engineering/cloud-exit-and-portability-plan.txt

[5] backup-restore-procedure — 4. Test results — relevance 0.61

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

| Quarter | Date | Duration | Assertions | Outcome |

|---|---|---|---|---|

| Q1 2026 | 17 Jan 2026 | 2h 41m | 1,240 / 1,240 | Pass |

| Q4 2025 | 11 Oct 2025 | 3h 02m | 1,238 / 1,240 | Pass, 2 known-stale fixtures corrected |
| Q3 2025 | 19 Jul 2025 | 3h 20m | 1,240 / 1,240 | Pass |

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

18. What security events are logged and for how long are they retained?

security · Q18 · Vendor Security Review row 19

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

19. Are key administrators and key users separated?

security · Q19 · Vendor Security Review row 20

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

20. Is the service directed at children under 16?

legal · Q20 · Vendor Security Review row 21

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] dpia-register — 4. Children's data — relevance 0.62

4. Children's data

****Kestrel Insight is not directed at children.**** It is a business-to-business analytics product sold to organisations, made available under a master agreement executed by a business entity, and it is not marketed to consumers. End users are the customer's own personnel.

Kestrel does not knowingly collect personal data from anyone under 16. There is no age verification because t

gs://attestor-505506-corpus/legal/dpia-register.txt

[2] dpia-register — Data Protection Impact Assessment Register — relevance 0.49

Data Protection Impact Assessment Register

****Document ID:**** KD-LEG-011 · ****Version:**** 1.9 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 16 January 2026 · ****Next review:**** 16 January 2027

****Maps to:**** GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corpus/legal/dpia-register.txt

[3] dpia-register — 3. Special category data — relevance 0.45

3. Special category data

****Kestrel does not knowingly process special category personal data under Article 9.**** The platform is not designed for it, the Acceptable Use terms in the master agreement prohibit uploading it, and no field in the data model is intended to hold it.

Kestrel cannot inspect customer-uploaded datasets — they are opaque by design — so the control is contractual and architect

gs://attestor-505506-corpus/legal/dpia-register.txt

[4] dpia-register — 5. Automated decision-making — relevance 0.45

5. Automated decision-making

Kestrel performs **no** automated decision-making producing legal effects or similarly significant effects concerning data subjects, within the meaning of Article 22. The two machine learning features described in KD-SEC-019 §2 surface information to the customer's own analysts; the decisions that follow are made by people at the customer, using the customer's own data

gs://attestor-505506-corporus/legal/dpia-register.txt

[5] dpia-register — 7. Availability — relevance 0.45

7. Availability

DPIA summaries are provided to customers under NDA on request through the account team. The full assessments are not distributed, because they contain architectural detail that is itself Confidential, but the DPO will walk a customer's privacy team through an assessment on a call.

gs://attestor-505506-corporus/legal/dpia-register.txt

21. Please confirm: Do you publish a modern slavery or supply chain labour statement?

legal · Q21 · Vendor Security Review row 22

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

22. What is your API deprecation policy?

engineering · Q22 · Vendor Security Review row 23

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

23. Describe your security incident classification scheme. Provide supporting evidence.

security · Q23 · Vendor Security Review row 24

Kestrel Data classifies security incidents into a four-tier severity scheme based on operational impact and data sensitivity: **SEV1**: Confirmed unauthorized access to customer production data or a full platform outage. This level triggers an immediate 24/7 on-call page and executive escalation to the CEO and CISO within 30 minutes. **SEV2**: Suspected compromise, a partial outage affecting more than 10% of tenants, or a confirmed data integrity fault. This level initiates an immediate 24/7 on-call page and notification to the CISO within 1 hour. **SEV3**: A security-relevant defect with no evidence of active exploitation. These incidents are addressed during business hours and reported in weekly executive summaries. **SEV4**: Informational or hygiene findings. These do not trigger on-call paging and are communicated via monthly reporting. (Source: `incident-response-runbook`, Section 1. Severity definitions)*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 1. Severity definitions — relevance 0.68

1. Severity definitions

| Sev | Definition | Page | Exec notify |

|---|---|---|---|

| **SEV1** | Confirmed unauthorised access to customer production data, or full platform outage | Immediate, 24/7 | CEO + CISO within 30 min |

| **SEV2** | Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault | Immediate, 24/7 | CISO within 1 hour |

| **SEV3**

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.65

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure. Internet-facing findings are escalated one level.

Severity	CVSS	Remediation SLA	Measured 2025 compliance
Critical	9.0-10.0	**7 days**	100% (11 of 11)
High	7.0-8.9	**30 days**	96% (74 of 77)
Medium	4.0-6.9	**90 days**	91%

gs://attestor-505506-corporate/security/vulnerability-management-policy.txt

[3] incident-response-runbook — 3. Lifecycle — relevance 0.63

3. Lifecycle

Detect, triage, contain, eradicate, recover, learn.

Detection sources are Datadog Security Monitoring, AWS GuardDuty, AWS Security Hub, Okta ThreatInsight, Snyk, customer reports to `security@kestreldata.com`, and the disclosure address published at `kestreldata.com/well-known/security.txt`.

Triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2, meas

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[4] incident-response-runbook — 8. Post-incident review — relevance 0.62

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[5] vulnerability-management-policy — 6. Exceptions — relevance 0.62

6. Exceptions

A finding that cannot be remediated within SLA requires a documented exception approved by the CISO, with a compensating control and an expiry date not exceeding 180 days.

gs://attestor-505506-corporate/security/vulnerability-management-policy.txt

24. What is your post-quantum cryptography readiness posture?

security · Q24 · Vendor Security Review row 25

Kestrel has begun its transition toward post-quantum cryptography readiness by completing a comprehensive cryptographic inventory (`SEC-GOV/crypto-inventory`, 19 January 2026). At the edge, TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement when supported by the connecting client. While post-quantum key agreement is supported at the edge, no migration commitment date has been established for internal services (Encryption Standard, Section 6, "Post-quantum posture").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 6. Post-quantum posture — relevance 0.70

6. Post-quantum posture

Kestrel completed a cryptographic inventory (`SEC-GOV/crypto-inventory`, 19 January 2026) as the first step toward post-quantum readiness. TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement where the client supports it. No migration commitment date has been set for internal services.

gs://attestor-505506-corporate/security/encryption-standard.txt

[2] encryption-standard — Encryption Standard — relevance 0.57

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporate/security/encryption-standard.txt

[3] encryption-standard — 5. Algorithm policy — relevance 0.54

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

gs://attestor-505506-corporate/security/encryption-standard.txt

[4] encryption-standard — 2. Data in transit — relevance 0.53

2. Data in transit

TLS 1.3 is the default for all external connections. TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004), scheduled for decommission in Q3 2026 and tracked as RISK-2025-0088. TLS 1.0 and 1.1 were disabled across all endpoints on 12 April 2024.

Cipher suites are restricted to the Mozilla Intermediate profile. HSTS is enabled with

gs://attestor-505506-corporate/security/encryption-standard.txt

[5] encryption-standard — 3. Key management — relevance 0.52

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporate/security/encryption-standard.txt

25. For which data are you the controller?

legal · Q25 · Vendor Security Review row 26

Kestrel Data acts as a data controller for a limited set of personal data where it determines the purposes and means of processing: * **Account Administration Data:** Contact and identity details for customer tenant administrators, including name, work email, job title, and company (*Data Processing Agreement*, Section 1; *Privacy Policy*, Section 2; *GDPR Records of Processing*, Part B). * **Billing and Financial Data:** Billing contact details, VAT numbers, and payment method tokens used for invoicing and tax compliance (*Privacy Policy*, Section 2; *GDPR Records of Processing*, Part B). * **Product Telemetry:** Pseudonymous usage events, feature usage, page views, and error events generated across the platform (*Data Processing Agreement*, Section 1; *Privacy Policy*, Section 2; *GDPR Records of Processing*, Part B). * **Customer Support Records:** Support ticket content and related correspondence (*Privacy Policy*, Section 2). * **Prospect and Marketing Contacts:** Contact information (name, work email, company) gathered for marketing communications (*Privacy Policy*, Section 2; *GDPR Records of Processing*, Part B; *Data Subject Rights Procedure*, Section 1). * **Recruitment and Personnel Data:** Job applicant materials (CVs, interview notes) and employee/contractor HR administration records (*Privacy Policy*, Section 2; *GDPR Records of Processing*, Part B; *Data Subject Rights Procedure*, Section 1). For all customer content and data uploaded or processed through the Kestrel Insight platform, Kestrel operates solely as a data processor (or sub-processor), with the customer remaining the controller (*Data Processing Agreement*, Section 1; *Data Subject Rights Procedure*, Section 1).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 1. Roles — relevance 0.69

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.68

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[3] privacy-policy — 2. What we collect as controller — relevance 0.67

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corpus/legal/privacy-policy.txt

[4] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.66

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[5] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.65

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

|---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

| C3 | Pro

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

26. Please confirm: What service credits apply if the availability commitment is missed?

legal · Q26 · Vendor Security Review row 27

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

27. Do you use organisation-level guardrails to enforce security configuration?

security · Q27 · Vendor Security Review row 28

No supporting evidence was found in the corpus for this question.

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

28. Do engineers receive secure development training?

security · Q28 · Vendor Security Review row 29

Yes. In addition to general security awareness training, all engineers complete role-specific secure development training annually, as well as within 60 days of hire (`information-security-policy`, Section 6. Personnel security; `personnel-security-and-training`, Section 6. Secure development training). The 2025 curriculum comprised Secure Code Warrior's OWASP Top 10 path along with an internal module on tenant isolation developed by the platform team following the INSEC-2026-0219 penetration test. As of 19 December 2025, completion across all 63 in-scope engineers was 100% (`personnel-security-and-training`, Section 6. Secure development training).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] personnel-security-and-training — 6. Secure development training — relevance 0.75

6. Secure development training

Engineers complete role-specific secure development training annually, in addition to the general awareness training. The 2025 curriculum was Secure Code Warrior's OWASP Top 10 path plus an internal module on tenant isolation written by the platform team after the INSEC-2026-0219 penetration test. Completion for the 63 engineers in scope was 100% as of 19 December 20

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[2] information-security-policy — 6. Personnel security — relevance 0.65

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corpus/security/information-security-policy.txt

[3] personnel-security-and-training — 4. Security awareness training — relevance 0.63

4. Security awareness training

Security awareness training is **mandatory** for all personnel, annually, plus at onboarding within the first 14 days. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[4] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.62

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[5] personnel-security-and-training — 7. How security responsibilities are communicated — relevance 0.61

7. How security responsibilities are communicated

Responsibilities are communicated four ways, deliberately overlapping: the offer pack and onboarding session; the annual policy acknowledgement; a standing item in the monthly all-hands delivered by the CISO; and the `#security` Slack channel, which is the documented route for reporting anything suspicious and is monitored during business hours

wit

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

29. Describe your API authentication mechanism.

engineering · Q29 · Vendor Security Review row 30

Kestrel Data's public API accepts two credential types for authentication: **OAuth 2.0 bearer tokens** issued via the client-credentials flow, which are valid for 60 minutes and scoped to a single tenant and an explicit permission set. This is the recommended integration path. **API keys** for server-to-server use, presented as a bearer token and scoped in the same manner. Every request must be authenticated, as there is no anonymous surface aside from the status endpoint and the OpenAPI documentation. Requests lacking a valid credential return an HTTP 401 response without disclosing information regarding whether the tenant or requested resource exists (``api-and-integration-standard`, "1. API authentication"`). Customers manage their API credentials directly through the tenant administrator console, where they can create, scope, rotate, and revoke credentials independently. Permissions can be restricted to read-only access, specific datasets, and source IP allowlists. When revoked, credentials become invalid across all regions within 30 seconds (``api-and-integration-standard`, "2. Customer control of API credentials"`). API keys are displayed only once upon creation and cannot be recovered by Kestrel support or engineering (``api-and-integration-standard`, "2. Customer control of API credentials"; `secrets-management-standard`, "6. Customer-issued API credentials"`).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] api-and-integration-standard — 1. API authentication — relevance 0.66

1. API authentication

The public API at ``https://api.kestreldata.com/v2`` accepts two credential types:

OAuth 2.0 bearer tokens issued through the client-credentials flow, valid for 60 minutes, scoped to a single tenant and to an explicit permission set. This is the recommended integration path.

API keys for simple server-to-server use, presented as a bearer token, scoped the same

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[2] api-and-integration-standard — API, Authentication and Integration Standard — relevance 0.63

API, Authentication and Integration Standard

Document ID: KD-ENG-005 · **Version:** 2.6 · **Owner:** Dana Whitfield, VP Engineering

Approved: 21 January 2026 · **Next review:** 21 January 2027

Maps to: SOC 2 CC6.1, CC6.6, CC8.1 · ISO 27001:2022 A.5.15, A.8.5, A.8.26

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[3] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.62

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

[4] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.61

2. Customer control of API credentials

Customers create, scope, rotate, and revoke their own API credentials from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

Kestrel support cannot recover a customer API key. K

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[5] api-and-integration-standard — 9. Integration security review — relevance 0.60

9. Integration security review

A new first-party integration is reviewed against this standard before release, covering

credential handling, scope minimisation, rate limiting, and audit event emission. The review is recorded in the pull request and is a required check on the 'kd-api' repository.

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

30. Is your organisation subject to any pending litigation relating to data protection?

legal · Q30 · Vendor Security Review row 31

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] legal-and-regulatory-history — 1. Litigation — relevance 0.69

1. Litigation

****Kestrel Data is not a party to any pending litigation relating to data protection, privacy, or information security**, and has not been since incorporation in 2019.**

The company has been party to two commercial disputes in total, neither involving personal data, security, or availability:

Matter	Year	Nature	Outcome
Kestrel Data, Inc. v. Northbeam Anal			

gs://attestor-505506-corporus/legal/legal-and-regulatory-history.txt

[2] dpia-register — Data Protection Impact Assessment Register — relevance 0.66

Data Protection Impact Assessment Register

****Document ID:** KD-LEG-011 · ****Version:** 1.9 · ****Owner:** Priya Raghunathan, DPO******

****Approved:** 16 January 2026 · ****Next review:** 16 January 2027****

****Maps to:** GDPR Articles 35, 36, 9, 8, 22**

gs://attestor-505506-corporus/legal/dpia-register.txt

[3] legal-and-regulatory-history — 2. Regulatory enforcement — relevance 0.64

2. Regulatory enforcement

****Kestrel Data has never been subject to a regulatory enforcement action, fine, consent decree, undertaking, or formal investigation** by any data protection authority, sectoral regulator, or competition authority. No supervisory authority has issued Kestrel a reprimand, order, or corrective measure under Article 58 of the GDPR.**

Kestrel has never made a personal data bre

gs://attestor-505506-corporus/legal/legal-and-regulatory-history.txt

[4] legal-and-regulatory-history — 6. Legal hold — relevance 0.63

6. Legal hold

Kestrel operates a documented legal hold process, owned by the General Counsel. On becoming aware of reasonably anticipated litigation or an investigation, the General Counsel issues a written hold notice identifying custodians and data sources, and suspension of the ordinary retention schedule is applied in Google Vault and by disabling the relevant retention jobs. Holds are reviewe

gs://attestor-505506-corporus/legal/legal-and-regulatory-history.txt

[5] legal-and-regulatory-history — 3. Complaints — relevance 0.63

3. Complaints

Two data subject complaints have been received directly since 2019, both from individuals whose employers were Kestrel customers, and both resolved by directing the complainant to their employer as controller with an explanation of the roles. Neither complainant escalated to a supervisory authority.

gs://attestor-505506-corporus/legal/legal-and-regulatory-history.txt

31. Provide evidence that your security controls are independently verified.

security · Q31 · Vendor Security Review row 32

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

32. Is your platform multi-tenant or single-tenant?

engineering · Q32 · Vendor Security Review row 33

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

33. What open source licences are prohibited in your codebase? Provide supporting evidence.

engineering · Q33 · Vendor Security Review row 34

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

34. Were any Critical or High findings identified in the most recent test?

security · Q34 · Vendor Security Review row 35

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

35. Have TLS 1.0 and TLS 1.1 been disabled across all endpoints? If not, describe compensating controls.

security · Q35 · Vendor Security Review row 36

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

36. Does the CISO have a reporting line independent of executive management?

security · Q36 · Vendor Security Review row 37

Yes. Kestrel Data's Chief Information Security Officer (CISO) has a direct reporting line to the Board Audit & Risk Committee that is independent of executive management (the CEO), ensuring that security concerns cannot be suppressed by management (*Information Security Policy*, Section 2. Governance). Additionally, the CISO reports operationally to the Chief Executive Officer rather than engineering or technology leadership, and maintains a standing right of direct access to the board (*Risk Management and Governance*, Section 1. Executive accountability).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 1. Executive accountability — relevance 0.65

1. Executive accountability

****Marcus Oyelaran, Chief Information Security Officer, is accountable for information security at Kestrel Data.**** The CISO reports to the Chief Executive Officer, not to the VP Engineering or the CTO, so that a security objection cannot be resolved by the person whose delivery schedule it obstructs. The CISO has a standing right of direct access to the board and exercises

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] company-and-security-programme-overview — 4. Governance — relevance 0.62

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] information-security-policy — 2. Governance — relevance 0.61

2. Governance

Security governance sits with the Security Council, chaired by the CISO and meeting monthly. Standing members are the CISO, VP Engineering (Dana Whitfield), General Counsel (Aaron Feldstein), Head of IT (Sofia Brenner), and the Data Protection Officer (Priya Raghunathan). Minutes are retained for seven years in Confluence space `SEC-GOV`.

The Board Audit & Risk Committee receives a

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] risk-management-and-governance — 2. Board oversight — relevance 0.61

2. Board oversight

The board receives a formal information security report at each quarterly meeting, presented by the CISO. The standing agenda covers: the risk register movement since the last meeting, incidents and their classification, certification and audit status, the results of penetration testing, and any exception granted above the CISO's own approval threshold. Board meetings covering s

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] risk-management-and-governance — 3. Security Steering Group — relevance 0.61

3. Security Steering Group

A Security Steering Group meets **monthly** and comprises the CISO (chair), VP Engineering, Head of IT, General Counsel, and DPO. It approves policy changes, reviews the risk register, and decides on exceptions. Minutes are retained for seven years and are made available to auditors; they are not shared with customers, but the decisions they record are reflected in the S

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

37. Was cross-tenant data access achieved during penetration testing?

security · Q37 · Vendor Security Review row 38

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

38. What encryption algorithm and key length is used for data at rest?

security · Q38 · Vendor Security Review row 39

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

39. Provide your current list of subprocessors. Provide supporting evidence.

legal · Q39 · Vendor Security Review row 40

Kestrel Data maintains an active list of authorized infrastructure and operational subprocessors (KD-LEG-002, Version 6.4, last updated 1 February 2026, published at `kestreldata.com/subprocessors`). ### Infrastructure Subprocessors * **Amazon Web Services, Inc.:** Provides cloud hosting, compute, storage, and database services in the US (`us-east-1`, `us-west-2`) and EU (`eu-west-1`, `eu-central-1`). Transfers are governed by Standard Contractual

Clauses (SCCs) and the AWS Data Processing Addendum (DPA), with EU customer data maintained within the EU (engaged since March 2019). * **Snowflake Inc.**: Provides the analytics data warehouse, hosted in the US (AWS `us-east-1`) and EU (AWS `eu-west-1`). Transfers are governed by SCCs, with a dedicated EU deployment for EU customers (engaged since August 2021). * **Cloudflare, Inc.**: Provides CDN, WAF, DDoS protection, and zero-trust access across a global edge network, with EU traffic terminated within the EU under Regional Services. Transfers are governed by SCCs and the Cloudflare DPA (engaged since January 2020). ### Operational Subprocessors * **Datadog, Inc.**: Utilized for observability, logging, and APM in the US and on an EU site (`datadoghq.eu`) for EU customers, under SCCs (engaged since June 2020). * **Okta, Inc.**: Utilized for identity and access management in the US and within an EU cell for EU customers, under SCCs (engaged since February 2021). * **Twilio SendGrid**:: Utilized for transactional email delivery in the US, under SCCs (engaged since March 2019). * **Zendesk, Inc.**: Utilized for customer support ticketing in the US with an enabled EU data centre option, under SCCs (engaged since September 2020). * **Stripe, Inc.**: Utilized for payment processing involving billing contacts only, located in the US and Ireland, under SCCs (engaged since March 2019). **Supporting Evidence:** * `subprocessor-list`, Section "Subprocessor List" * `subprocessor-list`, Section "Infrastructure subprocessors" * `subprocessor-list`, Section "Operational subprocessors"

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] subprocessor-list — Subprocessor List — relevance 0.77

Subprocessor List

Document ID: KD-LEG-002 · **Version:** 6.4 · **Owner:** Priya Raghunathan, DPO

Last updated: 1 February 2026 · **Published at:** `kestreldata.com/subprocessors`

Change notice: 30 days, subscribe at `kestreldata.com/subprocessors/subscribe`

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[2] subprocessor-list — Infrastructure subprocessors — relevance 0.74

Infrastructure subprocessors

| Subprocessor | Purpose | Location of processing | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Amazon Web Services, Inc. | Cloud hosting, compute, storage, database | US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)

| SCCs + AWS DPA; EU data stays in EU | Mar 2019 |

| Snowflake Inc. | Analytics data warehouse | US (AWS `us-east-1`);

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[3] subprocessor-list — Operational subprocessors — relevance 0.71

Operational subprocessors

| Subprocessor | Purpose | Location | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Datadog, Inc. | Observability, logs, APM | US; EU site (`datadoghq.eu`) for EU customers | SCCs | Jun 2020 |

| Okta, Inc. | Identity and access management | US; EU cell for EU customers | SCCs | Feb 2021 |

| Twilio SendGrid | Transactional email delivery | US | SCCs | Ma

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[4] subprocessor-list — EU data residency — relevance 0.59

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[5] subprocessor-list — Changes in the last 12 months — relevance 0.58

Changes in the last 12 months

| Date | Change | Notice given |

|---|---|---|

| 12 Nov 2025 | Added Cloudflare Zero Trust (existing vendor, new purpose) | 30 days, no objections |

| 4 Jun 2025 | Removed Segment, Inc. (product analytics discontinued) | N/A, removal |

| 18 Feb 2025 | Added Snowflake EU deployment for EU instance | 30 days, no objections |

40. Confirm whether any customer data is processed outside the stated regions.

legal · Q40 · Vendor Security Review row 41

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

41. Can an engineer deploy directly to production, bypassing the pipeline?

engineering · Q41 · Vendor Security Review row 42

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

42. Do you address Swiss FADP requirements? If not, describe compensating controls.

legal · Q42 · Vendor Security Review row 43

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

43. Who is your lead supervisory authority?

legal · Q43 · Vendor Security Review row 44

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

44. What audit rights do you grant customers? If not, describe compensating controls.

legal · Q44 · Vendor Security Review row 45

Under Kestrel's Data Processing Agreement (DPA), customers are granted the right to audit Kestrel's compliance once per twelve-month period upon 30 days' written notice (`master-agreement-summary`, Section 6, "Audit rights"). Additional audits are permitted following a personal data breach affecting the customer or upon instruction from a supervisory authority. All audits must be conducted during normal business hours, cannot unreasonably disrupt operations, and are subject to confidentiality obligations (`master-agreement-summary`, Section 6, "Audit rights"). Furthermore, customers exercising audit rights under the DPA can review redacted records of the Data Subject Rights (DSR) register (`data-subject-rights-procedure`, Section 9, "Records"). As an initial step to satisfy audit requests efficiently, Kestrel provides third-party assurance artifacts, including its SOC 2 Type II report, ISO 27001 certificate, penetration test executive summary, and a completed CAIQ. However, this report-first approach is a starting point rather than a refusal; if a customer's regulator or internal policy mandates an on-site or questionnaire-based audit, Kestrel accommodates the request (`master-agreement-summary`, Section 6, "Audit rights").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] master-agreement-summary — 6. Audit rights — relevance 0.63

6. Audit rights

Customers may audit Kestrel's compliance with the DPA **once per twelve-month period on 30 days' written notice**, with additional audits permitted following a personal data breach affecting the customer or on a supervisory authority's instruction. Audits are conducted during business hours, must not unreasonably disrupt operations, and are subject to confidentiality.

Kestrel firs

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[2] data-subject-rights-procedure — 9. Records — relevance 0.57

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] master-agreement-summary — Master Subscription Agreement — Summary of Key Terms — relevance 0.56

Master Subscription Agreement — Summary of Key Terms

****Document ID:**** KD-LEG-014 · ****Version:**** 3.2 · ****Owner:**** Aaron Feldstein, General Counsel

****Approved:**** 28 January 2026 · ****Next review:**** 28 January 2027

****Maps to:**** SOC 2 CC2.3, CC9.1 · GDPR Article 28

*A summary for review purposes. The executed agreement governs; where this summary and an executed contract differ, the contract prevails.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[4] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.55

1. Which rights, and against whom

For customer content, Kestrel is the ****processor**** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within ****3 business days****. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[5] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.55

Data Subject Rights Procedure

****Document ID:**** KD-LEG-007 · ****Version:**** 2.3 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

45. What test coverage threshold is enforced in CI?

engineering · Q45 · Vendor Security Review row 46

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

46. Provide an overview of your information security programme.

security · Q46 · Vendor Security Review row 47

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

47. Have you appointed a Data Protection Officer? Provide contact details. Provide supporting evidence.

legal · Q47 · Vendor Security Review row 48

Yes, Kestrel Data has appointed a Data Protection Officer (DPO). **Contact Details:** **Data Protection Officer:** Priya Raghunathan **Email:** `dpo@kestreldata.com` **Address:** Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA **EU Representative (Art. 27 GDPR):** Instant EU Rep Ltd, Dublin, Ireland **Lead Supervisory Authority:** Irish Data Protection Commission **Supporting Evidence:** **Privacy Policy** (KD-LEG-003), Section 1 ("Controller and contact")

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (8)

[1] dpia-register — Data Protection Impact Assessment Register — relevance 0.70

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporus/legal/dpia-register.txt

[2] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.70

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[3] privacy-policy — Privacy Policy — relevance 0.68

Privacy Policy

Document ID: KD-LEG-003 · **Version:** 4.0 · **Owner:** Priya Raghunathan, DPO

Effective: 15 January 2026 · **Published at:** `kestreldata.com/privacy`

This policy describes how Kestrel Data, Inc. handles personal data where Kestrel is the **controller**. Where Kestrel processes personal data on behalf of a business customer, that customer is the controller and its own

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] privacy-policy — 1. Controller and contact — relevance 0.67

1. Controller and contact

Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA.

EU representative under Art. 27 GDPR: Instant EU Rep Ltd, Dublin, Ireland.

Data Protection Officer: Priya Raghunathan, `dpo@kestreldata.com`.

Lead supervisory authority: Irish Data Protection Commission.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] data-retention-schedule — Data Retention Schedule — relevance 0.66

Data Retention Schedule

Document ID: KD-LEG-004 · **Version:** 3.2 · **Owner:** Priya Raghunathan, DPO

Approved: 15 January 2026 · **Next review:** 15 January 2027

Maps to: GDPR Art. 5(1)(e) · SOC 2 C1.2 · ISO 27001:2022 A.5.33, A.8.10

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[6] privacy-policy — 7. Complaints — relevance 0.63

7. Complaints

Complaints may be made to the Irish Data Protection Commission or to the supervisory authority of the data subject habitual residence.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[7] privacy-policy — 5. Your rights — relevance 0.61

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent.

California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[8] privacy-policy — 2. What we collect as controller — relevance 0.59

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate intere

gs://attestor-505506-corporus/legal/privacy-policy.txt

48. Provide your current list of subprocessors.

legal · Q48 · Vendor Security Review row 49

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

49. Do you offer on-premises or self-hosted deployment?

engineering · Q49 · Vendor Security Review row 50

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

50. Please confirm: What controls remain the responsibility of the customer?

engineering · Q50 · Vendor Security Review row 51

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

51. How are secrets stored and rotated?

security · Q51 · Vendor Security Review row 52

Kestrel Data manages, stores, and rotates secrets using a tiered, defense-in-depth model: * **Application Secrets and Tokens:** Application-level field encryption is applied to authentication secrets, API tokens, and OAuth refresh tokens using AES-256-GCM. The corresponding keys are stored securely in AWS Secrets Manager and rotated every 90 days (`encryption-standard`, Section 1: "Data at rest"). * **Customer Encryption Keys:** Encryption keys are managed as AWS KMS Customer Managed Keys (CMKs). Automatic annual rotation is enabled across all CMKs, and manual rotation is triggered immediately upon suspected compromise. Access to keys is strictly limited to named service roles with a separation of duties between key administrators and key users enforced by AWS Service Control Policies (`encryption-standard`, Section 3: "Key management"). * **Workload and Machine Credentials:** Workloads authenticate using short-lived credentials via AWS IAM Roles for Service Accounts (IRSA) in EKS and Workload Identity Federation in GCP. Long-lived static access keys are strictly prohibited, enforced by automated hourly scans that alert the on-call SRE upon detection (`access-control-standard`, Section 8: "Service accounts and machine identity"). * **Administrative and Break-Glass Credentials:** Emergency break-glass credentials are stored in a sealed 1Password vault and trigger immediate alerting to the CISO whenever accessed (`access-control-standard`, Section 1: "Identity provider").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (11)

[1] encryption-standard — Encryption Standard — relevance 0.69

Encryption Standard

****Document ID:**** KD-SEC-003 · ****Version:**** 2.4 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 8 January 2026 · ****Next review:**** 8 January 2027

****Maps to:**** SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] information-security-policy — 8. Cryptography — relevance 0.66

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] information-security-policy — 5. Information classification — relevance 0.64

5. Information classification

All information is classified into one of four tiers. Handling requirements are defined in the Data Handling Standard (KD-SEC-004).

- ****Restricted**** — customer production data, credentials, private keys, personal data.

Encrypted at rest and in transit, access logged, need-to-know only.

- ****Confidential**** — source code, architecture documents, contracts, financials.

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] data-handling-standard — Data Handling Standard — relevance 0.64

Data Handling Standard

****Document ID:**** KD-SEC-004 · ****Version:**** 2.4 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 15 January 2026 · ****Next review:**** 15 January 2027

****Maps to:**** SOC 2 CC6.1, CC6.7, C1.1 · ISO 27001:2022 A.5.12, A.5.13, A.8.10, A.8.11, A.8.12

gs://attestor-505506-corporus/security/data-handling-standard.txt

[5] encryption-standard — 3. Key management — relevance 0.64

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporus/security/encryption-standard.txt

[6] encryption-standard — 1. Data at rest — relevance 0.63

1. Data at rest

All customer data at rest is encrypted using ****AES-256-GCM****. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporus/security/encryption-standard.txt

[7] access-control-standard — 8. Service accounts and machine identity — relevance 0.59

8. Service accounts and machine identity

Workloads authenticate using short-lived credentials: AWS IAM Roles for Service Accounts (IRSA) in EKS, and Workload Identity Federation for GCP components. Long-lived static

access keys are prohibited; the last was decommissioned on 17 November 2024. Automated detection for newly created static keys runs hourly and pages the on-call SRE.

gs://attestor-505506-corporus/security/access-control-standard.txt

[8] access-control-standard — 1. Identity provider — relevance 0.58

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[9] encryption-standard — 2. Data in transit — relevance 0.56

2. Data in transit

****TLS 1.3**** is the default for all external connections. TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004), scheduled for decommission in Q3 2026 and tracked as RISK-2025-0088. TLS 1.0 and 1.1 were disabled across all endpoints on 12 April 2024.

Cipher suites are restricted to the Mozilla Intermediate profile. HSTS is enabled with

gs://attestor-505506-corporus/security/encryption-standard.txt

[10] encryption-standard — 5. Algorithm policy — relevance 0.53

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

gs://attestor-505506-corporus/security/encryption-standard.txt

[11] encryption-standard — 4. Customer-managed encryption keys — relevance 0.52

4. Customer-managed encryption keys

Enterprise-tier customers may supply their own key material for the Snowflake data layer through Tri-Secret Secure. As of 1 February 2026, 3 customers use this option. CMEK is ****not**** currently offered for the RDS or S3 tiers. That limitation is stated explicitly in the Security Addendum (KD-LEG-008) rather than glossed over.

gs://attestor-505506-corporus/security/encryption-standard.txt

52. Are manual production console changes permitted?

engineering · Q52 · Vendor Security Review row 53

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

53. What is your contractual availability commitment?

engineering · Q53 · Vendor Security Review row 54

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

54. Does the availability commitment apply to all pricing tiers?

legal · Q54 · Vendor Security Review row 55

No, the availability commitment does not apply to all pricing tiers. Kestrel provides a 99.9% monthly uptime commitment with service credits for customers on the Enterprise and Growth tiers, as detailed in the Availability SLA (KD-ENG-007). No availability SLA applies to the Starter tier ("security-addendum", Section 6, "Availability commitment").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] security-addendum — 6. Availability commitment — relevance 0.74

6. Availability commitment
99.9% monthly uptime for Enterprise and Growth tiers, with service credits as set out in the Availability SLA (KD-ENG-007). No availability SLA applies to the Starter tier.

gs://attestor-505506-corporate/legal/security-addendum.txt

[2] security-addendum — 8. Changes — relevance 0.63

8. Changes
Kestrel may update this addendum, provided that no update materially reduces the commitments during a paid term. Material changes are notified 30 days in advance.

gs://attestor-505506-corporate/legal/security-addendum.txt

[3] security-addendum — 5. Testing commitments — relevance 0.62

5. Testing commitments
- Independent penetration test at least **annually**; executive summary available under NDA.
- Vulnerability remediation to the SLAs in KD-SEC-006: Critical 7 days, High 30 days.
- Disaster recovery restore tested at least **quarterly**.

gs://attestor-505506-corporate/legal/security-addendum.txt

[4] security-addendum — 1. Certifications maintained — relevance 0.61

1. Certifications maintained
Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days**

gs://attestor-505506-corporate/legal/security-addendum.txt

[5] security-addendum — 2. Encryption commitments — relevance 0.60

2. Encryption commitments
- Customer data encrypted at rest using AES-256 or stronger.
- Customer data encrypted in transit using TLS 1.2 or higher; TLS 1.3 is the default.
- Encryption keys managed in a dedicated key management service with role separation.

gs://attestor-505506-corporate/legal/security-addendum.txt

55. Do you impose equivalent data protection obligations on subprocessors?

legal · Q55 · Vendor Security Review row 56

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

56. Do you act as a service provider under the CCPA?

legal · Q56 · Vendor Security Review row 57

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

57. Will you sign a Business Associate Agreement under HIPAA?

legal · Q57 · Vendor Security Review row 58

No. Kestrel does not sign Business Associate Agreements (BAAs) and does not accept protected health information (PHI) (Master Agreement Summary, Section 4; Legal and Regulatory History, Section 7). Kestrel Insight is not designed for PHI, is not HITECH-configured, and Kestrel's Acceptable Use terms explicitly prohibit uploading PHI. Furthermore, Kestrel is not a covered entity or business associate under HIPAA, and currently has zero executed BAAs (Master Agreement Summary, Section 4; Legal and Regulatory History, Section 7). Customers whose use cases require processing PHI should not select Kestrel for those workloads.

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] master-agreement-summary — 4. HIPAA and Business Associate Agreements — relevance 0.67

4. HIPAA and Business Associate Agreements

****Kestrel does not sign Business Associate Agreements and does not accept protected health information.**** Kestrel Insight is not designed for PHI, is not HITECH-configured, and the Acceptable Use terms prohibit uploading it. ****Zero BAAs are currently executed.**** A customer whose use case requires PHI should not select Kestrel for that workload, and Kestrel

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[2] legal-and-regulatory-history — 7. Regulatory scope — relevance 0.57

7. Regulatory scope

Kestrel is not a regulated financial institution, is not a covered entity or business associate under HIPAA (see KD-LEG-014 §4), is not a federal contractor, and is not subject to sectoral supervision. Its obligations arise from general data protection law, its contracts, and the certifications it chooses to maintain.

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[3] legal-and-regulatory-history — 8. Statements in this document — relevance 0.56

8. Statements in this document

Every statement above is confirmed by the General Counsel as at the approval date and is restated at each annual review. Where a customer requires a contemporaneous confirmation, the General Counsel will provide one in writing at the point of contracting; several customers require this annually and it is provided as a matter of course.

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[4] master-agreement-summary — 8. Assignment and change of control — relevance 0.55

8. Assignment and change of control

Neither party may assign without the other's consent, except to a successor in a merger or sale of substantially all assets, subject to notice. Where the acquirer is a competitor of the customer, the customer may terminate within 30 days of notice.

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[5] master-agreement-summary — 9. Subcontracting — relevance 0.55

9. Subcontracting

Sub-processing is governed by the DPA: a public list (KD-LEG-006), ****30 days' notice**** before adding or replacing a sub-processor, a right to object on reasonable data protection grounds, and termination without penalty if the objection cannot be resolved.

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

58. Provide your public privacy policy.

legal · Q58 · Vendor Security Review row 59

Kestrel Data's public Privacy Policy (Document ID: KD-LEG-003, Version 4.0) is published at `kestreldata.com/privacy`. This policy details how Kestrel Data, Inc. handles personal data in instances where Kestrel acts as the controller. In scenarios where Kestrel processes personal data on behalf of a business customer, the customer acts as the controller governed by its own privacy notice and Kestrel's Data Processing Addendum (KD-LEG-001) (`privacy-policy`, section "Privacy Policy").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — Privacy Policy — relevance 0.62

Privacy Policy

Document ID: KD-LEG-003 · **Version:** 4.0 · **Owner:** Priya Raghunathan, DPO
Effective: 15 January 2026 · **Published at:** `kestreldata.com/privacy`

This policy describes how Kestrel Data, Inc. handles personal data where Kestrel is the **controller**. Where Kestrel processes personal data on behalf of a business customer, that customer is the controller and its own

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] privacy-policy — 6. International transfers — relevance 0.62

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

[3] privacy-policy — 4. Cookies — relevance 0.62

4. Cookies

The marketing site uses strictly necessary cookies plus, with consent, analytics cookies (Plausible, which is cookieless, and Google Analytics 4 where consent is given). The application uses only strictly necessary cookies: a session cookie and a CSRF token. A consent banner meeting EDPB guidance is served to EEA, UK, and Swiss visitors, with reject as prominent as accept.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] privacy-policy — 7. Complaints — relevance 0.61

7. Complaints

Complaints may be made to the Irish Data Protection Commission or to the supervisory authority of the data subject habitual residence.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] privacy-policy — 2. What we collect as controller — relevance 0.61

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

59. How many government data requests did you receive last year?

legal · Q59 · Vendor Security Review row 60

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

60. Was cross-tenant data access achieved during penetration testing? If not, describe compensating controls.

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (13)

[1] pen-test-executive-summary — 3. Findings summary — relevance 0.71

3. Findings summary
| Severity | Found | Remediated | Retest verified |
|---|---|---|---|
| Critical | 0 | - | - |
| High | 1 | 1 | 18 March 2026 |
| Medium | 4 | 4 | 18 March 2026 |
| Low | 7 | 5 | 18 March 2026 |
| Informational | 9 | Accepted / tracked | - |

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[2] pen-test-executive-summary — Penetration Test Executive Summary — relevance 0.69

Penetration Test Executive Summary
****Document ID:**** KD-SEC-007 · ****Engagement:**** INSEC-2026-0219
****Tester:**** Include Security, Inc. · ****Dates:**** 3-14 February 2026
****Report issued:**** 24 February 2026 · ****Retest completed:**** 18 March 2026
****Classification:**** Confidential - shareable with customers under NDA

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[3] pen-test-executive-summary — 1. Scope — relevance 0.67

1. Scope
- Kestrel Insight web application (`app.kestreldata.com`), authenticated and unauthenticated surfaces
- Public REST API v2 (`api.kestreldata.com`), 89 endpoints
- Multi-tenant isolation testing across 3 seeded tenant accounts
- AWS cloud configuration review (IAM, S3, VPC, EKS)
- Authentication and session management, including the Okta SAML integration

Out of scope: physical se

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[4] pen-test-executive-summary — 2. Methodology — relevance 0.65

2. Methodology
Grey-box testing against OWASP ASVS 4.0 Level 2 and the OWASP API Security Top 10. Testers were given standard-tier and admin-tier credentials for each seeded tenant plus API documentation. 74 person-hours across two testers.

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[5] network-security-standard — 10. Testing — relevance 0.65

10. Testing
Network controls are exercised annually by the external penetration test. The February 2026 test (Include Security, INSEC-2026-0219) attempted lateral movement from a compromised application container and did not achieve it; the finding raised was the rate limiting gap on the password reset endpoint, remediated on 27 February 2026.

gs://attestor-505506-corporus/security/network-security-standard.txt

[6] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.65

6. Handling a vulnerability with no upstream fix
Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by

Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix
|

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[7] pen-test-executive-summary — 4. The High finding — relevance 0.65

4. The High finding

INSEC-2026-0219-H1 - Insufficient rate limiting on the password reset endpoint.

`POST /v2/auth/password-reset` was not rate limited per account, permitting user enumeration through response timing and, in combination with a slow SMTP path, a potential mail-flood against a targeted address. No authentication bypass was possible and no data was exposed.

Remediated on

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[8] pen-test-executive-summary — 7. Tester statement — relevance 0.64

7. Tester statement

**Kestrel Data demonstrates a mature security posture for an organisation of its size.

Tenant isolation is well implemented and defence in depth is evident throughout the platform. The single High finding was an availability and privacy concern rather than a confidentiality one.** - Include Security, 24 February 2026

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[9] cloud-security-posture-standard — 1. Account structure and guardrails — relevance 0.61

1. Account structure and guardrails

Kestrel runs an AWS Organization with six accounts and a dedicated management account that holds no workloads. **Organisation-level Service Control Policies enforce security configuration centrally**, so a misconfiguration in a member account is refused by the platform rather than caught later by a report. The enforced SCPs are:

| SCP | Effect |

|---|---|

| `de

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[10] soc2-control-matrix — Complementary user entity controls — relevance 0.61

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[11] network-security-standard — 3. Segmentation — relevance 0.60

3. Segmentation

Each environment is a separate AWS account inside the AWS Organization (`kd-prod-us`, `kd-prod-eu`, `kd-staging`, `kd-dev`, `kd-security`, `kd-shared-services`). There is **no VPC peering and no transit gateway route between production and non-production**; the boundary is an account boundary, not a firewall rule that can be edited.

Within a production VPC there are three subnet t

gs://attestor-505506-corporus/security/network-security-standard.txt

[12] network-security-standard — 7. Container security — relevance 0.58

7. Container security

Workloads run on EKS with:

* non-root user enforced (`runAsNonRoot: true`) and read-only root filesystems;

* all Linux capabilities dropped except `NET\_BIND\_SERVICE`;

* Pod Security Admission in `restricted` mode at the namespace level, which rejects a non-conforming workload at admission rather than reporting it later;
* network policies denying pod-to-pod traffic by default

gs://attestor-505506-corporate/security/network-security-standard.txt

[13] network-security-standard — 6. Internal application access — relevance 0.58

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporate/security/network-security-standard.txt

61. What is your notification window for confirmed unauthorised access to production data?

security · Q61 · Vendor Security Review row 62

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] information-security-policy — 9. Incident response — relevance 0.66

9. Incident response

Security incidents are handled under the Incident Response Runbook (KD-SEC-005). Kestrel commits contractually to notifying affected customers within 72 hours of confirming a personal data breach, and within 24 hours for incidents involving confirmed unauthorised access to customer production data.

gs://attestor-505506-corporate/security/information-security-policy.txt

[2] logging-monitoring-standard — 4. Alerting — relevance 0.65

4. Alerting

Detections run in Datadog Security Monitoring. Alert routing is by severity through PagerDuty. Current detection coverage includes impossible-travel sign-ins, MFA fatigue patterns, IAM policy changes granting broad permissions, disabling of CloudTrail or GuardDuty, unusual Snowflake export volume, and break-glass account use.

Alert quality is reviewed monthly. Alerts with a false

gs://attestor-505506-corporate/security/logging-monitoring-standard.txt

[3] incident-response-runbook — 4. Customer notification commitments — relevance 0.64

4. Customer notification commitments

These are contractual and are reproduced in the DPA (KD-LEG-001) and the Security Addendum (KD-LEG-008):

- **Personal data breach** - affected customers notified without undue delay and in any event **within 72 hours** of Kestrel confirming the breach.
- **Confirmed unauthorised access to customer production data** - affected customers notified **within 24 hours**

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[4] incident-response-runbook — 1. Severity definitions — relevance 0.63

1. Severity definitions

| Sev | Definition | Page | Exec notify |

|---|---|---|---|

| **SEV1** | Confirmed unauthorised access to customer production data, or full platform outage | Immediate, 24/7 | CEO + CISO within 30 min |

| **SEV2** | Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault | Immediate, 24/7 | CISO within 1 hour |

| **SEV3**

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 9. 2025 incident summary — relevance 0.63

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- ****INC-2025-0044**** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.

- ****INC-2025-0071**** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

62. For each applicable system: Who holds the encryption keys for customer data?

engineering · Q62 · Vendor Security Review row 63

Kestrel manages encryption and key management for its systems as part of its shared responsibility model. For all data tier systems storing customer data—including account identity and usage data in Aurora PostgreSQL, as well as customer-uploaded datasets in Snowflake and S3—data is encrypted at rest using AES-256-GCM under AWS KMS keys. These keys are held in AWS KMS within the instance's own region (`us-east-1` for the US instance or `eu-west-1` for the EU instance), and key material never leaves AWS KMS (data-flow-and-shared-responsibility, "1. Data flow, end to end" and "3. The shared responsibility model"; secrets-management-standard, "1. Where secrets live"). Additionally, system backups are encrypted with AES-256 using AWS KMS, with daily logical dumps utilizing a separate Customer Master Key (CMK) from the primary database (backup-restore-procedure, "2. Encryption and location").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (8)

[1] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.69

1. Data flow, end to end

1. ****Ingress**** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. ****Instance selection**** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. ****A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[2] backup-restore-procedure — 2. Encryption and location — relevance 0.66

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a ****separate CMK**** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.66

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[4] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.65

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

****Kestrel is responsible for:****

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.64

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another jurisdiction.**

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[6] cloud-exit-and-portability-plan — 4. Estimated exit timeline — relevance 0.64

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

| Phase | Work | Estimate |

|---|---|---|

| 1 | Target selection, landing zone, network and identity foundation | 4–6 weeks |

| 2 | Terraform provider rewrite, CI/CD retargeting | 6–8 weeks |

| 3 | Data migration — Snowflake region move, PostgreSQL logical replication, ob

gs://attestor-505506-corporate-engineering/cloud-exit-and-portability-plan.txt

[7] secrets-management-standard — 1. Where secrets live — relevance 0.63

1. Where secrets live

| Secret class | Store | Rotation |

|---|---|---|

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corporate-engineering/secrets-management-standard.txt

[8] cloud-exit-and-portability-plan — 8. Testing — relevance 0.62

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporate-engineering/cloud-exit-and-portability-plan.txt

63. Do you deploy endpoint detection and response on all company devices?

security · Q63 · Vendor Security Review row 64

Yes. CrowdStrike Falcon is deployed on 100% of managed endpoints (including all macOS laptops and Linux workstations) as well as all production compute nodes (*Endpoint Protection and Data Loss Prevention Standard*, Section 2, "Endpoint detection and response"; Section 1, "Managed devices"). Coverage is reconciled nightly against our Kandji and AWS inventories, and any device identified in inventory without Falcon active triggers an alert and a ticket to the Head of IT within one business day. High- and Critical-severity detections route to the security alerts channel and automatically page the on-call engineer (*Endpoint Protection and Data Loss Prevention Standard*, Section 2, "Endpoint detection and response").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] endpoint-protection-standard — 2. Endpoint detection and response — relevance 0.64

2. Endpoint detection and response

****CrowdStrike Falcon is deployed on 100% of managed endpoints and on all production compute nodes.**** Coverage is reconciled nightly against the Kandji and AWS inventories, and a device present in inventory but absent from Falcon raises a ticket to the Head of IT within one business day. The reconciliation found two gaps during 2025, both new contractor laptops, b

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[2] endpoint-protection-standard — 8. Patching of endpoints — relevance 0.61

8. Patching of endpoints

Operating system updates are enforced within 14 days of release for standard updates and 72 hours for updates addressing a Critical vulnerability, with a Kandji deferral window that cannot be extended by the user. Measured compliance at the last audit point (1 February 2026) was 168 of 174 devices within policy, the remaining six being on extended leave with access suspend

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[3] endpoint-protection-standard — Endpoint Protection and Data Loss Prevention Standard — relevance 0.60

Endpoint Protection and Data Loss Prevention Standard

****Document ID:**** KD-SEC-015 · ****Version:**** 2.2 · ****Owner:**** Sofia Brenner, Head of IT
****Approved:**** 19 January 2026 · ****Next review:**** 19 January 2027
****Maps to:**** SOC 2 CC6.6, CC6.8, CC7.1 · ISO 27001:2022 A.8.1, A.8.7, A.8.12, A.8.16

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[4] endpoint-protection-standard — 4. Disk encryption — relevance 0.59

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[5] endpoint-protection-standard — 1. Managed devices — relevance 0.59

1. Managed devices

Every device with access to Kestrel systems is company-owned and centrally managed. There is no bring-your-own-device programme for laptops. As of 1 February 2026 the estate is 163 macOS laptops managed by Kandji and 11 Linux workstations managed by Fleet; there are no Windows endpoints in use.

Enrolment is a precondition of access: Cloudflare Access performs a device posture c

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

64. Can customers export their data in a machine-readable format?

engineering · Q64 · Vendor Security Review row 65

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (11)

[1] cloud-exit-and-portability-plan — no section recorded — relevance 0.69

A customer may leave at any time and take their data with them: * full self-service export of all customer-uploaded datasets in their original format, plus ...

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[2] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.67

Cloud Exit and Portability Plan

****Document ID:**** KD-ENG-010 · ****Version:**** 1.7 · ****Owner:**** Dana Whitfield, VP Engineering
****Approved:**** 30 January 2026 · ****Next review:**** 30 January 2027
****Maps to:**** SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[3] cloud-exit-and-portability-plan — 6. Customer's own exit from Kestrel — relevance 0.66

6. Customer's own exit from Kestrel

Distinct from Kestrel's exit from AWS, and more likely to be what a reviewer is asking about. A customer may leave at any time and take their data with them:

- * full self-service export of all customer-uploaded datasets in their original format, plus account identity data and usage events as JSON or CSV;
- * the same through the public API, with no volume charge

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] cloud-exit-and-portability-plan — 5. Customer-facing continuity during an exit — relevance 0.64

5. Customer-facing continuity during an exit

An exit would be executed instance by instance, with EU and US cut over separately, and **data residency commitments would be honoured throughout**: an EU tenant would move to an EU region of the target provider, never transiting a US region. Customers would be given a minimum of 90 days' notice of a planned provider change and would retain their export

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.60

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

Layer	Technology	Portability
Compute	Kubernetes (EKS)	High — standard manifests, no EKS-specific APIs in workloads
Container images	OCI in ECR	High — registry is a copy operation
Data warehouse	Snowflake	Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[6] data-flow-and-shared-responsibility — 2. What crosses a boundary, and what does not — relevance 0.60

2. What crosses a boundary, and what does not

Data	Leaves the tenant's region?
Customer-uploaded analytics datasets	No
Backups of customer content	No
Account identity data (EU tenants)	Only for support access, under §4 of KD-SEC-002
Pseudonymised product telemetry	Yes — aggregated to the US, assessed in KD-LEG-010
Operational logs (content-redacted)	

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[7] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.59

1. Data flow, end to end

- Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
- Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[8] cloud-exit-and-portability-plan — 4. Estimated exit timeline — relevance 0.59

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

Phase	Work	Estimate
1	Target selection, landing zone, network and identity foundation	4–6 weeks
2	Terraform provider rewrite, CI/CD retargeting	6–8 weeks
3	Data migration — Snowflake region move, PostgreSQL logical replication, ob	

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[9] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.58

- * deciding what data they upload, and its lawfulness — Kestrel does not inspect it;
- * configuring SSO, and enforcing MFA at their own identity provider;
- * managing their own users, roles, and permissions, including timely removal of leavers;
- * the scope, storage, and rotation of the API credentials they create;
- * reviewing their own audit log, which Kestrel makes available for 13 months;
- * acting

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[10] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.57

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No processing occurs outside the stated regions****, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[11] cloud-exit-and-portability-plan — 8. Testing — relevance 0.56

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

65. In which cloud regions is the production platform hosted?

legal · Q65 · Vendor Security Review row 66

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

66. Is there board-level oversight of information security?

security · Q66 · Vendor Security Review row 67

Yes, Kestrel Data maintains formal board-level oversight of information security. The Board receives a formal information security report presented quarterly by the Chief Information Security Officer (CISO) (`risk-management-and-governance`, Section 2. Board oversight; `information-security-policy`, Section 2. Governance). The standing agenda covers: - Risk register movement since the previous meeting - Incidents and their classifications - Certification and audit status - Penetration testing results - Any policy or security exceptions granted above the CISO's approval threshold The Board has specifically designated Elaine Vasquez, a non-executive director and former CIO of a regulated financial services firm, as the director with designated security oversight responsibility (`risk-management-and-governance`, Section 2. Board oversight). Additionally, the CISO maintains an independent direct reporting line and a standing right of direct access to the Board and the Board Audit & Risk Committee, ensuring security matters can be escalated independently of executive management (`risk-management-and-governance`, Section 1. Executive accountability; `information-security-policy`, Section 2. Governance).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 2. Board oversight — relevance 0.70

2. Board oversight

The board receives a formal information security report at each quarterly meeting, presented by the CISO. The standing agenda covers: the risk register movement since the last meeting, incidents and their classification, certification and audit status, the results of penetration testing, and any exception granted above the CISO's own approval

threshold. Board meetings covering s

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] company-and-security-programme-overview — 4. Governance — relevance 0.67

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] information-security-policy — 2. Governance — relevance 0.66

2. Governance

Security governance sits with the Security Council, chaired by the CISO and meeting monthly. Standing members are the CISO, VP Engineering (Dana Whitfield), General Counsel (Aaron Feldstein), Head of IT (Sofia Brenner), and the Data Protection Officer (Priya Raghunathan). Minutes are retained for seven years in Confluence space `SEC-GOV`.

The Board Audit & Risk Committee receives a

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] risk-management-and-governance — 1. Executive accountability — relevance 0.66

1. Executive accountability

****Marcus Oyelaran, Chief Information Security Officer, is accountable for information security at Kestrel Data.**** The CISO reports to the Chief Executive Officer, not to the VP Engineering or the CTO, so that a security objection cannot be resolved by the person whose delivery schedule it obstructs. The CISO has a standing right of direct access to the board and exercises

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] risk-management-and-governance — 3. Security Steering Group — relevance 0.64

3. Security Steering Group

A Security Steering Group meets ****monthly**** and comprises the CISO (chair), VP Engineering, Head of IT, General Counsel, and DPO. It approves policy changes, reviews the risk register, and decides on exceptions. Minutes are retained for seven years and are made available to auditors; they are not shared with customers, but the decisions they record are reflected in the S

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

67. Do you publish a transparency report of government data requests?

legal · Q67 · Vendor Security Review row 68

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

68. Can a developer approve their own pull request?

engineering · Q68 · Vendor Security Review row 69

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

69. What is the governing law of your standard agreement?

legal · Q69 · Vendor Security Review row 70

No supporting evidence was found in the corpus for this question.

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

70. Do you undergo independent audit of your security controls?

security · Q70 · Vendor Security Review row 71

Yes, Kestrel undergoes independent audits and assessments of its security controls: - **SOC 2 Type II Examination:** Conducted annually by Prescient Assurance LLP. The most recent examination covered 1 January through 31 December 2025 and was issued on 14 March 2026 with no exceptions (‘company-and-security-programme-overview’, Section 3; ‘risk-management-and-governance’, Section 7). - **ISO 27001:2022 Certification:** Audited and certified by BSI under certificate ‘IS-2025-44817’, issued 22 September 2025 and valid through 21 September 2028, supported by regular surveillance audits (‘company-and-security-programme-overview’, Section 3; ‘risk-management-and-governance’, Section 7). - **Independent Penetration Testing:** Conducted annually by Include Security, with the most recent test performed between 3 and 14 February 2026 (‘company-and-security-programme-overview’, Section 3; ‘risk-management-and-governance’, Section 7). Additionally, control operation is continuously monitored via Vanta across automated checks with failures routed directly to control owners (‘risk-management-and-governance’, Section 7).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 7. Internal audit — relevance 0.67

7. Internal audit

Kestrel is too small to maintain a separate internal audit function, and says so rather than claiming one. Independent assurance comes from the annual SOC 2 Type II examination (Prescient Assurance LLP), the ISO 27001 surveillance audits (BSI), and the annual penetration test (Include Security). Control operation is monitored continuously by Vanta across 187 automated checks, wit

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] soc2-control-matrix — Common Criteria — relevance 0.65

Common Criteria

Control	Description	Evidence	Test result
---------	-------------	----------	-------------

---	---	---	---
-----	-----	-----	-----

CC1.1	Board oversight of security; Audit and Risk Committee meets quarterly	Committee minutes, 4 meetings in 2025	No exceptions
-------	---	---------------------------------------	---------------

CC1.4	Security awareness training at hire and annually	Curricula completion records, 100% of active staff	No exceptions
-------	--	--	---------------

CC2.1	Internal communication of securit		
-------	-----------------------------------	--	--

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[3] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.62

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. **Independent verification.** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, **no exceptions**) and ISO 27001:2022 (BSI certificate ‘IS-2025-44817’, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] risk-management-and-governance — Risk Management and Security Governance — relevance 0.62

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] soc2-control-matrix — Complementary user entity controls — relevance 0.61

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including

managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

71. Please confirm: Do you maintain Records of Processing Activities under Article 30?

legal · Q71 · Vendor Security Review row 72

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

72. How many changes were deployed to production in the last year?

engineering · Q72 · Vendor Security Review row 73

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

73. Describe your network segmentation approach.

security · Q73 · Vendor Security Review row 74

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

74. Will EU customer data ever be processed outside the EEA, including backups?

legal · Q74 · Vendor Security Review row 75

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

75. Please confirm: Provide the results of your most recent disaster recovery test.

engineering · Q75 · Vendor Security Review row 76

Kestrel Data tests restore and disaster recovery procedures quarterly via a full restore into an isolated account. The most recent test was conducted on 17 January 2026 (Q1 2026), completing in 2 hours and 41 minutes with a passing outcome and 1,240 out of 1,240 integrity assertions passed (‘backup-restore-procedure’, Section 4 “Test results”).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 4. Test results — relevance 0.70

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.61

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 3. Restore procedure — relevance 0.58

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — Backup and Restore Procedure — relevance 0.57

Backup and Restore Procedure

****Document ID:**** KD-ENG-004 · ****Version:**** 2.5 · ****Owner:**** Sofia Brenner, Head of IT
****Approved:**** 29 January 2026 · ****Maps to:**** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.55

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | ****35 days**** |

| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

76. Are shared or team accounts permitted?

security · Q76 · Vendor Security Review row 77

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] acceptable-use-policy — 3. Credentials — relevance 0.63

3. Credentials

Credentials are personal and may not be shared, including with other Kestrel staff. Shared team accounts are prohibited. Where a shared credential is unavoidable for a third-party service that does not support SSO, it is held in a 1Password shared vault with access logged, and the service is recorded on the SSO-gap register.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[2] acceptable-use-policy — 4. Data handling — relevance 0.60

4. Data handling

Restricted data may not be copied to personal cloud storage, personal email, USB media, or unmanaged devices. USB mass storage is blocked at the OS level on all managed devices.

Screen sharing during customer calls must use a dedicated demo tenant, never production.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[3] acceptable-use-policy — Acceptable Use Policy — relevance 0.56

Acceptable Use Policy

****Document ID:**** KD-SEC-011 · ****Version:**** 2.3 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 15 January 2026 · ****Next review:**** 15 January 2027

****Applies to:**** all employees, contractors, and anyone issued Kestrel credentials

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[4] acceptable-use-policy — 5. Email and communications — relevance 0.54

5. Email and communications

Kestrel uses Google Workspace with DMARC set to `p=reject`, SPF, and DKIM enforced on all sending domains. External email is banner-tagged. Automatic forwarding to external addresses is disabled at the tenant level and cannot be enabled by end users.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[5] acceptable-use-policy — 1. Company devices — relevance 0.54

1. Company devices

All laptops are company-owned and managed through Kandji (macOS) or Intune (Windows). Personal devices may not access Restricted or Confidential data. BYOD is permitted only for calendar and chat through managed applications with app-level containerisation.

Required device posture, enforced continuously and checked at every Cloudflare Access authentication: full-disk encry

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

77. How do you detect configuration drift in production infrastructure?

engineering · Q77 · Vendor Security Review row 78

Production infrastructure is managed exclusively through Terraform within the `kestrel-infra` repository, and manual changes via the AWS console are strictly prohibited. Automated drift detection runs every 6 hours, raising a SEV3 alert upon identifying any unmanaged change (`change-management-procedure`, Section 4. Infrastructure changes).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] change-management-procedure — 4. Infrastructure changes — relevance 0.66

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository. Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] change-management-procedure — Change Management Procedure — relevance 0.54

Change Management Procedure

****Document ID:**** KD-ENG-002 · ****Version:**** 3.0 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 20 January 2026 · ****Maps to:**** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] change-management-procedure — 1. Change classes — relevance 0.53

1. Change classes

Class	Definition	Approval	Example
-------	------------	----------	---------

---	---	---	---
-----	-----	-----	-----

Standard	Pre-approved, low risk, automated	PR review + CI	Application code, config change through IaC
---------------------	-----------------------------------	----------------	---

Normal	Material risk or customer-visible	PR review + Change Advisory sign-off	Schema migration, dependency major version
-------------------	-----------------------------------	--------------------------------------	--

Emergency	Fixing an active SEV1/SEV2	Retrospective with	
----------------------	----------------------------	--------------------	--

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[4] change-management-procedure — 2. Normal change requirements — relevance 0.53

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE).

Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[5] change-management-procedure — 5. Database changes — relevance 0.53

5. Database changes

Migrations run through Atlas with a plan-and-approve step. Destructive operations (column drop, table drop) require a two-phase deployment separated by at least one release: the column is first stopped being read, then dropped in a later release.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

78. For each applicable system: Do you undergo independent audit of your security controls?

security · Q78 · Vendor Security Review row 79

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

79. Have TLS 1.0 and TLS 1.1 been disabled across all endpoints?

security · Q79 · Vendor Security Review row 80

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

80. In which jurisdictions is customer data processed?

legal · Q80 · Vendor Security Review row 81

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

81. What is the maximum age of a production compute node?

engineering · Q81 · Vendor Security Review row 82

Production compute node images are immutable, and nodes are recycled with a maximum age of 30 days rather than being patched in place (Infrastructure Architecture Overview, Section 3. Compute).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 3. Compute — relevance 0.62

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.56

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the

Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.54

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

| Instance | Region | Serves |

|---|---|---|

| US | `us-east-1` (3 AZs) | North America, and customers with no residency requirement |

| EU | `eu-west-1` (3 AZs) | EEA, UK, and Swiss customers electing EU residency |

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 2. Account structure — relevance 0.53

2. Account structure

AWS Organizations with 9 accounts: `management`, `security-tooling`, `log-archive`, `shared-services`, `prod-us`, `prod-eu`, `staging`, `dev`, `sandbox`. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The `log-archive` account has no

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.52

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

82. Will you execute a Data Processing Agreement?

legal · Q82 · Vendor Security Review row 83

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

83. Do engineers receive secure development training? Provide supporting evidence.

engineering · Q83 · Vendor Security Review row 84

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

84. For each applicable system: Describe your process for responding to government requests for customer data.

legal · Q84 · Vendor Security Review row 85

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.68

Government Requests Policy and Transparency Report

****Document ID:**** KD-LEG-012 · ****Version:**** 2.0 · ****Owner:**** Aaron Feldstein, General Counsel

****Approved:**** 2 February 2026 · ****Next review:**** 2 February 2027

****Maps to:**** GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 1. Who may receive a request — relevance 0.68

1. Who may receive a request

All law enforcement, regulatory, and national security requests for customer data must be directed to the General Counsel at `legal@kestreldata.com`. No other person at Kestrel is authorised to accept service or to disclose customer data to a government authority.

Support, sales, and engineering personnel are trained to route any such approach to the General Counsel wi

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[3] government-requests-and-transparency-report — 2. How a request is handled — relevance 0.66

2. How a request is handled

1. ****Log.**** The request is recorded in the government request register on the day of receipt, with the requesting authority, the legal instrument, and the data sought.

2. ****Validate.**** The General Counsel, with outside counsel where warranted, assesses whether the instrument is valid, whether it is binding on Kestrel in the jurisdiction concerned, and whether i

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[4] government-requests-and-transparency-report — 6. Records — relevance 0.66

6. Records

The government request register is retained for ten years and is available to the auditors and, in redacted form, to a customer exercising audit rights. Retention is longer than the ordinary schedule deliberately: the value of this record is precisely that it goes back further than anyone's memory.

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[5] data-subject-rights-procedure — 9. Records — relevance 0.64

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

85. Do you have a documented exit plan from your cloud provider?

engineering · Q85 · Vendor Security Review row 86

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.72

Cloud Exit and Portability Plan

****Document ID:**** KD-ENG-010 · ****Version:**** 1.7 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 30 January 2026 · ****Next review:**** 30 January 2027

****Maps to:**** SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[2] cloud-exit-and-portability-plan — 2. Exit triggers — relevance 0.69

2. Exit triggers

The plan would be invoked on: sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or a security failure at the provider that could not be compensated for.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[3] cloud-exit-and-portability-plan — 5. Customer-facing continuity during an exit — relevance 0.67

5. Customer-facing continuity during an exit

An exit would be executed instance by instance, with EU and US cut over separately, and ****data residency commitments would be honoured throughout****: an EU tenant would move to an EU region of the target provider, never transiting a US region. Customers would be given a minimum of 90 days' notice of a planned provider change and would retain their export

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] cloud-exit-and-portability-plan — 4. Estimated exit timeline — relevance 0.66

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

Phase	Work	Estimate
1	Target selection, landing zone, network and identity foundation	4–6 weeks
2	Terraform provider rewrite, CI/CD retargeting	6–8 weeks
3	Data migration — Snowflake region move, PostgreSQL logical replication, ob	

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.65

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

Layer	Technology	Portability
Compute	Kubernetes (EKS)	High — standard manifests, no EKS-specific APIs in workloads
Container images	OCI in ECR	High — registry is a copy operation
Data warehouse	Snowflake	Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[6] cloud-exit-and-portability-plan — 8. Testing — relevance 0.60

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

86. Have you appointed an EU representative under Article 27?

legal · Q86 · Vendor Security Review row 87

Yes, Kestrel Data has appointed Instant EU Rep Ltd, located in Dublin, Ireland, as its EU representative under Article 27 of the GDPR (Privacy Policy, Section 1, "Controller and contact").

Release status: No — held for a human · confidence low · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — 1. Controller and contact — relevance 0.52

1. Controller and contact

Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA.
EU representative under Art. 27 GDPR: Instant EU Rep Ltd, Dublin, Ireland.
Data Protection Officer: Priya Raghunathan, `dpo@kestreldata.com`.
Lead supervisory authority: Irish Data Protection Commission.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] privacy-policy — 7. Complaints — relevance 0.51

7. Complaints

Complaints may be made to the Irish Data Protection Commission or to the supervisory authority of the data subject habitual residence.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[3] privacy-policy — 2. What we collect as controller — relevance 0.51

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] privacy-policy — 6. International transfers — relevance 0.49

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] privacy-policy — 4. Cookies — relevance 0.46

4. Cookies

The marketing site uses strictly necessary cookies plus, with consent, analytics cookies (Plausible, which is cookieless, and Google Analytics 4 where consent is given). The application uses only strictly necessary cookies: a session cookie and a CSRF token. A consent banner meeting EDPB guidance is served to EEA, UK, and Swiss visitors, with reject as prominent as accept.

gs://attestor-505506-corporus/legal/privacy-policy.txt

87. What is your Recovery Point Objective?

engineering · Q87 · Vendor Security Review row 88

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

88. What is your remediation SLA for Critical severity vulnerabilities?

security · Q88 · Vendor Security Review row 89

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

89. Describe your approach to environmental sustainability and carbon reporting.

unassigned · Q89 · Vendor Security Review row 90

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

90. How much notice is given before scheduled maintenance?

engineering · Q90 · Vendor Security Review row 91

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.71

2. Scheduled maintenance

The standard maintenance window is ****Sundays 06:00–10:00 UTC****. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

****Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting**, and 30 days' notice where the change requires customer a**

`gs://attestor-505506-corpus/engineering/service-operations-and-support.txt`

[2] change-management-procedure — 6. Customer notification — relevance 0.63

6. Customer notification

Customers are notified at least ****7 days**** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum ****12 months**** notice, with the deprecated version remaining available throughout.

`gs://attestor-505506-corpus/engineering/change-management-procedure.txt`

[3] service-operations-and-support — 7. Incident communication to customers — relevance 0.59

7. Incident communication to customers

Customer-facing incident communication is owned by the incident commander and follows the commitments in KD-SEC-008 §4. In practice: status page inside 15 minutes, direct email to affected tenant administrators inside 60 minutes for a Sev 1, and a written post-incident review within 5 business days for any Sev 1 or Sev 2, shared with affected customers on req

`gs://attestor-505506-corpus/engineering/service-operations-and-support.txt`

[4] change-management-procedure — 7. Change freeze — relevance 0.58

7. Change freeze

A change freeze applies from 20 December to 2 January, and during any active SEV1. Only Emergency changes are permitted during a freeze.

`gs://attestor-505506-corpus/engineering/change-management-procedure.txt`

[5] service-operations-and-support — 8. Capacity and performance — relevance 0.57

8. Capacity and performance

Capacity is reviewed monthly against a 90-day forecast. Autoscaling handles ordinary variation; the review exists for the changes autoscaling cannot absorb, such as a large tenant onboarding. Two capacity increases were made ahead of demand in 2025, neither triggered by a saturation alert.

`gs://attestor-505506-corpus/engineering/service-operations-and-support.txt`

91. For each applicable system: How do workloads authenticate to cloud services?

engineering · Q91 · Vendor Security Review row 92

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

92. Do you support SCIM user provisioning?

security · Q92 · Vendor Security Review row 93

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

93. Please confirm: How do you detect prohibited licences?

engineering · Q93 · Vendor Security Review row 94

Licence compliance is detected automatically in the CI pipeline using FOSSA on every pull request (`third-party-library-policy`, Section 2. Licence policy). If a prohibited licence—such as GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, or any licence lacking a clear grant—is introduced, the build automatically fails. Additionally, adding any new direct dependency requires a pull request where the licence is explicitly verified against the approved licence allowlist (`third-party-library-policy`, Section 1. Adding a dependency).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 2. Licence policy — relevance 0.57

2. Licence policy

****Allowed:**** MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

****Requires legal review:**** MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.50

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — Third-Party Library Policy — relevance 0.49

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 7. Internal forks — relevance 0.48

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains ****zero**** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.47

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

94. Do Kestrel personnel routinely access customer production data? Provide supporting evidence.

security · Q94 · Vendor Security Review row 95

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorization recorded in Zendesk, is restricted to the specific customer tenant, and automatically expires after 24 hours. As evidence of this control in practice, between January 1 and December 31, 2025, there were 19 authorized accesses across 7 customers, all of which are evidenced and audited under control CC6.1 in Kestrel's SOC 2 Type II report (`access-control-standard`, Section 5, "Customer data access").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 5. Customer data access — relevance 0.81

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] incident-response-runbook — 4. Customer notification commitments — relevance 0.76

4. Customer notification commitments

These are contractual and are reproduced in the DPA (KD-LEG-001) and the Security Addendum (KD-LEG-008):

- **Personal data breach** - affected customers notified without undue delay and in any event **within 72 hours** of Kestrel confirming the breach.

- **Confirmed unauthorised access to customer production data** - affected customers notified **with**

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] information-security-policy — 9. Incident response — relevance 0.76

9. Incident response

Security incidents are handled under the Incident Response Runbook (KD-SEC-005). Kestrel commits contractually to notifying affected customers within 72 hours of confirming a personal data breach, and within 24 hours for incidents involving confirmed unauthorised access to customer production data.

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] information-security-policy — 1. Purpose and scope — relevance 0.74

1. Purpose and scope

This policy establishes how Kestrel Data, Inc. ("Kestrel") protects the confidentiality, integrity, and availability of information belonging to Kestrel and to customers of the Kestrel Insight platform.

It applies to all 187 employees and to all 24 contractors engaged as of 1 February 2026, to every system that processes Kestrel or customer data, and to all facilities includi

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] physical-and-environmental-security — 1. Production infrastructure — relevance 0.74

1. Production infrastructure

Kestrel Data operates **no owned or leased data centre**. All production infrastructure runs in AWS: `us-east-1` for the US instance and `eu-west-1` for the EU instance.

Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corporus/security/physical-and-environmental-security.txt

95. Are you self-certified under the EU-US Data Privacy Framework? Provide supporting evidence.

legal · Q95 · Vendor Security Review row 96

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

96. Provide evidence of your most recent user access review. If not, describe compensating controls.

security · Q96 · Vendor Security Review row 97

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

97. For each applicable system: Provide an overview of your information security programme.

security · Q97 · Vendor Security Review row 98

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.70

Company and Security Programme Overview

Document ID: KD-SEC-021 · **Version:** 4.2 · **Owner:** Marcus Oyelaran, CISO

Approved: 6 February 2026 · **Next review:** 6 February 2027

Maps to: SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[2] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.68

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. **Independent verification:** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, **no exceptions**) and ISO 27001:2022 (BSI certificate 'IS-2025-44817', issued 22 September 2025, valid to 21

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[3] company-and-security-programme-overview — 4. Governance — relevance 0.68

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[4] risk-management-and-governance — 8. Policy management — relevance 0.66

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corpus/security/risk-management-and-governance.txt

[5] personnel-security-and-training — 4. Security awareness training — relevance 0.66

4. Security awareness training

Security awareness training is **mandatory** for all personnel, annually, plus at onboarding within the first 14 days. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[6] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.66

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

98. How many employees and contractors does your organisation have?

unassigned · Q98 · Vendor Security Review row 99

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

99. Provide your Information Security Policy.

security · Q99 · Vendor Security Review row 100

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

100. Which module of the 2021 Standard Contractual Clauses do you use?

legal · Q100 · Vendor Security Review row 101

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] standard-contractual-clauses-summary — Standard Contractual Clauses and Transfer Impact Assessment - Summary — relevance 0.68

Standard Contractual Clauses and Transfer Impact Assessment - Summary

Document ID: KD-LEG-006 · **Version:** 2.2 · **Owner:** Aaron Feldstein, General Counsel

Last updated: 28 January 2026 · **Next review:** 28 January 2027

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

[2] standard-contractual-clauses-summary — 1. Which clauses apply — relevance 0.65

1. Which clauses apply

Kestrel incorporates the **2021 EU Standard Contractual Clauses** (Commission Implementing Decision (EU) 2021/914 of 4 June 2021):

- **Module Two** (Controller to Processor) where a customer established in the EEA transfers personal data to Kestrel in the US.

- **Module Three** (Processor to Sub-processor) where a customer is itself a processor, and in Kestrel own

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

[3] standard-contractual-clauses-summary — 2. UK and Switzerland — relevance 0.63

2. UK and Switzerland

- **UK** - the ICO International Data Transfer Addendum (version B1.0, in force 21 March 2022) is appended to the EU SCCs. UK GDPR references replace EU GDPR references; the competent authority is the ICO.
- **Switzerland** - the Swiss Annex applies. The FDPIC is the competent authority, and references to Member State law are read as references to Swiss law. The SCC

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

[4] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.59

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[5] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.58

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO
Approved: 9 January 2026 · **Next review:** 9 January 2027
Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

101. How many security incidents were recorded in the last calendar year?

security · Q101 · Vendor Security Review row 102

In 2025, Kestrel Data recorded a total of 41 security events, with zero SEV1 incidents and two SEV2 incidents, both of which were resolved without customer data exposure: **INC-2025-0044** (14 August 2025): An RDS failover fault caused 41 minutes of degraded service. RPO and RTO were both met with no data loss, and the root cause was identified as a misconfigured connection pool ceiling. **INC-2025-0071** (2 November 2025): A contractor account remained active for 38 minutes following termination due to an HRIS webhook delay. Review of Okta system logs confirmed no access occurred during this window, and the issue was remediated with a reconciliation job running every 15 minutes. No customer data breach has occurred in the history of the company. *(Source: 'incident-response-runbook', Section 9. 2025 incident summary)*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 9. 2025 incident summary — relevance 0.68

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- **INC-2025-0044** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.
- **INC-2025-0071** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] soc2-control-matrix — Common Criteria — relevance 0.65

Common Criteria

| Control | Description | Evidence | Test result |

|---|---|---|---|

| CC1.1 | Board oversight of security; Audit and Risk Committee meets quarterly | Committee minutes, 4 meetings in 2025 | No exceptions |

| CC1.4 | Security awareness training at hire and annually | Curricula completion records, 100% of active staff | No exceptions |

| CC2.1 | Internal communication of securit

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[3] incident-response-runbook — 3. Lifecycle — relevance 0.64

3. Lifecycle

Detect, triage, contain, eradicate, recover, learn.

Detection sources are Datadog Security Monitoring, AWS GuardDuty, AWS Security Hub, Okta ThreatInsight, Snyk, customer reports to `security@kestreldata.com`, and the disclosure address published at `kestreldata.com/.well-known/security.txt`.

Triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2, meas

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] personnel-security-and-training — 5. Simulated phishing — relevance 0.62

5. Simulated phishing

Kestrel runs simulated phishing exercises **quarterly** through Curricula, targeting all personnel with a Kestrel mailbox. Results for 2025:

Quarter	Sent	Click rate	Credential submission	Reported to security
---------	------	------------	-----------------------	----------------------

Q1 2025	198	6.1%	1.0%	41%
---------	-----	------	------	-----

Q2 2025	203	4.4%	0.5%	52%
---------	-----	------	------	-----

Q3 2025	208	3.4%	0.0%	58%
---------	-----	------	------	-----

Q4 2025	211	2		
---------	-----	----------	--	--

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] incident-response-runbook — 1. Severity definitions — relevance 0.62

1. Severity definitions

Sev	Definition	Page	Exec notify
-----	------------	------	-------------

SEV1	Confirmed unauthorised access to customer production data, or full platform outage	Immediate, 24/7	CEO + CISO within 30 min
-------------	--	-----------------	--------------------------

SEV2	Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault	Immediate, 24/7	CISO within 1 hour
-------------	--	-----------------	--------------------

SEV3			
-------------	--	--	--

gs://attestor-505506-corporus/security/incident-response-runbook.txt

102. Do you have a documented exit plan from your cloud provider? If not, describe compensating controls.

engineering · Q102 · Vendor Security Review row 103

Yes, Kestrel Data maintains a documented **Cloud Exit and Portability Plan** (`cloud-exit-and-portability-plan`, *Cloud Exit and Portability Plan*). Key details of the plan include: * **Governance and Testing:** Running entirely on AWS is an accepted concentration risk (`RISK-2025-0044`). The exit plan is reviewed annually and was last validated through a tabletop exercise on 19 November 2025 (`cloud-exit-and-portability-plan`, *1. Why this exists*). * **Exit Triggers:** The plan is invoked in the event of sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or an uncompensable security failure at the provider (`cloud-exit-and-portability-plan`, *2. Exit triggers*). * **Portability by Design:** The platform architecture prioritizes portable technologies to minimize lock-in: * **Compute & Containers:** Standard Kubernetes (EKS) manifests without proprietary workload APIs and OCI-compliant container images. * **Data & Storage:** Snowflake (runs across AWS, Azure, and GCP), S3-compatible object storage, and Aurora PostgreSQL (migrated via logical replication). * **Decoupled Edge & Identity:** Okta (identity) and Cloudflare (edge routing/WAF) operate independently of AWS, ensuring authentication and traffic management remain unaffected during a cloud migration. * **Key Management:** Because AWS KMS keys are non-exportable by design, migration involves re-encrypting data under the target provider's KMS (`cloud-exit-and-portability-plan`, *3. Portability by design*). * **Execution & Continuity:** Based on tabletop planning, full migration across five phases is estimated at approximately 5–6 months. Migration is performed instance by instance, with EU and US tenants migrated separately. Data residency commitments are honored throughout (EU tenants migrate directly to EU regions without transiting US infrastructure). Customers receive a minimum of 90 days' advance notice of a planned provider transition while retaining full data export rights (`cloud-exit-and-portability-plan`, *4. Estimated exit timeline* and *5. Customer-facing continuity during an exit*). * **Customer Exit:** For customers wishing to exit Kestrel, the platform supports self-service and API-driven exports of customer datasets in original formats (with identity and usage logs as JSON/CSV), 30 days of post-termination export

access, and structured data deletion with certificates of destruction upon request (`cloud-exit-and-portability-plan`, *6. Customer's own exit from Kestrel*).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (8)

[1] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.74

Cloud Exit and Portability Plan

Document ID: KD-ENG-010 · **Version:** 1.7 · **Owner:** Dana Whitfield, VP Engineering

Approved: 30 January 2026 · **Next review:** 30 January 2027

Maps to: SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[2] cloud-exit-and-portability-plan — 2. Exit triggers — relevance 0.71

2. Exit triggers

The plan would be invoked on: sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or a security failure at the provider that could not be compensated for.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[3] cloud-exit-and-portability-plan — 4. Estimated exit timeline — relevance 0.69

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

| Phase | Work | Estimate |

|---|---|---|

| 1 | Target selection, landing zone, network and identity foundation | 4–6 weeks |

| 2 | Terraform provider rewrite, CI/CD retargeting | 6–8 weeks |

| 3 | Data migration — Snowflake region move, PostgreSQL logical replication, ob

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] cloud-exit-and-portability-plan — 5. Customer-facing continuity during an exit — relevance 0.68

5. Customer-facing continuity during an exit

An exit would be executed instance by instance, with EU and US cut over separately, and **data residency commitments would be honoured throughout**: an EU tenant would move to an EU region of the target provider, never transiting a US region. Customers would be given a minimum of 90 days' notice of a planned provider change and would retain their export

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.64

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

| Layer | Technology | Portability |

|---|---|---|

| Compute | Kubernetes (EKS) | High — standard manifests, no EKS-specific APIs in workloads |

| Container images | OCI in ECR | High — registry is a copy operation |

| Data warehouse | Snowflake | Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[6] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.62

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid sess

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[7] cloud-exit-and-portability-plan — 1. Why this exists — relevance 0.51

1. Why this exists

Kestrel runs entirely on AWS. That is a concentration risk, recorded as `RISK-2025-0044` and **accepted** rather than mitigated by multi-cloud, on the reasoning that operating two clouds badly is worse than operating one well at this size. Accepting a risk obliges you to know what you would do if it materialised, which is what this document is. It is reviewed annually and was la

gs://attestor-505506-corpus/engineering/cloud-exit-and-portability-plan.txt

[8] cloud-exit-and-portability-plan — 6. Customer's own exit from Kestrel — relevance 0.48

6. Customer's own exit from Kestrel

Distinct from Kestrel's exit from AWS, and more likely to be what a reviewer is asking about. A customer may leave at any time and take their data with them:

- * full self-service export of all customer-uploaded datasets in their original format, plus account identity data and usage events as JSON or CSV;
- * the same through the public API, with no volume charge

gs://attestor-505506-corpus/engineering/cloud-exit-and-portability-plan.txt

103. Do you operate a web application firewall?

security · Q103 · Vendor Security Review row 104

Yes. Cloudflare WAF is enabled across all production hostnames. It runs the Cloudflare Managed Ruleset, the OWASP Core Ruleset configured at paranoia level 2, and 14 custom Kestrel-authored rules. New rules are deployed in log mode for seven days prior to enforcement to identify potential false positives before customer traffic is affected. Additionally, edge rate limiting is enforced, configured to 120 requests per minute per tenant for the public API and 10 authentication attempts per five minutes per source address (Network Security Standard, Section 2: "Web application firewall").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (10)

[1] network-security-standard — no section recorded — relevance 0.69

Web application firewall **Cloudflare WAF is enabled on all production hostnames**, running the Cloudflare Managed Ruleset, the OWASP Core Ruleset at ...

gs://attestor-505506-corpus/security/network-security-standard.txt

[2] network-security-standard — Network Security Standard — relevance 0.66

Network Security Standard

Document ID: KD-SEC-016 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering
Approved: 5 February 2026 · **Next review:** 5 February 2027
Maps to: SOC 2 CC6.6, CC6.7, CC7.1 · ISO 27001:2022 A.8.20, A.8.21, A.8.22, A.8.23

gs://attestor-505506-corpus/security/network-security-standard.txt

[3] network-security-standard — 2. Web application firewall — relevance 0.66

2. Web application firewall

Cloudflare WAF is enabled on all production hostnames, running the Cloudflare Managed Ruleset, the OWASP Core Ruleset at paranoia level 2, and 14 Kestrel-authored rules. Rules are deployed in log mode for 7 days before enforcement so that a false positive is found before it blocks a customer. Blocked request volume averaged 41,000 per day during 2025, of which the l

gs://attestor-505506-corpus/security/network-security-standard.txt

[4] network-security-standard — 4. Inbound rules — relevance 0.64

4. Inbound rules

There are no unrestricted inbound rules (`0.0.0.0/0`) in any production security group other than ports 80 and 443 on the load balancer security group, which are themselves restricted to Cloudflare ranges. **SSH ingress is closed entirely**; administrative access is through AWS Systems Manager Session Manager, which requires an IAM identity and produces a recorded session.

Config

gs://attestor-505506-corporus/security/network-security-standard.txt

[5] network-security-standard — 9. DDoS protection — relevance 0.61

9. DDoS protection

Cloudflare provides layer 3/4 and layer 7 DDoS protection. The largest mitigated event in 2025 peaked at 18 Gbps on 3 June 2025 and caused no measurable increase in application error rate.

gs://attestor-505506-corporus/security/network-security-standard.txt

[6] network-security-standard — 6. Internal application access — relevance 0.60

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

[7] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.52

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[8] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.51

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[9] company-and-security-programme-overview — 4. Governance — relevance 0.51

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[10] company-and-security-programme-overview — 5. Named accountabilities — relevance 0.49

5. Named accountabilities

| Role | Holder |

|---|---|

| Chief Information Security Officer | Marcus Oyelaran |

| VP Engineering | Dana Whitfield |

| General Counsel | Aaron Feldstein |

| Data Protection Officer | Priya Raghunathan |

| Head of IT | Sofia Brenner |

| Board director with security oversight | Elaine Vasquez (non-executive) |

****Primary security contact for customers:**** Marcus Oyelaran

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

104. How do workloads authenticate to cloud services?

engineering · Q104 · Vendor Security Review row 105

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.59

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[2] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.58

2. Customer control of API credentials

Customers create, scope, rotate, and revoke their own API credentials from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

Kestrel support cannot recover a customer API key. K

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[3] infrastructure-architecture-overview — 2. Account structure — relevance 0.57

2. Account structure

AWS Organizations with 9 accounts: `management`, `security-tooling`, `log-archive`, `shared-services`, `prod-us`, `prod-eu`, `staging`, `dev`, `sandbox`. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The `log-archive` account has no

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 7. Observability — relevance 0.57

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant_id` and `request_id`.

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

105. How do you detect prohibited licences?

engineering · Q105 · Vendor Security Review row 106

Prohibited licences are detected automatically during continuous integration (CI) by FOSSA on every pull request. If a prohibited licence (such as GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, or any licence lacking a clear grant) is detected, the build fails (`third-party-library-policy`, Section 2: "Licence policy"). Additionally, adding any new direct dependency requires a pull request documenting the licence and verifying it against the allowlist

before approval (`third-party-library-policy`, Section 1: "Adding a dependency").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 2. Licence policy — relevance 0.60

2. Licence policy

****Allowed:**** MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

****Requires legal review:**** MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.53

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 7. Internal forks — relevance 0.50

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains ****zero**** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — Third-Party Library Policy — relevance 0.49

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.49

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

106. Do you sell personal data to third parties?

legal · Q106 · Vendor Security Review row 107

No, Kestrel does not sell personal data and has never done so. In addition, Kestrel does not share personal data with advertising networks or for cross-context behavioral advertising (Privacy Policy, §3; Data Subject Rights Procedure, §8).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — 3. What we do not do — relevance 0.68

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.65

8. California and other US state rights

Kestrel acts as a **service provider** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colora

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] privacy-policy — 2. What we collect as controller — relevance 0.63

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] privacy-policy — 5. Your rights — relevance 0.62

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent.

California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] privacy-policy — 6. International transfers — relevance 0.61

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

107. Describe how tenant isolation is enforced.

engineering · Q107 · Vendor Security Review row 108

Kestrel Insight is a multi-tenant platform utilizing logical isolation enforced across three distinct layers: 1. **Database Layer:** PostgreSQL row-level security (RLS) policies are keyed on `tenant_id` and applied at the connection level from an authenticated session variable. No application query can opt out of these policies (`infrastructure-architecture-overview`, Section 5). 2. **Application Layer:** Every incoming request carries a validated tenant claim. The data access layer refuses any query lacking a tenant predicate, a rule enforced programmatically through a repository base class rather than developer convention (`infrastructure-architecture-overview`, Section 5). 3. **Storage Layer:** All S3 object keys are tenant-prefixed, and AWS IAM policies strictly constrain data access by prefix (`infrastructure-architecture-overview`, Section 5). Isolation integrity is verified continuously through an automated test suite containing 84 assertions that attempt cross-tenant reads across every public API surface on every build (`infrastructure-architecture-overview`, Section 5; `sdhc-policy`, Section 3). Furthermore, any pull request modifying tenant isolation logic requires two approving reviews via `CODEOWNERS` before merging (`sdhc-policy`, Section 1). Tenant isolation was also independently validated during the February 2026 penetration test, with zero cross-tenant

access achieved (`infrastructure-architecture-overview`, Section 5).

Release status: No — held for a human · confidence low · drafted by EngineeringAgent

Evidence (4)

[1] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.50

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] sdlc-policy — 3. Testing requirements — relevance 0.49

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 1. Branching and review — relevance 0.47

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.46

- * deciding what data they upload, and its lawfulness — Kestrel does not inspect it;
- * configuring SSO, and enforcing MFA at their own identity provider;
- * managing their own users, roles, and permissions, including timely removal of leavers;
- * the scope, storage, and rotation of the API credentials they create;
- * reviewing their own audit log, which Kestrel makes available for 13 months;
- * acting

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

108. How long is product telemetry retained?

legal · Q108 · Vendor Security Review row 109

Kestrel retains pseudonymous product telemetry for 24 months on the basis of legitimate interests, which is reviewed annually (`data-retention-schedule`, Section 2; `dpa-annex-2-technical-measures`, Section 6; `gdpr-records-of-processing`, Part B).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-retention-schedule — 2. Kestrel-controlled data — relevance 0.70

2. Kestrel-controlled data

| Data class | Retention | Basis |

|---|---|---|

| Account and contact records | Term + 3 years | Contract, limitation periods |

| Billing and tax records | **7 years** | US and Irish tax law |

| Product telemetry | 24 months | Legitimate interests, reviewed annually |
| Support tickets | Term + 2 years | Contract |
| Marketing contacts | Until consent withdrawal +

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[2] data-retention-schedule — 1. Customer data — relevance 0.68

1. Customer data

| Data class | Active retention | Post-termination | Deletion mechanism |

|---|---|---|---|

| Customer records in the platform | Term of subscription | **30 days** export window, then deleted within **90 days** | Automated
`tenant-purge` job, nightly |

| Analytics warehouse (Snowflake) | Term | Deleted with tenant purge | Automated |

| Uploaded files (S3) | Term | Deleted with

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[3] dpa-annex-2-technical-measures — 6. Data minimisation — relevance 0.67

6. Data minimisation

The Service collects only data the customer chooses to provide. Kestrel product telemetry is pseudonymous and retained for 24 months. Kestrel does not use customer content to train machine learning models.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[4] data-retention-schedule — 6. Exceptions — relevance 0.66

6. Exceptions

Where a retention period conflicts with a customer contractual requirement, the shorter period applies unless law requires otherwise. Longer retention requires DPO approval, which has not been granted for any customer data class to date.

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[5] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.65

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

|---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

| C3 | Pro

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

109. How much notice do you provide before adding a subprocessor?

legal · Q109 · Vendor Security Review row 110

Kestrel Data provides **30 days' notice** before adding or replacing a subprocessor. Customers may object to a new subprocessor on reasonable data-protection grounds within that 30-day period. If the objection cannot be resolved, the customer may terminate the affected Service without penalty for the remainder of the prepaid term (`data-processing-agreement`, Section 5. Sub-processing; `subprocessor-list`, Section Subprocessor List).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 5. Sub-processing — relevance 0.73

5. Sub-processing

Customer grants general authorisation for the sub-processors listed at `kestreldata.com/subprocessors`. Kestrel gives **30 days** notice before adding or replacing a sub-processor. Customer may object on reasonable data-protection grounds within that period; if the objection cannot be resolved, Customer may terminate the affected Service without penalty for the remainder of t

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] subprocessor-list — Subprocessor List — relevance 0.68

Subprocessor List

****Document ID:**** KD-LEG-002 · ****Version:**** 6.4 · ****Owner:**** Priya Raghunathan, DPO

****Last updated:**** 1 February 2026 · ****Published at:**** `kestreldata.com/subprocessors`

****Change notice:**** 30 days, subscribe at `kestreldata.com/subprocessors/subscribe`

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[3] subprocessor-list — Infrastructure subprocessors — relevance 0.66

Infrastructure subprocessors

| Subprocessor | Purpose | Location of processing | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Amazon Web Services, Inc. | Cloud hosting, compute, storage, database | US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)

| SCCs + AWS DPA; EU data stays in EU | Mar 2019 |

| Snowflake Inc. | Analytics data warehouse | US (AWS `us-east-1`);

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[4] subprocessor-list — Operational subprocessors — relevance 0.65

Operational subprocessors

| Subprocessor | Purpose | Location | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Datadog, Inc. | Observability, logs, APM | US; EU site (`datadoghq.eu`) for EU customers | SCCs | Jun 2020 |

| Okta, Inc. | Identity and access management | US; EU cell for EU customers | SCCs | Feb 2021 |

| Twilio SendGrid | Transactional email delivery | US | SCCs | Ma

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[5] data-processing-agreement — 1. Roles — relevance 0.64

1. Roles

Customer is ****Controller****. Kestrel Data, Inc. is ****Processor****. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is ****Controller**** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

110. Are you self-certified under the EU-US Data Privacy Framework?

legal · Q110 · Vendor Security Review row 111

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

111. Provide the technical and organisational measures annexed to your DPA. Provide supporting evidence.

legal · Q111 · Vendor Security Review row 112

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

112. Is restore tested by performing an actual restore, or by verifying backup existence?

engineering · Q112 · Vendor Security Review row 113

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

113. Please confirm: Do you use customer content to train machine learning models?

legal · Q113 · Vendor Security Review row 114

Kestrel Data does not use customer content to train machine learning models, whether proprietary or third-party. This commitment is formally set forth in Kestrel's Master Services Agreement (MSA) rather than being solely a policy statement (`privacy-policy`, Section 3, "What we do not do"; `dpa-annex-2-technical-measures`, Section 6, "Data minimisation").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — 3. What we do not do — relevance 0.64

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] dpa-annex-2-technical-measures — 6. Data minimisation — relevance 0.62

6. Data minimisation

The Service collects only data the customer chooses to provide. Kestrel product telemetry is pseudonymous and retained for 24 months. Kestrel does not use customer content to train machine learning models.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[3] dpia-register — 5. Automated decision-making — relevance 0.59

5. Automated decision-making

Kestrel performs **no** automated decision-making producing legal effects or similarly significant effects concerning data subjects, within the meaning of Article 22. The two machine learning features described in KD-SEC-019 §2 surface information to the customer's own analysts; the decisions that follow are made by people at the customer, using the customer's own data

gs://attestor-505506-corporus/legal/dpia-register.txt

[4] dpia-register — 3. Special category data — relevance 0.58

3. Special category data

Kestrel does not knowingly process special category personal data under Article 9. The platform is not designed for it, the Acceptable Use terms in the master agreement prohibit uploading it, and no field in the data model is intended to hold it.

Kestrel cannot inspect customer-uploaded datasets — they are opaque by design — so the control is contractual and architect

gs://attestor-505506-corporus/legal/dpia-register.txt

[5] privacy-policy — 2. What we collect as controller — relevance 0.55

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

114. Are you FedRAMP authorised?

security · Q114 · Vendor Security Review row 115

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

115. Do you permit use of generative AI tools with customer data?

security · Q115 · Vendor Security Review row 116

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

116. Can a privileged administrator delete or alter audit logs?

security · Q116 · Vendor Security Review row 117

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

117. Does the platform incorporate any machine learning models that process customer data?

engineering · Q117 · Vendor Security Review row 118

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

118. What categories of customer data does the platform process?

legal · Q118 · Vendor Security Review row 119

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

119. How far back are customer-accessible audit logs available?

security · Q119 · Vendor Security Review row 120

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

120. Provide your public privacy policy. Provide supporting evidence.

legal · Q120 · Vendor Security Review row 121

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

121. For which data stores are customer-managed keys available?

engineering · Q121 · Vendor Security Review row 122

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.65

1. Data flow, end to end
1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[2] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.65

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporate-engineering/secrets-management-standard.txt

[3] secrets-management-standard — 4. Runtime access — relevance 0.61

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corporate-engineering/secrets-management-standard.txt

[4] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.61

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud co

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[5] secrets-management-standard — 1. Where secrets live — relevance 0.60

1. Where secrets live

| Secret class | Store | Rotation |

|---|---|---|

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corporate-engineering/secrets-management-standard.txt

[6] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.57

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. No processing occurs outside the stated regions, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[7] secrets-management-standard — Secrets Management Standard — relevance 0.56

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporate-engineering/secrets-management-standard.txt

122. Do you encrypt data in transit, and which TLS versions do you support?

security · Q122 · Vendor Security Review row 123

Kestrel Data encrypts all data in transit across external and internal networks: * **External Connections and Supported TLS Versions:** TLS 1.3 is the default across all external connections. TLS 1.2 remains enabled solely for a single legacy customer SFTP integration (INT-LEGACY-0004), which is tracked under RISK-2025-0088 and scheduled for decommission in Q3 2026. Support for TLS 1.0 and TLS 1.1 was disabled across all endpoints on 12 April 2024 (*Encryption Standard*, Section 2, "Data in transit"; *Information Security Policy*, Section 8, "Cryptography"). * **Configuration and Certificates:** Cipher suites follow the Mozilla Intermediate profile, and HTTP Strict Transport Security (HSTS) is enforced with `max-age=31536000; includeSubDomains; preload`. Certificates are issued via AWS Certificate Manager and rotated automatically (*Encryption Standard*, Section 2, "Data in transit"). * **Internal Service-to-Service Traffic:** Internal traffic within the EKS cluster is encrypted via mutual TLS (mTLS) enforced by Istio 1.24, with certificates rotated every 24 hours (*Encryption Standard*, Section 2, "Data in transit").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 2. Data in transit — relevance 0.71

2. Data in transit

TLS 1.3 is the default for all external connections. TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004), scheduled for decommission in Q3 2026 and tracked as RISK-2025-0088. TLS 1.0 and 1.1 were disabled across all endpoints on 12 April 2024.

Cipher suites are restricted to the Mozilla Intermediate profile. HSTS is enabled with

gs://attestor-505506-corpus/security/encryption-standard.txt

[2] information-security-policy — 8. Cryptography — relevance 0.69

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corpus/security/information-security-policy.txt

[3] encryption-standard — 1. Data at rest — relevance 0.66

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corpus/security/encryption-standard.txt

[4] encryption-standard — Encryption Standard — relevance 0.60

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corpus/security/encryption-standard.txt

[5] encryption-standard — 3. Key management — relevance 0.60

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporus/security/encryption-standard.txt

123. Which MFA factors are permitted? Are SMS or TOTP still accepted?

security · Q123 · Vendor Security Review row 124

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

124. Please confirm: In which cloud regions is the production platform hosted?

engineering · Q124 · Vendor Security Review row 125

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

125. Which transfer mechanism do you rely on for transfers out of the EEA?

legal · Q125 · Vendor Security Review row 126

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.66

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[2] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.65

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[3] standard-contractual-clauses-summary — 2. UK and Switzerland — relevance 0.63

2. UK and Switzerland

- **UK** - the ICO International Data Transfer Addendum (version B1.0, in force 21 March 2022) is appended to the EU SCCs. UK GDPR references replace EU GDPR references; the competent authority is the ICO.

- **Switzerland** - the Swiss Annex applies. The FDPIC is the competent authority, and references to Member State law are read as references to Swiss law. The SCC

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

[4] standard-contractual-clauses-summary — Standard Contractual Clauses and Transfer Impact Assessment - Summary — relevance 0.62

Standard Contractual Clauses and Transfer Impact Assessment - Summary

Document ID: KD-LEG-006 · **Version:** 2.2 · **Owner:** Aaron Feldstein, General Counsel

****Last updated:**** 28 January 2026 · ****Next review:**** 28 January 2027

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

[5] transfer-impact-assessment — 1. Status — relevance 0.61

1. Status

****Kestrel Data has completed a Transfer Impact Assessment****, most recently updated on 9 January 2026. It is refreshed annually and on any material change to the transfer chain, the receiving country's law, or the supplementary measures relied on. A copy is available to customers under NDA.

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

126. How frequently are Tier 1 vendors reassessed?

security · Q126 · Vendor Security Review row 127

Tier 1 vendors are reassessed annually, requiring a full security review with SOC 2 or ISO 27001 evidence and an executed DPA (Vendor Risk Management Policy, Section 1: "Tiering"). Additionally, Tier 1 vendors undergo continuous monitoring through SecurityScorecard, where a score drop of more than 10 points within 30 days triggers an out-of-cycle review, and attestation expirations are tracked in Vanta with alerts 60 days prior to lapse (Vendor Risk Management Policy, Section 5: "Ongoing monitoring").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] vendor-risk-management-policy — 5. Ongoing monitoring — relevance 0.73

5. Ongoing monitoring

Tier 1 vendors are monitored continuously through SecurityScorecard, with a score drop of more than 10 points in 30 days triggering review. Attestation expiry is tracked in Vanta, with a reminder at 60 days before lapse.

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[2] vendor-risk-management-policy — 1. Tiering — relevance 0.71

1. Tiering

Vendors are tiered on data sensitivity and operational dependency.

Tier	Definition	Diligence	Review
------	------------	-----------	--------

---	---	---	---
-----	-----	-----	-----

Tier 1	Processes customer production data, or an outage stops the platform	Full security review, SOC 2 or ISO 27001 evidence required, DPA required	Annual
------------	---	--	--------

Tier 2	Processes Kestrel internal or employee data	Security questionnaire, a	
------------	---	---------------------------	--

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[3] vendor-risk-management-policy — 2. Onboarding requirements — relevance 0.68

2. Onboarding requirements

No Tier 1 vendor is engaged without: a current SOC 2 Type II report or ISO 27001 certificate reviewed by the Security team; an executed DPA including the 2021 EU Standard Contractual Clauses where personal data leaves the EEA; documented data flows and retention; and a recorded exit plan.

Reviews are recorded in Vanta with the reviewer, date, evidence reviewed, and

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[4] vendor-risk-management-policy — 6. Offboarding — relevance 0.60

6. Offboarding

On termination, the vendor must certify deletion of Kestrel and customer data within 30 days. Certification is filed in the vendor record. Access is revoked on the termination date through the standard leaver process.

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[5] vendor-risk-management-policy — Vendor Risk Management Policy — relevance 0.59

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

127. Do you maintain a formal risk register? How frequently is it reviewed?

security · Q127 · Vendor Security Review row 128

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

128. Can a single customer be restored without affecting other tenants?

engineering · Q128 · Vendor Security Review row 129

Yes. A single customer can be restored without affecting other tenants by performing a restore to an isolated account and exporting that specific tenant's data back into production (`backup-restore-procedure`, Section 5 "Tenant-scoped restore" and Section 3 "Restore procedure").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.71

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 3. Restore procedure — relevance 0.64

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 6. Backup deletion — relevance 0.61

6. Backup deletion

Backups expire automatically. When a customer terminates and the tenant purge runs, backups containing that data expire on the normal cycle, a maximum of **35 days** later. Kestrel does not selectively surgically remove a tenant from historical backup images, and says so rather than implying otherwise.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — 4. Test results — relevance 0.59

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
---------	------	----------	------------	---------

---	---	---	---	---
-----	-----	-----	-----	-----

Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
---------	-------------	--------	---------------	------

Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
---------	-------------	--------	---------------	--

Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass
---------	-------------	--------	---------------	------

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — Backup and Restore Procedure — relevance 0.57

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT

Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

129. Do you process special category personal data?

legal · Q129 · Vendor Security Review row 130

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

130. Will you notify customers of a government request for their data?

legal · Q130 · Vendor Security Review row 131

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

131. What is the export window available after termination?

legal · Q131 · Vendor Security Review row 132

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

132. Do you subscribe to threat intelligence feeds?

security · Q132 · Vendor Security Review row 133

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

133. Describe your privileged access management approach for production systems.

security · Q133 · Vendor Security Review row 134

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

134. Do you support SAML or OIDC single sign-on?

security · Q134 · Vendor Security Review row 135

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

135. For each applicable system: Is your organisation subject to any pending litigation relating to data protection?

legal · Q135 · Vendor Security Review row 136

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

136. Provide your security awareness training completion rate.

security · Q136 · Vendor Security Review row 137

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

137. For each applicable system: Is restore tested by performing an actual restore, or by verifying backup existence?

engineering · Q137 · Vendor Security Review row 138

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

138. Is production data ever copied to non-production environments?

engineering · Q138 · Vendor Security Review row 139

No, production data is never copied to lower or non-production environments. Non-production environments rely exclusively on non-production data: - `local` and `ci` environments use synthetic fixtures only. - `staging` uses synthetic and anonymized data, with fixtures generated synthetically via tooling (`tools/gen\_fixtures.py`). Kestrel Data maintains no "sanitized production dump" process, ensuring customer production data remains strictly within the production environment (`sdlc-policy`, Section 2, "Environments").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 2. Environments — relevance 0.71

2. Environments

| Environment | Purpose | Data |

|---|---|---|

| `local` | Developer machines | Synthetic fixtures only |

| `ci` | Automated testing | Synthetic fixtures only |

| `staging` | Pre-production verification | Synthetic and anonymised data |

| `production` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 3. Testing requirements — relevance 0.56

3. Testing requirements

- Unit test coverage gate at ****80%**** on changed lines, enforced in CI.

- Integration tests run against ephemeral infrastructure provisioned per pull request.

- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.

- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 6. Release — relevance 0.55

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based:

5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate

or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 7. Separation of duties — relevance 0.53

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.53

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

139. Do you accept SOC 2 and ISO 27001 reports in place of a customer audit?

legal · Q139 · Vendor Security Review row 140

Kestrel first offers its SOC 2 Type II report, ISO 27001 certificate, penetration test executive summary, and completed CAIQ to satisfy customer audit requests, and in practice these satisfy the majority of audits. However, this report-first position is a starting point rather than a refusal: if a customer's regulator or internal policy requires an on-site or questionnaire-based audit, Kestrel will accommodate it upon 30 days' written notice (master-agreement-summary, Section 6 "Audit rights").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] security-addendum — 1. Certifications maintained — relevance 0.65

1. Certifications maintained

Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days**

gs://attestor-505506-corporus/legal/security-addendum.txt

[2] master-agreement-summary — 6. Audit rights — relevance 0.62

6. Audit rights

Customers may audit Kestrel's compliance with the DPA **once per twelve-month period on 30 days' written notice**, with additional audits permitted following a personal data breach affecting the customer or on a supervisory authority's instruction. Audits are conducted during business hours, must not unreasonably disrupt operations, and are subject to confidentiality.

Kestrel firs

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[3] master-agreement-summary — Master Subscription Agreement — Summary of Key Terms — relevance 0.61

Master Subscription Agreement — Summary of Key Terms

Document ID: KD-LEG-014 · **Version:** 3.2 · **Owner:** Aaron Feldstein, General Counsel

Approved: 28 January 2026 · **Next review:** 28 January 2027

Maps to: SOC 2 CC2.3, CC9.1 · GDPR Article 28

*A summary for review purposes. The executed agreement governs; where this summary and an executed contract differ, the contract prevails.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[4] dpa-annex-2-technical-measures — 4. Regular testing and evaluation (Art. 32(1)(d)) — relevance 0.59

4. Regular testing and evaluation (Art. 32(1)(d))
| Activity | Frequency | Last performed |
|---|---|---|
| Independent penetration test | Annual minimum | 3-14 February 2026 |
| SOC 2 Type II audit | Annual | Period ended 31 December 2025 |
| ISO 27001 surveillance audit | Annual | 22 September 2025 |
| Disaster recovery restore test | Quarterly | 17 January 2026 |
| User access review | Qu

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[5] dpa-annex-2-technical-measures — 5. Organisational measures — relevance 0.58

5. Organisational measures
Security governance through a monthly Security Council with a direct board reporting line;
background screening before start date; confidentiality obligations surviving employment;
annual security awareness training at 100% completion; documented incident response with a
trained IC rota; vendor risk management with tiered diligence.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

140. Do you monitor for anomalous data export volumes?

security · Q140 · Vendor Security Review row 141

Yes. Kestrel Data monitors egress from Snowflake and production S3 buckets for anomalous volume. The detection threshold is set to a rolling 7-day tenant baseline plus three standard deviations, evaluated hourly within Datadog Security Monitoring, with alerts routed by severity through PagerDuty (`data-handling-standard`, §7. Data export monitoring; `logging-monitoring-standard`, §4. Alerting).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] data-handling-standard — 7. Data export monitoring — relevance 0.75

7. Data export monitoring
Egress from Snowflake and from the production S3 buckets is monitored for anomalous volume. The threshold is a rolling 7-day tenant baseline plus three standard deviations, evaluated hourly in Datadog. Two alerts fired in 2025, both traced to legitimate customer-initiated bulk exports and closed the same day.

gs://attestor-505506-corporus/security/data-handling-standard.txt

[2] logging-monitoring-standard — 4. Alerting — relevance 0.64

4. Alerting
Detections run in Datadog Security Monitoring. Alert routing is by severity through PagerDuty. Current detection coverage includes impossible-travel sign-ins, MFA fatigue patterns, IAM policy changes granting broad permissions, disabling of CloudTrail or GuardDuty, unusual Snowflake export volume, and break-glass account use.

Alert quality is reviewed monthly. Alerts with a false

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[3] data-handling-standard — 4. Production data in non-production environments — relevance 0.58

4. Production data in non-production environments
Customer production data is never copied into development or staging environments.
This is a hard prohibition, not a preference. Staging is populated by
`kd-synthetic-gen` (KD-ENG-003 §2), which generates structurally identical but wholly
fabricated datasets from a fixed seed. The last audit of staging table contents against
production tenant i

gs://attestor-505506-corporus/security/data-handling-standard.txt

[4] logging-monitoring-standard — 2. Retention — relevance 0.57

2. Retention

| Log class | Hot (searchable) | Archive | Total |

|---|---|---|---|

| Security and audit (CloudTrail, Okta) | 90 days in Datadog | 7 years in S3 Glacier | **7 years** |

| Application | 30 days in Datadog | 1 year in S3 | 1 year |

| Snowflake ACCESS_HISTORY | 365 days native | 7 years in S3 | 7 years |

| VPC Flow / WAF | 30 days | 1 year | 1 year |

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[5] logging-monitoring-standard — 3. Tamper resistance — relevance 0.56

3. Tamper resistance

The security archive bucket uses S3 Object Lock in **compliance mode**, which cannot be disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

141. Are backups encrypted, and with which keys?

engineering · Q141 · Vendor Security Review row 142

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

142. Who is accountable for information security at executive level?

security · Q142 · Vendor Security Review row 143

Marcus Oyelaran, Chief Information Security Officer (CISO), is accountable for information security at Kestrel Data. The CISO reports directly to the Chief Executive Officer rather than engineering or product leadership, ensuring independent oversight, and maintains a standing right of direct access to the board of directors ('risk-management-and-governance', Section 1. Executive accountability).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 1. Executive accountability — relevance 0.72

1. Executive accountability

Marcus Oyelaran, Chief Information Security Officer, is accountable for information security at Kestrel Data. The CISO reports to the Chief Executive Officer, not to the VP Engineering or the CTO, so that a security objection cannot be resolved by the person whose delivery schedule it obstructs. The CISO has a standing right of direct access to the board and exercises

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] information-security-policy — 2. Governance — relevance 0.66

2. Governance

Security governance sits with the Security Council, chaired by the CISO and meeting monthly. Standing members are the CISO, VP Engineering (Dana Whitfield), General Counsel (Aaron Feldstein), Head of IT (Sofia Brenner), and the Data Protection Officer (Priya Raghunathan). Minutes are retained for seven years in Confluence space 'SEC-GOV'.

The Board Audit & Risk Committee receives a

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] risk-management-and-governance — 2. Board oversight — relevance 0.66

2. Board oversight

The board receives a formal information security report at each quarterly meeting, presented by the CISO. The standing agenda covers: the risk register movement since the last meeting, incidents and their classification, certification and audit status, the results of penetration testing, and any exception granted above the CISO's own approval threshold. Board meetings covering s

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] company-and-security-programme-overview — 4. Governance — relevance 0.65

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] risk-management-and-governance — 3. Security Steering Group — relevance 0.65

3. Security Steering Group

A Security Steering Group meets **monthly** and comprises the CISO (chair), VP Engineering, Head of IT, General Counsel, and DPO. It approves policy changes, reviews the risk register, and decides on exceptions. Minutes are retained for seven years and are made available to auditors; they are not shared with customers, but the decisions they record are reflected in the S

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

143. Have you appointed a Data Protection Officer? Provide contact details.

legal · Q143 · Vendor Security Review row 144

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

144. How long is customer data retained after contract termination?

legal · Q144 · Vendor Security Review row 145

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

145. Which cloud service providers do you use?

engineering · Q145 · Vendor Security Review row 146

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

146. What is your personal data breach notification commitment to customers?

legal · Q146 · Vendor Security Review row 147

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

147. Do you use a VPN for internal application access, or a zero-trust approach?

security · Q147 · Vendor Security Review row 148

Kestrel Data does not use a traditional VPN for internal application access, employing a zero-trust architecture instead. Internal applications are published through Cloudflare Access, which requires both Okta identity authentication and device posture verification on every request. In this model, network position confers no implicit trust or access rights ('network-security-standard', Section 6: "Internal application access"). Device posture checks enforced by Cloudflare Access require full disk encryption, a supported and current operating system, and an enrolled mobile device management (MDM) profile ('access-control-standard', Section 10: "Remote access").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] network-security-standard — 6. Internal application access — relevance 0.73

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

[2] access-control-standard — 10. Remote access — relevance 0.57

10. Remote access

There is no traditional VPN. Access to internal applications is mediated by Cloudflare Access with device posture checks requiring disk encryption, a current OS, and an enrolled MDM profile (Kandji for macOS, 163 devices as of 1 February 2026).

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 3. Role-based access — relevance 0.54

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix ('SEC-GOV/access-matrix'), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] network-security-standard — 10. Testing — relevance 0.54

10. Testing

Network controls are exercised annually by the external penetration test. The February 2026 test (Include Security, INSEC-2026-0219) attempted lateral movement from a compromised application container and did not achieve it; the finding raised was the rate limiting gap on the password reset endpoint, remediated on 27 February 2026.

gs://attestor-505506-corporus/security/network-security-standard.txt

[5] network-security-standard — 8. Wireless — relevance 0.54

8. Wireless

The Austin office wireless network is WPA3-Enterprise with certificate-based authentication for the corporate SSID and a fully segregated guest SSID that routes straight to the internet. Neither network grants any access to production; production is reached the same way from the office as from a coffee shop, which is deliberate.

gs://attestor-505506-corporus/security/network-security-standard.txt

148. Have you completed a Transfer Impact Assessment?

legal · Q148 · Vendor Security Review row 149

Yes, Kestrel Data has completed a Transfer Impact Assessment (TIA), most recently updated on January 9, 2026 ('transfer-impact-assessment', Section 1 "Status"). The assessment is refreshed annually as well as upon any material change to the transfer chain, applicable laws in receiving countries, or the supplementary measures relied upon. A full copy of the Transfer Impact Assessment is available to customers under NDA ('transfer-impact-assessment', Section 1 "Status").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.71

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[2] transfer-impact-assessment — 1. Status — relevance 0.70

1. Status

Kestrel Data has completed a Transfer Impact Assessment, most recently updated on 9 January 2026. It is refreshed annually and on any material change to the transfer chain, the receiving country's law, or the supplementary measures relied on. A copy is available to customers under NDA.

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — 6. Conclusion — relevance 0.66

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[4] standard-contractual-clauses-summary — 4. Transfer Impact Assessment - conclusion — relevance 0.63

4. Transfer Impact Assessment - conclusion

A TIA was completed on 28 January 2026 covering transfers to the US. Summary of conclusions:

Assessment of US law. Kestrel assessed FISA 702 and EO 12333. Kestrel is not an "electronic communications service provider" as defined in 50 U.S.C. 1881(b)(4) and has never received a national security request of any kind, nor a National Security Letter

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

[5] dpia-register — 6. Review cadence — relevance 0.62

6. Review cadence

Each completed DPIA is reviewed annually, and immediately on a material change to the processing it covers. The 2026 review cycle for all four assessments completed on 16 January 2026, with no changes to the residual risk ratings.

gs://attestor-505506-corporus/legal/dpia-register.txt

149. Will you certify deletion of customer data on request? Provide supporting evidence.

legal · Q149 · Vendor Security Review row 150

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-retention-schedule — 4. Deletion verification — relevance 0.68

4. Deletion verification

The `tenant-purge` job emits a structured completion record listing every store touched and the row or object counts removed. That record is retained for 7 years as evidence of deletion and is the artefact provided when a customer requests certification of deletion.

Deletion was exercised 11 times in 2025 (customer churn). Median time from termination to

completed pu

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[2] data-subject-rights-procedure — 5. Erasure (Article 17) — relevance 0.67

5. Erasure (Article 17)

Erasure of controller-side data is completed within 30 calendar days. Erasure of processor-side data is executed on customer instruction; deletion from live systems is immediate, and **encrypted backups containing the deleted data expire on the ordinary backup rotation within 35 days**. Kestrel does not selectively edit backups, and says so: surgical deletion inside an encr

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] data-processing-agreement — 8. Deletion and return — relevance 0.67

8. Deletion and return

On termination, Customer may export its data through the Service for **30 days**. After that period Kestrel deletes Customer Personal Data within **90 days**, save where storage is required by law. Backups containing deleted data expire on the standard backup cycle, a maximum of **35 days** after deletion from primary storage. Certification of deletion is provided on wri

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] data-retention-schedule — 1. Customer data — relevance 0.66

1. Customer data

| Data class | Active retention | Post-termination | Deletion mechanism |

|---|---|---|---|

| Customer records in the platform | Term of subscription | **30 days** export window, then deleted within **90 days** | Automated `tenant-purge` job, nightly |

| Analytics warehouse (Snowflake) | Term | Deleted with tenant purge | Automated |

| Uploaded files (S3) | Term | Deleted with

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[5] data-retention-schedule — 6. Exceptions — relevance 0.66

6. Exceptions

Where a retention period conflicts with a customer contractual requirement, the shorter period applies unless law requires otherwise. Longer retention requires DPO approval, which has not been granted for any customer data class to date.

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

150. Describe your secure development lifecycle.

engineering · Q150 · Vendor Security Review row 151

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

151. May a customer object to a new subprocessor? What is the remedy?

legal · Q151 · Vendor Security Review row 152

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

152. What audit rights do you grant customers?

legal · Q152 · Vendor Security Review row 153

Under our Data Processing Agreement and standard contract terms, Kestrel grants customers the right to audit compliance with data protection obligations under the following conditions: * **Frequency and Notice:** Customers may

conduct an audit once per twelve-month period upon 30 days' written notice (*master-agreement-summary*, Section 6; *data-processing-agreement*, Section 9). Additional audits are permitted following a personal data breach affecting the customer or upon instruction from a supervisory authority (*master-agreement-summary*, Section 6). * **Assurance Reports First:** In the first instance, Kestrel makes available its current SOC 2 Type II report, ISO 27001 certificate, penetration test executive summary, and a completed CAIQ to satisfy audit requirements (*master-agreement-summary*, Section 6; *data-processing-agreement*, Section 9). * **Scope and Accommodation:** Where a customer has documented specific concerns not addressed by these reports, or where internal policy or regulatory requirements necessitate an on-site or questionnaire-based audit, Kestrel accommodates the request (*master-agreement-summary*, Section 6; *data-processing-agreement*, Section 9). Customers exercising audit rights may also inspect redacted records, such as the Data Subject Rights (DSR) register (*data-subject-rights-procedure*, Section 9). * **Conduct and Logistics:** Audits must be conducted during normal business hours, must not unreasonably disrupt operations, are subject to confidentiality, and are conducted at the customer's expense, with the customer bearing reasonable costs for Kestrel personnel time exceeding 8 hours (*master-agreement-summary*, Section 6; *data-processing-agreement*, Section 9).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] master-agreement-summary — 6. Audit rights — relevance 0.71

6. Audit rights

Customers may audit Kestrel's compliance with the DPA **once per twelve-month period on 30 days' written notice**, with additional audits permitted following a personal data breach affecting the customer or on a supervisory authority's instruction. Audits are conducted during business hours, must not unreasonably disrupt operations, and are subject to confidentiality.

Kestrel firs

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[2] data-processing-agreement — 9. Audit — relevance 0.70

9. Audit

Kestrel makes available its current SOC 2 Type II report and ISO 27001 certificate, which Customer accepts as satisfying Art. 28(3)(h) in the first instance. Where Customer has a documented, specific concern not addressed by those reports, Customer may conduct an audit no more than **once per twelve months**, on 30 days written notice, during business hours, subject to confidentiality

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[3] data-subject-rights-procedure — 9. Records — relevance 0.65

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[4] data-processing-agreement — 6. Data subject rights — relevance 0.64

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within **10

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[5] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.62

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within

****3 business days****. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

153. How do you support California consumer rights requests?

legal · Q153 · Vendor Security Review row 154

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.72

Data Subject Rights Procedure

****Document ID:**** KD-LEG-007 · ****Version:**** 2.3 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[2] data-processing-agreement — 6. Data subject rights — relevance 0.68

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within ****10**

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[3] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.68

1. Which rights, and against whom

For customer content, Kestrel is the ****processor**** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within ****3 business days****. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.68

8. California and other US state rights

Kestrel acts as a ****service provider**** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colorado

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[5] data-subject-rights-procedure — 9. Records — relevance 0.66

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[6] privacy-policy — 5. Your rights — relevance 0.65

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent. California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[7] privacy-policy — 3. What we do not do — relevance 0.57

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

154. Describe your security incident classification scheme.

security · Q154 · Vendor Security Review row 155

Kestrel Data classifies security incidents into four severity levels based on their operational impact and data security risk, as outlined in the **incident-response-runbook** (Section 1, **Severity definitions**): **SEV1**: Confirmed unauthorized access to customer production data, or a full platform outage. These incidents trigger immediate 24/7 on-call paging, with executive notification sent to the CEO and CISO within 30 minutes. **SEV2**: Suspected compromise, a partial outage affecting more than 10% of tenants, or a confirmed data integrity fault. These require immediate 24/7 paging and notification to the CISO within 1 hour. **SEV3**: Security-relevant defects with no evidence of exploitation. These are managed during business hours and reported through weekly executive summaries. **SEV4**: Informational or security hygiene findings that do not require paging and are tracked in monthly reports.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 1. Severity definitions — relevance 0.65

1. Severity definitions

| Sev | Definition | Page | Exec notify |

|---|---|---|---|

| **SEV1** | Confirmed unauthorised access to customer production data, or full platform outage | Immediate, 24/7 | CEO + CISO within 30 min |

| **SEV2** | Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault | Immediate, 24/7 | CISO within 1 hour |

| **SEV3**

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 3. Lifecycle — relevance 0.65

3. Lifecycle

Detect, triage, contain, eradicate, recover, learn.

Detection sources are Datadog Security Monitoring, AWS GuardDuty, AWS Security Hub, Okta ThreatInsight, Snyk, customer reports to `security@kestreldata.com`, and the disclosure address published at `kestreldata.com/.well-known/security.txt`.

Triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2, meas

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — 8. Post-incident review — relevance 0.64

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — 2. Roles — relevance 0.63

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 6. Evidence handling — relevance 0.62

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

155. Will you certify deletion of customer data on request?

legal · Q155 · Vendor Security Review row 156

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

156. How are security responsibilities communicated to personnel?

security · Q156 · Vendor Security Review row 157

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] personnel-security-and-training — 7. How security responsibilities are communicated — relevance 0.71

7. How security responsibilities are communicated

Responsibilities are communicated four ways, deliberately overlapping: the offer pack and onboarding session; the annual policy acknowledgement; a standing item in the monthly all-hands delivered by the CISO; and the `#security` Slack channel, which is the documented route for reporting anything suspicious and is monitored during business hours
wit

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — 4. Security awareness training — relevance 0.64

4. Security awareness training

Security awareness training is **mandatory** for all personnel, annually, plus at onboarding within the first 14 days. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[3] risk-management-and-governance — 8. Policy management — relevance 0.64

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.63

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] incident-response-runbook — 2. Roles — relevance 0.61

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

157. Who holds the encryption keys for customer data?

engineering · Q157 · Vendor Security Review row 158

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

158. Do you support SCIM user provisioning? Provide supporting evidence.

security · Q158 · Vendor Security Review row 159

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

159. Do you encrypt customer data at rest?

security · Q159 · Vendor Security Review row 160

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

160. Do you offer EU data residency?

legal · Q160 · Vendor Security Review row 161

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

161. For each applicable system: How much notice is given before scheduled maintenance?

engineering · Q161 · Vendor Security Review row 162

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

162. Is 24x7 support available for production-down incidents?

engineering · Q162 · Vendor Security Review row 163

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

163. Provide your standard Data Processing Agreement.

legal · Q163 · Vendor Security Review row 164

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] data-processing-agreement — Data Processing Agreement (Template) — relevance 0.75

Data Processing Agreement (Template)

****Document ID:**** KD-LEG-001 · ****Version:**** 5.1 · ****Owner:**** Aaron Feldstein, General Counsel

****Effective:**** 1 February 2026 · ****Supersedes:**** v4.3 of 12 May 2025

****Governing law:**** Delaware, USA, save where the SCCs specify otherwise

This DPA forms part of the Kestrel Data Master Subscription Agreement and applies where Kestrel processes Personal Data on

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] master-agreement-summary — 9. Subcontracting — relevance 0.74

9. Subcontracting

Sub-processing is governed by the DPA: a public list (KD-LEG-006), ****30 days' notice**** before adding or replacing a sub-processor, a right to object on reasonable data protection grounds, and termination without penalty if the objection cannot be resolved.

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[3] data-processing-agreement — 10. International transfers — relevance 0.73

10. International transfers

Where Personal Data is transferred out of the EEA, UK, or Switzerland, the parties enter into the ****2021 EU Standard Contractual Clauses**** (Commission Implementing Decision 2021/914), Module Two (Controller to Processor) or Module Three (Processor to Sub-processor) as applicable, incorporated by reference. The UK International Data Transfer Addendum and the Swiss An

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[4] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.73

Part A - Kestrel as Processor (Art. 30(2))

****Controller:**** each Kestrel customer, as identified in the applicable Order Form.

****Processor:**** Kestrel Data, Inc.

****DPO:**** Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[5] master-agreement-summary — 1. Structure — relevance 0.72

1. Structure

A Kestrel engagement comprises the Master Subscription Agreement, an Order Form, the Data Processing Agreement (KD-LEG-001) with its Annex 2 technical measures (KD-LEG-003), and the Security Addendum (KD-LEG-005). The DPA and Security Addendum are incorporated by reference into every agreement; they are not optional extras negotiated case by case.

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[6] data-processing-agreement — 2. Scope and duration — relevance 0.69

2. Scope and duration

Processing continues for the term of the Agreement plus the retention periods in Annex 2. Kestrel processes Personal Data only on documented instructions from Customer. The Agreement, this DPA, and Customer configuration of the Service constitute those instructions.

If Kestrel is required by Union or Member State law to process beyond those instructions, it will inform

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

164. Are backups replicated across regions? Do they leave the residency boundary?

engineering · Q164 · Vendor Security Review row 165

Yes, backups are replicated across regions while strictly maintaining data residency boundaries. Specifically, the US production instance in `us-east-1` replicates backups to `us-west-2`, and the EU production instance in `eu-west-1` replicates backups to `eu-central-1` (backup-restore-procedure, Section 2: Encryption and location; infrastructure-architecture-overview, Section 1: Cloud footprint). Backups do not leave the residency boundary; EU customer data never leaves the European Economic Area (EEA), including in backups (backup-restore-procedure, Section 2: Encryption and location).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 2. Encryption and location — relevance 0.70

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 1. What is backed up — relevance 0.63

1. What is backed up

Asset	Method	Frequency	Retention
-------	--------	-----------	-----------

---	---	---	---
-----	-----	-----	-----

RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	35 days
----------------	--	------------	----------------

RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
------------------	--	-----------------	---------

S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
------------	---------------------------------------	------------	----------------------------------

Snowflake	Time Tr		
-----------	---------	--	--

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[3] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.61

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
----------	--------	--------

---	---	---
-----	-----	-----

US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
----	---------------------	--

EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency
----	---------------------	--

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[4] backup-restore-procedure — 6. Backup deletion — relevance 0.59

6. Backup deletion

Backups expire automatically. When a customer terminates and the tenant purge runs, backups containing that data expire on the normal cycle, a maximum of **35 days** later. Kestrel does not selectively surgically remove a tenant from historical backup images, and says so rather than implying otherwise.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 4. Test results — relevance 0.58

4. Test results

Restore is tested ****quarterly****, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

165. How much notice do you give customers before a breaking API change?

engineering · Q165 · Vendor Security Review row 166

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

166. Describe your process for responding to government requests for customer data.

legal · Q166 · Vendor Security Review row 167

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] government-requests-and-transparency-report — 2. How a request is handled — relevance 0.72

2. How a request is handled

- **Log.**** The request is recorded in the government request register on the day of receipt, with the requesting authority, the legal instrument, and the data sought.
- **Validate.**** The General Counsel, with outside counsel where warranted, assesses whether the instrument is valid, whether it is binding on Kestrel in the jurisdiction concerned, and whether i

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 1. Who may receive a request — relevance 0.70

1. Who may receive a request

All law enforcement, regulatory, and national security requests for customer data must be directed to the General Counsel at `legal@kestreldata.com`. No other person at Kestrel is authorised to accept service or to disclose customer data to a government authority. Support, sales, and engineering personnel are trained to route any such approach to the General Counsel wi

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[3] data-subject-rights-procedure — 9. Records — relevance 0.68

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.68

Government Requests Policy and Transparency Report

****Document ID:**** KD-LEG-012 · ****Version:**** 2.0 · ****Owner:**** Aaron Feldstein, General Counsel

****Approved:**** 2 February 2026 · ****Next review:**** 2 February 2027

****Maps to:**** GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[5] government-requests-and-transparency-report — 6. Records — relevance 0.68

6. Records

The government request register is retained for ten years and is available to the auditors and, in redacted form, to a customer exercising audit rights. Retention is longer than the ordinary schedule deliberately: the value of this record is precisely that it goes back further than anyone's memory.

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[6] government-requests-and-transparency-report — 5. Emergency disclosure requests — relevance 0.56

5. Emergency disclosure requests

An emergency request citing an imminent risk to life is escalated to the General Counsel immediately, at any hour, through the 'legal-oncall' PagerDuty rotation. Disclosure in those circumstances is limited to what is necessary to address the emergency, is documented in the register, and the customer is notified afterwards unless prohibited. No emergency request ha

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

167. Do you maintain Records of Processing Activities under Article 30?

legal · Q167 · Vendor Security Review row 168

Yes. Kestrel Data maintains Records of Processing Activities under GDPR Article 30 (Document ID: KD-LEG-005), maintained under Article 30(1) where Kestrel acts as a controller and Article 30(2) where Kestrel acts as a processor. These records are maintained by the Data Protection Officer and are available to supervisory authorities upon request (GDPR Records of Processing Activities (Art. 30), "GDPR Records of Processing Activities (Art. 30)").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.70

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[2] data-subject-rights-procedure — 9. Records — relevance 0.65

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.63

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[4] dpia-register — 6. Review cadence — relevance 0.62

6. Review cadence

Each completed DPIA is reviewed annually, and immediately on a material change to the processing it covers. The 2026 review cycle for all four assessments completed on

16 January 2026, with no changes to the residual risk ratings.

gs://attestor-505506-corporus/legal/dpia-register.txt

[5] dpia-register — Data Protection Impact Assessment Register — relevance 0.60

Data Protection Impact Assessment Register

****Document ID:**** KD-LEG-011 · ****Version:**** 1.9 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 16 January 2026 · ****Next review:**** 16 January 2027

****Maps to:**** GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporus/legal/dpia-register.txt

168. Do you publish a modern slavery or supply chain labour statement?

legal · Q168 · Vendor Security Review row 169

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

169. What authorisation is required for support access to customer data?

security · Q169 · Vendor Security Review row 170

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

170. Summarise the supplementary measures identified in your Transfer Impact Assessment.

legal · Q170 · Vendor Security Review row 171

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

171. For each applicable system: How do you support California consumer rights requests?

legal · Q171 · Vendor Security Review row 172

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.69

8. California and other US state rights

Kestrel acts as a ****service provider**** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colora

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[2] privacy-policy — 5. Your rights — relevance 0.65

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent.

California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[3] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.64

Data Subject Rights Procedure

Document ID: KD-LEG-007 · **Version:** 2.3 · **Owner:** Priya Raghunathan, DPO

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.60

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[5] privacy-policy — 3. What we do not do — relevance 0.59

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

172. Do you hold HITRUST certification?

security · Q172 · Vendor Security Review row 173

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

173. Do you have a documented AI governance policy?

security · Q173 · Vendor Security Review row 174

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

174. What is the minimum password length enforced?

security · Q174 · Vendor Security Review row 175

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

175. For each applicable system: How do you handle a vulnerability with no available upstream fix?

security · Q175 · Vendor Security Review row 176

When a vulnerability has no available upstream fix, Kestrel Data handles it through the following process: 1. **Risk Registration and Ownership:** The vulnerability is recorded in the risk register with an assigned, named owner (*Cloud Security Posture Standard*, Section 6). 2. **Compensating Mitigation:** A mitigation strategy is selected from one of three approaches (*Cloud Security Posture Standard*, Section 6): - Removing the affected component. - Blocking the attack path at the network or Web Application Firewall (WAF) layer. - Applying a vendored patch maintained internally

by Kestrel (in accordance with KD-ENG-007 §7). 3. ****Continuous Monitoring and Review:**** The vulnerability is re-reviewed weekly until an official upstream fix becomes available (***Cloud Security Posture Standard***, Section 6). 4. ****Exception Approval:**** If the vulnerability cannot be remediated within standard service level agreements (SLAs), it requires a documented exception approved by the CISO, complete with compensating controls and an expiration date not to exceed 180 days (***Vulnerability Management Policy***, Section 6).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (12)

[1] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.76

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[2] risk-management-and-governance — 5. Worked examples from the register — relevance 0.71

5. Worked examples from the register

| Risk | Description | Treatment | Residual |

|---|---|---|---|

| RISK-2025-0031 | SMS and TOTP factors phishable | Mitigate — hardware factors mandated 30 June 2025 | Low |

| RISK-2024-0017 | No file-scanning anti-malware on container hosts | Accept — immutable hosts, signed images, runtime detection | Low |

|

| RISK-2025-0044 | Single-cloud concentration on AWS

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] vulnerability-management-policy — Vulnerability Management Policy — relevance 0.68

Vulnerability Management Policy

****Document ID:**** KD-SEC-006 ****Version:**** 3.3 ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 ****Next review:**** 22 January 2027

****Maps to:**** SOC 2 CC7.1, CC7.2 · ISO 27001:2022 A.8.8

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[4] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.67

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure.

Internet-facing findings are escalated one level.

| Severity | CVSS | Remediation SLA | Measured 2025 compliance |

|---|---|---|---|

| Critical | 9.0-10.0 | ****7 days**** | 100% (11 of 11) |

| High | 7.0-8.9 | ****30 days**** | 96% (74 of 77) |

| Medium | 4.0-6.9 | ****90 days**** | 91% |

|

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[5] vulnerability-management-policy — 6. Exceptions — relevance 0.65

6. Exceptions

A finding that cannot be remediated within SLA requires a documented exception approved by the CISO, with a compensating control and an expiry date not exceeding 180 days.

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[6] risk-management-and-governance — Risk Management and Security Governance — relevance 0.65

Risk Management and Security Governance

****Document ID:**** KD-SEC-018 ****Version:**** 3.0 ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 26 January 2026 ****Next review:**** 26 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[7] pen-test-executive-summary — Penetration Test Executive Summary — relevance 0.64

Penetration Test Executive Summary

Document ID: KD-SEC-007 · **Engagement:** INSEC-2026-0219

Tester: Include Security, Inc. · **Dates:** 3-14 February 2026

Report issued: 24 February 2026 · **Retest completed:** 18 March 2026

Classification: Confidential - shareable with customers under NDA

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[8] vendor-risk-management-policy — Vendor Risk Management Policy — relevance 0.60

Vendor Risk Management Policy

Document ID: KD-SEC-008 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 4 February 2026 · **Next review:** 4 February 2027

Maps to: SOC 2 CC9.2 · ISO 27001:2022 A.5.19-A.5.22 · GDPR Art. 28

gs://attestor-505506-corpus/security/vendor-risk-management-policy.txt

[9] pen-test-executive-summary — 5. Medium findings, in brief — relevance 0.60

5. Medium findings, in brief

1. Session cookie missing `SameSite=Strict` on one legacy subdomain. Fixed 2 March 2026.

2. Verbose error messages disclosing library versions on 4 API endpoints. Fixed 4 March 2026.

3. S3 bucket `kestrel-public-assets` permitted `s3:ListBucket` to authenticated AWS

principals outside the Organization. Fixed 27 February 2026 with an explicit bucket

policy den

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[10] pen-test-executive-summary — 3. Findings summary — relevance 0.58

3. Findings summary

| Severity | Found | Remediated | Retest verified |

|---|---|---|---|

| Critical | 0 | - | - |

| High | 1 | 1 | 18 March 2026 |

| Medium | 4 | 4 | 18 March 2026 |

| Low | 7 | 5 | 18 March 2026 |

| Informational | 9 | Accepted / tracked | - |

No cross-tenant data access was achieved. Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[11] pen-test-executive-summary — 6. Two accepted low findings — relevance 0.57

6. Two accepted low findings

- **L6** - Username enumeration remains possible through the SAML metadata endpoint for customers using IdP-initiated flows. Accepted; mitigation would break a documented integration pattern. Tracked as RISK-2026-0004.

- **L7** - TLS 1.2 remains enabled on the legacy SFTP endpoint. Accepted until the Q3 2026 decommission. Tracked as RISK-2025-0088.

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[12] vulnerability-management-policy — 2. Scanning coverage — relevance 0.56

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

176. What security evidence do you require from subprocessors before engagement?

security · Q176 · Vendor Security Review row 177

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

177. Describe how tenant isolation is enforced. If not, describe compensating controls.

engineering · Q177 · Vendor Security Review row 178

Kestrel Insight is a multi-tenant platform utilizing logical isolation enforced across three distinct layers (infrastructure-architecture-overview, §5. Tenant isolation): 1. **Database Layer:** Logical isolation is enforced via PostgreSQL row-level security policies keyed on `tenant\_id`. These policies are applied at the connection level from an authenticated session variable, ensuring that no application query can opt out. 2. **Application Layer:** Every incoming request carries a validated tenant claim. The data access layer is architected via a repository base class that systematically rejects any query lacking a tenant predicate, rather than relying on developer convention. 3. **Storage Layer:** All Amazon S3 object keys are tenant-prefixed, and AWS IAM policies strictly constrain access by prefix. Tenant isolation is continuously verified by an 84-assertion automated test suite executed on every build, and its effectiveness was validated during the February 2026 independent penetration test, where no cross-tenant access was achieved (infrastructure-architecture-overview, §5. Tenant isolation).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.66

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[2] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.63

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid sess

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[3] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.62

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[4] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.61

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.61

Data Flow and Shared Responsibility Model

****Document ID:**** KD-ENG-011 · ****Version:**** 2.0 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 2 February 2026 · ****Next review:**** 2 February 2027

****Maps to:**** SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

178. Please confirm: Provide your ISO 27001 certificate and its scope statement.

security · Q178 · Vendor Security Review row 179

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

179. In what year was the company founded, and where is it incorporated?

legal · Q179 · Vendor Security Review row 180

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

180. How frequently are user access reviews performed?

security · Q180 · Vendor Security Review row 181

User access reviews are conducted on a quarterly basis, covering all production systems, the AWS Organization, Snowflake, GitHub, and Okta. Reviews are conducted by the respective system owners and formally attested in Vanta (Access Control Standard, Section 7: "Access reviews").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 7. Access reviews — relevance 0.72

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 3. Role-based access — relevance 0.66

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] risk-management-and-governance — 8. Policy management — relevance 0.64

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] access-control-standard — 6. Joiners, movers, leavers — relevance 0.64

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 4. Just-in-time production access — relevance 0.63

4. Just-in-time production access

Engineers request elevated production access through the `/access` Slack workflow. A request requires a written business justification, a linked incident or change ticket, and approval from a second engineer holding the SRE role. Self-approval is blocked.

Granted access expires automatically after **8 hours**. All commands executed in an elevated session are

gs://attestor-505506-corporus/security/access-control-standard.txt

181. For each applicable system: Do you operate active-active failover between regions?

engineering · Q181 · Vendor Security Review row 182

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

182. Please confirm: Do you encrypt customer data at rest?

security · Q182 · Vendor Security Review row 183

Yes. All customer data at rest is encrypted using AES-256-GCM across all storage tiers, and no customer data is stored unencrypted (`encryption-standard`, Section 1: "Data at rest"; `information-security-policy`, Section 8: "Cryptography"). Specifically, storage-level encryption is enforced across the environment: - **Amazon RDS (PostgreSQL 16):** Encrypted using per-environment AWS KMS Customer Managed Keys (CMKs). - **Amazon S3:** Encrypted via SSE-KMS using per-bucket AWS KMS CMKs. - **Snowflake:** Encrypted natively with Tri-Secret Secure using customer-managed keys in AWS KMS. - **Amazon EBS:** Encrypted volumes enforced at the AWS Organization level using AWS KMS CMKs. - **Backups:** Protected using the same CMK class as the source. Additionally, application-level field encryption is applied to authentication secrets, API tokens, and OAuth refresh tokens using AES-256-GCM with keys maintained in AWS Secrets Manager and rotated every 90 days (`encryption-standard`, Section 1: "Data at rest").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 1. Data at rest — relevance 0.73

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key |

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] encryption-standard — 3. Key management — relevance 0.65

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no

individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporus/security/encryption-standard.txt

[3] physical-and-environmental-security — 1. Production infrastructure — relevance 0.65

1. Production infrastructure

Kestrel Data operates **no owned or leased data centre**. All production infrastructure runs in AWS: ``us-east-1`` for the US instance and ``eu-west-1`` for the EU instance.

Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corporus/security/physical-and-environmental-security.txt

[4] information-security-policy — 8. Cryptography — relevance 0.64

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] encryption-standard — Encryption Standard — relevance 0.62

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

183. Do you have data loss prevention controls on endpoints?

security · Q183 · Vendor Security Review row 184

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

184. How many security incidents were recorded in the last calendar year? If not, describe compensating controls.

security · Q184 · Vendor Security Review row 185

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] soc2-control-matrix — Common Criteria — relevance 0.68

Common Criteria

| Control | Description | Evidence | Test result |

|---|---|---|---|

| CC1.1 | Board oversight of security; Audit and Risk Committee meets quarterly | Committee minutes, 4 meetings in 2025 | No exceptions

|

| CC1.4 | Security awareness training at hire and annually | Curricula completion records, 100% of active staff | No exceptions |

| CC2.1 | Internal communication of securit

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] risk-management-and-governance — 9. Exceptions — relevance 0.67

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] incident-response-runbook — 9. 2025 incident summary — relevance 0.65

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- **INC-2025-0044** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.
- **INC-2025-0071** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] risk-management-and-governance — 8. Policy management — relevance 0.63

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] risk-management-and-governance — Risk Management and Security Governance — relevance 0.63

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

185. Do you retain an external incident response firm?

security · Q185 · Vendor Security Review row 186

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

186. What is your backup retention period?

engineering · Q186 · Vendor Security Review row 187

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

187. How frequently do you commission independent penetration testing?

security · Q187 · Vendor Security Review row 188

Kestrel Data commissions an independent penetration test annually at a minimum, and additionally before any significant architectural change (*Vulnerability Management Policy*, Section 4, "Penetration testing"). The most recent assessment was conducted by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219; *Vulnerability Management Policy*, Section 4, "Penetration testing"; *Company and Security Programme Overview*, Section 3, "Security programme in summary").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 4. Penetration testing — relevance 0.68

4. Penetration testing

An independent penetration test is commissioned **annually** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[2] network-security-standard — 10. Testing — relevance 0.62

10. Testing

Network controls are exercised annually by the external penetration test. The February 2026 test (Include Security, INSEC-2026-0219) attempted lateral movement from a compromised application container and did not achieve it; the finding raised was the rate limiting gap on the password reset endpoint, remediated on 27 February 2026.

gs://attestor-505506-corporus/security/network-security-standard.txt

[3] pen-test-executive-summary — Penetration Test Executive Summary — relevance 0.61

Penetration Test Executive Summary

Document ID: KD-SEC-007 · **Engagement:** INSEC-2026-0219

Tester: Include Security, Inc. · **Dates:** 3-14 February 2026

Report issued: 24 February 2026 · **Retest completed:** 18 March 2026

Classification: Confidential - shareable with customers under NDA

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[4] company-and-security-programme-overview — 4. Governance — relevance 0.60

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.60

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. **Independent verification.** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, **no exceptions**) and ISO 27001:2022 (BSI certificate 'IS-2025-44817', issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

188. Do you carry professional indemnity insurance?

legal · Q188 · Vendor Security Review row 189

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

189. Do you operate anti-malware controls on servers?

security · Q189 · Vendor Security Review row 190

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] endpoint-protection-standard — 3. Anti-malware on servers — relevance 0.69

3. Anti-malware on servers

Production compute runs immutable, minimal container images on Bottlerocket hosts. Traditional file-scanning anti-malware is not deployed on those hosts; the compensating controls are read-only root filesystems, no interactive shell access in normal operation, image signing enforced at admission, and the Falcon sensor running in Linux mode for runtime behavioural detecti

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[2] endpoint-protection-standard — 8. Patching of endpoints — relevance 0.60

8. Patching of endpoints

Operating system updates are enforced within 14 days of release for standard updates and 72 hours for updates addressing a Critical vulnerability, with a Kandji deferral window that cannot be extended by the user. Measured compliance at the last audit point (1 February 2026) was 168 of 174 devices within policy, the remaining six being on extended leave with access suspend

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[3] endpoint-protection-standard — 4. Disk encryption — relevance 0.60

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[4] endpoint-protection-standard — 2. Endpoint detection and response — relevance 0.57

2. Endpoint detection and response

CrowdStrike Falcon is deployed on 100% of managed endpoints and on all production compute nodes. Coverage is reconciled nightly against the Kandji and AWS inventories, and a device present in inventory but absent from Falcon raises a ticket to the Head of IT within one business day. The reconciliation found two gaps during 2025, both new contractor laptops, b

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[5] network-security-standard — 2. Web application firewall — relevance 0.57

2. Web application firewall

Cloudflare WAF is enabled on all production hostnames, running the Cloudflare Managed Ruleset, the OWASP Core Ruleset at paranoia level 2, and 14 Kestrel-authored rules. Rules are deployed in log mode for 7 days before enforcement so that a false positive is found before it blocks a customer. Blocked request volume averaged 41,000 per day during 2025, of which the l

gs://attestor-505506-corporus/security/network-security-standard.txt

190. Do you share personal data with advertising networks?

legal · Q190 · Vendor Security Review row 191

No, Kestrel Data does not share personal data with advertising networks, nor does it share personal data for cross-context behavioral advertising (Privacy Policy, "3. What we do not do"; Data Subject Rights Procedure, "8. California and other US state rights").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — 3. What we do not do — relevance 0.67

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] privacy-policy — 4. Cookies — relevance 0.63

4. Cookies

The marketing site uses strictly necessary cookies plus, with consent, analytics cookies (Plausible, which is cookieless, and Google Analytics 4 where consent is given). The application uses only strictly necessary cookies: a session cookie and a CSRF token. A consent banner meeting EDPB guidance is served to EEA, UK, and Swiss visitors, with reject as prominent as accept.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[3] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.62

8. California and other US state rights

Kestrel acts as a **service provider** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colora

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] privacy-policy — 6. International transfers — relevance 0.61

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] privacy-policy — 2. What we collect as controller — relevance 0.61

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

191. Is there board-level oversight of information security? If not, describe compensating controls.

security · Q191 · Vendor Security Review row 192

Yes, Kestrel Data maintains formal board-level oversight of information security. The board receives a formal information security report at each quarterly meeting, presented by the Chief Information Security Officer (CISO). This standing agenda covers movements in the risk register since the prior meeting, security incidents and their classifications, certification and audit status, results of penetration testing, and any policy exceptions granted above the CISO's approval threshold (*Risk Management and Security Governance*, Section 2, "Board oversight"). Additionally, the board has designated Elaine Vasquez, a non-executive director and former CIO of a regulated financial services firm, as the specific director holding security oversight responsibility (*Risk Management and Security Governance*, Section 2, "Board oversight"). The CISO also maintains a standing right of direct access to the board (*Risk Management and Security Governance*, Section 1, "Executive accountability").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — Risk Management and Security Governance — relevance 0.64

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] risk-management-and-governance — 2. Board oversight — relevance 0.63

2. Board oversight

The board receives a formal information security report at each quarterly meeting, presented by the CISO. The standing agenda covers: the risk register movement since the last meeting, incidents and their classification, certification and audit status, the results of penetration testing, and any exception granted above the CISO's own approval threshold. Board meetings covering s

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] risk-management-and-governance — 9. Exceptions — relevance 0.62

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] risk-management-and-governance — 1. Executive accountability — relevance 0.62

1. Executive accountability

******Marcus Oyelaran, Chief Information Security Officer, is accountable for information security at Kestrel Data.****** The CISO reports to the Chief Executive Officer, not to the VP Engineering or the CTO, so that a security objection cannot be resolved by the person whose delivery schedule it obstructs. The CISO has a standing right of direct access to the board and exercis

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] company-and-security-programme-overview — 4. Governance — relevance 0.61

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

192. Do you follow OWASP secure coding guidance?

engineering · Q192 · Vendor Security Review row 193

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

193. Have you completed a cryptographic inventory?

security · Q193 · Vendor Security Review row 194

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

194. What is your target time to revoke access when personnel depart?

security · Q194 · Vendor Security Review row 195

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

195. How do you communicate security changes to customers?

engineering · Q195 · Vendor Security Review row 196

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

196. Provide the executive summary of your most recent penetration test.

security · Q196 · Vendor Security Review row 197

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

197. How frequently are production operating systems patched?

engineering · Q197 · Vendor Security Review row 198

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

198. Are there any unrestricted inbound network rules in production?

engineering · Q198 · Vendor Security Review row 199

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

199. Do you perform software composition analysis for third-party dependencies?

engineering · Q199 · Vendor Security Review row 200

Yes. Kestrel Data performs software composition analysis and dependency scanning using Snyk, which runs automatically on every pull request and daily against the `main` branch (`sdlc-policy`, Section 4; `third-party-library-policy`, Section 4). Any Critical or High severity dependency finding blocks pull request merging (`sdlc-policy`, Section 4; `third-party-library-policy`, Section 4). Additionally, dependency vulnerabilities are remediated in accordance with strict SLAs (Critical within 7 days, High within 30 days, Medium within 90 days), and automated upgrade pull requests are generated weekly via Renovate to keep dependencies updated (`third-party-library-policy`, Section 4; `sdlc-policy`, Section 5).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (6)

[1] third-party-library-policy — Third-Party Library Policy — relevance 0.64

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 4. Vulnerability response — relevance 0.64

4. Vulnerability response

Dependency vulnerabilities follow the SLAs in KD-SEC-006: Critical 7 days, High 30 days, Medium 90 days. Snyk runs on every pull request and daily against `main`. A Critical or High finding blocks merge.

Where no upstream fix exists within the SLA, the options in order of preference are: apply a vendored patch, replace the dependency, or accept the risk with a docum

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 1. Adding a dependency — relevance 0.63

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] sdlc-policy — 5. Dependency policy — relevance 0.62

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 4. Security in the pipeline — relevance 0.60

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[6] third-party-library-policy — no section recorded — relevance 0.60

****Owner:**** Dana Whitfield, VP Engineering ****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28 ## 1.
Adding a dependency A new ...

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

200. Do you have a published responsible disclosure policy?

security · Q200 · Vendor Security Review row 201

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

201. Do you offer source code escrow arrangements?

engineering · Q201 · Vendor Security Review row 202

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

202. Is production data used in test environments?

engineering · Q202 · Vendor Security Review row 203

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

203. How do you manage cookie consent on your web properties?

legal · Q203 · Vendor Security Review row 204

On our web properties, cookie usage and consent are managed as follows: * **Application***: The application uses only strictly necessary cookies, specifically a session cookie and a CSRF token. * **Marketing Site***: The marketing site uses strictly necessary cookies along with analytics. Plausible is used as a cookieless analytics solution, while Google Analytics 4 is deployed only where consent is explicitly given. * **Consent Banner***: Visitors from the EEA, UK, and Switzerland are presented with a cookie consent banner aligned with European Data Protection Board (EDPB) guidance, featuring a "reject" option that is as prominent as the "accept" option. *(Privacy Policy, Section 4: Cookies)*

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — 4. Cookies — relevance 0.63

4. Cookies

The marketing site uses strictly necessary cookies plus, with consent, analytics cookies (Plausible, which is cookieless, and Google Analytics 4 where consent is given). The application uses only strictly necessary cookies: a session cookie and a CSRF token. A consent banner meeting EDPB guidance is served to EEA, UK, and Swiss visitors, with reject as prominent as accept.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] privacy-policy — 3. What we do not do — relevance 0.55

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

[3] privacy-policy — 5. Your rights — relevance 0.55

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent. California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] privacy-policy — 2. What we collect as controller — relevance 0.55

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

| ---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate intere

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] privacy-policy — 6. International transfers — relevance 0.54

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

204. How do you handle a vulnerability with no available upstream fix?

security · Q204 · Vendor Security Review row 205

When a vulnerability has no upstream fix available, Kestrel Data records the finding in the risk register with an assigned named owner. A mitigation is implemented by selecting one of three controls: removing the affected component, blocking the attack path at the network or Web Application Firewall (WAF) layer, or applying a Kestrel-maintained

vendored patch (cloud-security-posture-standard §6). The vulnerability is subsequently re-reviewed on a weekly basis until an upstream fix is released and deployed (cloud-security-posture-standard §6).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.72

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[2] pen-test-executive-summary — 3. Findings summary — relevance 0.60

3. Findings summary

| Severity | Found | Remediated | Retest verified |

|---|---|---|---|

| Critical | 0 | - | - |

| High | 1 | 1 | 18 March 2026 |

| Medium | 4 | 4 | 18 March 2026 |

| Low | 7 | 5 | 18 March 2026 |

| Informational | 9 | Accepted / tracked | - |

No cross-tenant data access was achieved. Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[3] vulnerability-management-policy — 6. Exceptions — relevance 0.60

6. Exceptions

A finding that cannot be remediated within SLA requires a documented exception approved by the CISO, with a compensating control and an expiry date not exceeding 180 days.

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[4] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.60

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure. Internet-facing findings are escalated one level.

| Severity | CVSS | Remediation SLA | Measured 2025 compliance |

|---|---|---|---|

| Critical | 9.0-10.0 | **7 days** | 100% (11 of 11) |

| High | 7.0-8.9 | **30 days** | 96% (74 of 77) |

| Medium | 4.0-6.9 | **90 days** | 91% |

|

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[5] risk-management-and-governance — 5. Worked examples from the register — relevance 0.60

5. Worked examples from the register

| Risk | Description | Treatment | Residual |

|---|---|---|---|

| RISK-2025-0031 | SMS and TOTP factors phishable | Mitigate — hardware factors mandated 30 June 2025 | Low |

| RISK-2024-0017 | No file-scanning anti-malware on container hosts | Accept — immutable hosts, signed images, runtime detection | Low |

|

| RISK-2025-0044 | Single-cloud concentration on AWS

gs://attestor-505506-corpus/security/risk-management-and-governance.txt

205. Do you perform static application security testing on every code change?

security · Q205 · Vendor Security Review row 206

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

206. Do you use customer content to train machine learning models?

legal · Q206 · Vendor Security Review row 207

No, Kestrel does not use customer content to train machine learning models—neither our own nor anyone else's. This commitment is established contractually in the Master Services Agreement (MSA) and reflected in our operational practices (Privacy Policy, §3 "What we do not do"; DPA Annex 2 - Technical Measures, §6 "Data minimisation").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — 3. What we do not do — relevance 0.64

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corpus/legal/privacy-policy.txt

[2] dpa-annex-2-technical-measures — 6. Data minimisation — relevance 0.62

6. Data minimisation

The Service collects only data the customer chooses to provide. Kestrel product telemetry is pseudonymous and retained for 24 months. Kestrel does not use customer content to train machine learning models.

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[3] dpia-register — 5. Automated decision-making — relevance 0.59

5. Automated decision-making

Kestrel performs **no** automated decision-making producing legal effects or similarly significant effects concerning data subjects, within the meaning of Article 22. The two machine learning features described in KD-SEC-019 §2 surface information to the customer's own analysts; the decisions that follow are made by people at the customer, using the customer's own data

gs://attestor-505506-corpus/legal/dpia-register.txt

[4] dpia-register — 3. Special category data — relevance 0.58

3. Special category data

Kestrel does not knowingly process special category personal data under Article 9. The platform is not designed for it, the Acceptable Use terms in the master agreement prohibit uploading it, and no field in the data model is intended to hold it.

Kestrel cannot inspect customer-uploaded datasets — they are opaque by design — so the control is contractual and architect

gs://attestor-505506-corpus/legal/dpia-register.txt

[5] privacy-policy — 2. What we collect as controller — relevance 0.55

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corpus/legal/privacy-policy.txt

207. Are manual production console changes permitted? If not, describe compensating controls.

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

208. What is your Recovery Time Objective?

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

209. How do you support customer responses to data subject access requests?

For customer content, Kestrel acts as a processor and supports customer responses to data subject access requests through the following mechanisms: * **Self-Service Functionality:** Kestrel provides built-in self-service tools that allow customers to directly access, correct, export, and delete personal data within the service (*Data Processing Agreement*, §6). * **Processor Assistance:** When self-service tooling is insufficient, Kestrel commits to assisting the customer upon written request (*Data Processing Agreement*, §6; *Data Subject Rights Procedure*, §2). Support includes: 1. Guiding the customer to the appropriate self-service tooling; 2. Generating an export of the identified data subject's records if the customer cannot isolate them; or 3. Executing a tenant-level deletion as directed by the customer (*Data Subject Rights Procedure*, §2). * **Direct Data Subject Inquiries:** If a data subject approaches Kestrel directly concerning customer content, Kestrel does not respond substantively on the controller's behalf and redirects the request to the customer without undue delay, typically within 3 business days when the customer can be identified (*Data Processing Agreement*, §6; *Data Subject Rights Procedure*, §1). * **Recordkeeping:** All data subject requests, routing, and resolution dates are tracked in a DSR register maintained by the Data Protection Officer (DPO) and retained for three years (*Data Subject Rights Procedure*, §9).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] data-subject-rights-procedure — 9. Records — relevance 0.68

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[2] data-subject-rights-procedure — 2. Assisting customers as processor — relevance 0.67

2. Assisting customers as processor

Kestrel commits to assist a customer with a data subject request within 5 business days of a written request, which is the commitment in the DPA (KD-LEG-001 §6). Assistance means one of three things:

1. Pointing the customer at the self-service tooling that lets them do it themselves, which is the fastest route and covers the majority of requests;
2. Pro

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[3] data-processing-agreement — 6. Data subject rights — relevance 0.66

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within **10**

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] government-requests-and-transparency-report — 2. How a request is handled — relevance 0.66

2. How a request is handled

1. **Log.** The request is recorded in the government request register on the day of receipt, with the requesting authority, the legal instrument, and the data sought.
2. **Validate.** The General Counsel, with outside counsel where warranted, assesses whether the instrument is valid, whether it is binding on Kestrel in the jurisdiction concerned, and whether i

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[5] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.65

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

210. Which generative AI tools are approved for internal use?

security · Q210 · Vendor Security Review row 211

As of 1 February 2026, internal use of generative AI tools is restricted to an approved list operating under strict zero-retention and enterprise governance controls: **GitHub Copilot Business**: Approved for code completion (and permitted for source code), with telemetry and code-snippet retention disabled by tenant policy (`ai-governance-policy`, Section 4; `acceptable-use-policy`, Section 2). **Anthropic Claude**: Approved for analysis and drafting in the Kestrel enterprise/team workspace with a zero-retention configuration, permitted for data classified up to Internal (`ai-governance-policy`, Section 4; `acceptable-use-policy`, Section 2). **Google Gemini**: Approved within Google Workspace under Google Workspace data processing terms for Internal or Public information (`ai-governance-policy`, Section 4). **OpenAI ChatGPT Enterprise**: Approved for analysis and drafting for data classified up to Internal under zero-retention agreements (`acceptable-use-policy`, Section 2). All other generative AI tools and personal or consumer tiers of approved products are strictly prohibited on company devices and blocked at the network and DNS layers via Cloudflare Gateway (`ai-governance-policy`, Section 4; `acceptable-use-policy`, Section 2). Additionally, customer production data and Restricted information may not be entered into any generative AI tool (`ai-governance-policy`, Section 4; `acceptable-use-policy`, Section 2).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] ai-governance-policy — 4. Approved generative AI tools for internal use — relevance 0.72

4. Approved generative AI tools for internal use

Personnel may use generative AI tools **only** from the approved list, and **only** with information classified Internal or Public. Restricted or Confidential information — including any customer content — must not be entered into any generative AI tool.

Approved as of 1 February 2026:

* GitHub Copilot Business (code completion; telemetry and code

gs://attestor-505506-corporus/security/ai-governance-policy.txt

[2] acceptable-use-policy — 2. Generative AI tools — relevance 0.68

2. Generative AI tools

Use of generative AI is permitted only with approved tools under a zero-retention agreement. As of 1 February 2026 the approved list is:

Tool	Approved for	Data tier permitted
------	--------------	---------------------

---	---	---
-----	-----	-----

GitHub Copilot Business	Code completion	Confidential (source code)
-------------------------	-----------------	----------------------------

Anthropic Claude (Team)	Analysis, drafting	Internal
-------------------------	--------------------	----------

gs://attestor-505506-corporate/security/acceptable-use-policy.txt

[3] ai-governance-policy — 5. Approving a new AI feature or tool — relevance 0.62

5. Approving a new AI feature or tool

A new AI feature or tool requires an assessment covering: what data it processes and at what classification, where the processing occurs, whether the provider trains on inputs, retention, the effect on the ROPA and the subprocessor list, human oversight, and failure behaviour. The assessment is reviewed by the CISO and DPO jointly and recorded in the Security

gs://attestor-505506-corporate/security/ai-governance-policy.txt

[4] ai-governance-policy — 7. Transparency to customers — relevance 0.57

7. Transparency to customers

The use of AI features, the model providers involved, and the regions of processing are disclosed in the subprocessor list (KD-LEG-006) and in the product documentation. AWS Bedrock is listed as a subprocessor. Customers may disable both AI features at the tenant level, and 11 customers had done so as of 1 February 2026.

gs://attestor-505506-corporate/security/ai-governance-policy.txt

[5] information-security-policy — 10. Exceptions — relevance 0.57

10. Exceptions

Exceptions to this policy require written approval from the CISO, a documented compensating control, and an expiry date not exceeding 180 days. Four exceptions are open as of 11 February 2026, all tracked in Vanta and all with expiry dates before 30 September 2026.

gs://attestor-505506-corporate/security/information-security-policy.txt

211. Can customers scope and revoke their own API credentials? Provide supporting evidence.

engineering · Q211 · Vendor Security Review row 212

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

212. Provide your measured median access revocation time for the last 12 months.

security · Q212 · Vendor Security Review row 213

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

213. Can customers scope and revoke their own API credentials?

security · Q213 · Vendor Security Review row 214

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] pen-test-executive-summary — 2. Methodology — relevance 0.59

2. Methodology

Grey-box testing against OWASP ASVS 4.0 Level 2 and the OWASP API Security Top 10. Testers were given standard-tier and admin-tier credentials for each seeded tenant plus API documentation. 74 person-hours across two testers.

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[2] information-security-policy — 3. Certifications and attestations — relevance 0.56

3. Certifications and attestations

| Framework | Status | Evidence |

|---|---|---|

| SOC 2 Type II | Current | Report issued 14 March 2026 by Prescient Assurance LLP, covering 1 January – 31 December 2025. No exceptions noted. |

| ISO/IEC 27001:2022 | Certified | Certificate IS-2025-44817, issued by BSI on 22 September 2025, valid to 21 September 2028 |

| ISO/IEC 27701:2019 | Certified | Extension

gs://attestor-505506-corpus/security/information-security-policy.txt

[3] pen-test-executive-summary — 1. Scope — relevance 0.56

1. Scope

- Kestrel Insight web application (`app.kestreldata.com`), authenticated and unauthenticated surfaces

- Public REST API v2 (`api.kestreldata.com`), 89 endpoints

- Multi-tenant isolation testing across 3 seeded tenant accounts

- AWS cloud configuration review (IAM, S3, VPC, EKS)

- Authentication and session management, including the Okta SAML integration

Out of scope: physical se

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[4] personnel-security-and-training — 2. Confidentiality obligations — relevance 0.55

2. Confidentiality obligations

All personnel sign a confidentiality agreement as a condition of employment or engagement. **The confidentiality obligation survives termination indefinitely for customer data and for five years for other Kestrel confidential information.** Contractors sign the same obligation through their engagement contract, and the obligation flows down to any of their own person

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[5] acceptable-use-policy — 3. Credentials — relevance 0.54

3. Credentials

Credentials are personal and may not be shared, including with other Kestrel staff.

Shared team accounts are prohibited. Where a shared credential is unavoidable for a third-party service that does not support SSO, it is held in a 1Password shared vault with access logged, and the service is recorded on the SSO-gap register.

gs://attestor-505506-corpus/security/acceptable-use-policy.txt

[6] information-security-policy — 6. Personnel security — relevance 0.53

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corpus/security/information-security-policy.txt

[7] pen-test-executive-summary — 4. The High finding — relevance 0.53

4. The High finding

INSEC-2026-0219-H1 - Insufficient rate limiting on the password reset endpoint.

`POST /v2/auth/password-reset` was not rate limited per account, permitting user enumeration through response timing and, in combination with a slow SMTP path, a potential mail-flood against a targeted address. No authentication bypass was possible and no data was exposed.

Remediated on

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[8] access-control-standard — 1. Identity provider — relevance 0.53

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`).
Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[9] pen-test-executive-summary — 5. Medium findings, in brief — relevance 0.53

5. Medium findings, in brief

1. Session cookie missing `SameSite=Strict` on one legacy subdomain. Fixed 2 March 2026.
2. Verbose error messages disclosing library versions on 4 API endpoints. Fixed 4 March 2026.
3. S3 bucket `kestrel-public-assets` permitted `s3:ListBucket` to authenticated AWS principals outside the Organization. Fixed 27 February 2026 with an explicit bucket policy den

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[10] pen-test-executive-summary — 3. Findings summary — relevance 0.53

3. Findings summary

Severity	Found	Remediated	Retest verified
Critical	0	-	-
High	1	1	18 March 2026
Medium	4	4	18 March 2026
Low	7	5	18 March 2026
Informational	9	Accepted / tracked	-

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

214. Do you offer Canadian or Australian data residency?

legal · Q214 · Vendor Security Review row 215

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

215. Do you perform automated decision-making with legal or significant effects?

legal · Q215 · Vendor Security Review row 216

Kestrel does not perform automated decision-making that produces legal effects or similarly significant effects concerning data subjects within the meaning of GDPR Article 22. Any machine learning features provided surface information to the customer's own analysts, and all subsequent decisions are made directly by people at the customer using their own data (DPIA Register, Section 5: Automated decision-making).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] dpia-register — 5. Automated decision-making — relevance 0.68

5. Automated decision-making

Kestrel performs ****no automated decision-making producing legal effects or similarly significant effects**** concerning data subjects, within the meaning of Article 22. The two machine learning features described in KD-SEC-019 §2 surface information to the customer's own analysts; the decisions that follow are made by people at the customer, using the customer's own data

gs://attestor-505506-corporus/legal/dpia-register.txt

[2] dpia-register — Data Protection Impact Assessment Register — relevance 0.59

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corpus/legal/dpia-register.txt

[3] dpia-register — 1. When Kestrel performs a DPIA — relevance 0.56

1. When Kestrel performs a DPIA

A DPIA is performed where processing is likely to result in a high risk to data subjects, and in every case triggered by the Article 35(3) list or the lead supervisory authority's own list. In practice Kestrel triggers an assessment for: a new machine learning feature processing customer data, a new sub-processor receiving customer content, a change to the residency

gs://attestor-505506-corpus/legal/dpia-register.txt

[4] dpia-register — 6. Review cadence — relevance 0.56

6. Review cadence

Each completed DPIA is reviewed annually, and immediately on a material change to the processing it covers. The 2026 review cycle for all four assessments completed on 16 January 2026, with no changes to the residual risk ratings.

gs://attestor-505506-corpus/legal/dpia-register.txt

[5] dpia-register — 7. Availability — relevance 0.54

7. Availability

DPIA summaries are provided to customers under NDA on request through the account team. The full assessments are not distributed, because they contain architectural detail that is itself Confidential, but the DPO will walk a customer's privacy team through an assessment on a call.

gs://attestor-505506-corpus/legal/dpia-register.txt

216. Describe your break-glass access procedure.

security · Q216 · Vendor Security Review row 217

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

217. Are you controller or processor for customer data?

legal · Q217 · Vendor Security Review row 218

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-processing-agreement — 1. Roles — relevance 0.71

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.67

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[3] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.66

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[4] privacy-policy — Privacy Policy — relevance 0.64

Privacy Policy

Document ID: KD-LEG-003 · **Version:** 4.0 · **Owner:** Priya Raghunathan, DPO

Effective: 15 January 2026 · **Published at:** `kestreldata.com/privacy`

This policy describes how Kestrel Data, Inc. handles personal data where Kestrel is the **controller**. Where Kestrel processes personal data on behalf of a business customer, that customer is the controller and its own

gs://attestor-505506-corpus/legal/privacy-policy.txt

[5] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.62

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

218. Provide the name and contact details of your primary security contact.

security · Q218 · Vendor Security Review row 219

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

219. Which Trust Services Criteria are in scope for your SOC 2 report?

security · Q219 · Vendor Security Review row 220

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

220. How many BAAs are currently executed?

legal · Q220 · Vendor Security Review row 221

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

221. How is cloud provider concentration risk managed?

engineering · Q221 · Vendor Security Review row 222

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

222. What is your committed customer notification window for a personal data breach?

legal · Q222 · Vendor Security Review row 223

Kestrel Data commits to notifying customers of a personal data breach affecting customer personal data without undue delay and in any event within 72 hours of becoming aware of the incident. In cases where there is confirmed unauthorized access to customer production data, notification is provided within 24 hours. The notification includes the information required under Article 33(3) of the GDPR to the extent known (Data Processing Agreement, Section 7: "Personal data breach").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 7. Personal data breach — relevance 0.64

7. Personal data breach

Kestrel notifies Customer **without undue delay and in any event within 72 hours** of becoming aware of a Personal Data Breach affecting Customer Personal Data, and within **24 hours** where there is confirmed unauthorised access to Customer production data. Notification includes the information required by Art. 33(3) GDPR to the extent known.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.58

Data Subject Rights Procedure

Document ID: KD-LEG-007 · **Version:** 2.3 · **Owner:** Priya Raghunathan, DPO
Approved: 20 January 2026 · **Next review:** 20 January 2027
Maps to: GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[3] legal-and-regulatory-history — 2. Regulatory enforcement — relevance 0.58

2. Regulatory enforcement

Kestrel Data has never been subject to a regulatory enforcement action, fine, consent decree, undertaking, or formal investigation by any data protection authority, sectoral regulator, or competition authority. No supervisory authority has issued Kestrel a reprimand, order, or corrective measure under Article 58 of the GDPR.

Kestrel has never made a personal data bre

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[4] data-subject-rights-procedure — 9. Records — relevance 0.57

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[5] legal-and-regulatory-history — 3. Complaints — relevance 0.57

3. Complaints

Two data subject complaints have been received directly since 2019, both from individuals whose employers were Kestrel customers, and both resolved by directing the complainant to their employer as controller with an explanation of the roles. Neither complainant escalated to a supervisory authority.

gs://attestor-505506-corporus/legal/legal-and-regulatory-history.txt

223. How frequently do you test restoration from backup?

engineering · Q223 · Vendor Security Review row 224

We test restoration from backup on a quarterly basis (`backup-restore-procedure`, Section 4. "Test results"). These quarterly tests perform a full restore into an isolated environment rather than a simple backup-listing check, and include validating the restored data against an automated integrity suite covering row counts, referential integrity, tenant isolation invariants, and known-value spot checks (`backup-restore-procedure`, Section 3. "Restore procedure" and Section 4. "Test results").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 4. Test results — relevance 0.71

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.62

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — Backup and Restore Procedure — relevance 0.60

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — 3. Restore procedure — relevance 0.60

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spot checks.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.58

1. What is backed up

Asset	Method	Frequency	Retention
RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	35 days
RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Travel	Continuous	90 days

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

224. Are workloads deployed with least-privilege container security contexts?

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

225. How long do elevated production access grants remain valid?

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

226. For each applicable system: Describe your approach to environmental sustainability and carbon reporting.

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

227. For each applicable system: Do you act as a service provider under the CCPA?

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.68

8. California and other US state rights

Kestrel acts as a ****service provider**** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colora

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[2] data-processing-agreement — 5. Sub-processing — relevance 0.68

5. Sub-processing

Customer grants general authorisation for the sub-processors listed at `kestreldata.com/subprocessors`. Kestrel gives ****30 days**** notice before adding or replacing a sub-processor. Customer may object on reasonable data-protection grounds within that period; if the objection cannot be resolved, Customer may terminate the affected Service without penalty for the remainder of t

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[3] data-processing-agreement — Data Processing Agreement (Template) — relevance 0.67

Data Processing Agreement (Template)

****Document ID:**** KD-LEG-001 · ****Version:**** 5.1 · ****Owner:**** Aaron Feldstein, General Counsel

****Effective:**** 1 February 2026 · ****Supersedes:**** v4.3 of 12 May 2025

****Governing law:**** Delaware, USA, save where the SCCs specify otherwise

This DPA forms part of the Kestrel Data Master Subscription Agreement and applies where Kestrel processes Personal Data on

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[4] data-processing-agreement — 1. Roles — relevance 0.66

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[5] data-processing-agreement — 10. International transfers — relevance 0.66

10. International transfers

Where Personal Data is transferred out of the EEA, UK, or Switzerland, the parties enter into the **2021 EU Standard Contractual Clauses** (Commission Implementing Decision 2021/914), Module Two (Controller to Processor) or Module Three (Processor to Sub-processor) as applicable, incorporated by reference. The UK International Data Transfer Addendum and the Swiss An

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[6] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.66

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[7] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.63

Data Subject Rights Procedure

Document ID: KD-LEG-007 · **Version:** 2.3 · **Owner:** Priya Raghunathan, DPO

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[8] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.62

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[9] subprocessor-list — Operational subprocessors — relevance 0.62

Operational subprocessors

| Subprocessor | Purpose | Location | Transfer mechanism | Engaged since |

| ---|---|---|---|---|

| Datadog, Inc. | Observability, logs, APM | US; EU site (`datadoghq.eu`) for EU customers | SCCs | Jun 2020 |

| Okta, Inc. | Identity and access management | US; EU cell for EU customers | SCCs | Feb 2021 |

| Twilio SendGrid | Transactional email delivery | US | SCCs | Ma

gs://attestor-505506-corpus/legal/subprocessor-list.txt

228. What is your remediation SLA for High severity vulnerabilities?

security · Q228 · Vendor Security Review row 229

Kestrel Data's remediation SLA for High severity vulnerabilities (CVSS 7.0–8.9) is ****30 days**** (`vulnerability-management-policy`, §1). Severity is assigned based on the CVSS v3.1 base score and adjusted for exploitability and exposure, with internet-facing findings escalated by one level (`vulnerability-management-policy`, §1). Any finding that cannot be remediated within SLA requires a documented exception approved by the CISO, accompanied by a compensating control and an expiry date not exceeding 180 days (`vulnerability-management-policy`, §6).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.78

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure.
Internet-facing findings are escalated one level.

Severity CVSS Remediation SLA Measured 2025 compliance
--- --- --- ---
Critical 9.0-10.0 **7 days** 100% (11 of 11)
High 7.0-8.9 **30 days** 96% (74 of 77)
Medium 4.0-6.9 **90 days** 91%

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 6. Exceptions — relevance 0.71

6. Exceptions

A finding that cannot be remediated within SLA requires a documented exception approved by the CISO, with a compensating control and an expiry date not exceeding 180 days.

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[3] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.66

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[4] incident-response-runbook — 8. Post-incident review — relevance 0.66

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 1. Severity definitions — relevance 0.66

1. Severity definitions

Sev Definition Page Exec notify

--- --- --- ---

SEV1 Confirmed unauthorised access to customer production data, or full platform outage Immediate, 24/7 CEO + CISO within 30 min
--

SEV2 Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault Immediate, 24/7 CISO within 1 hour
--

**SEV3

gs://attestor-505506-corporus/security/incident-response-runbook.txt

229. Describe the shared responsibility model between you and your customers.

security · Q229 · Vendor Security Review row 230

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (13)

[1] soc2-control-matrix — Complementary user entity controls — relevance 0.67

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] risk-management-and-governance — Risk Management and Security Governance — relevance 0.61

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] access-control-standard — Access Control Standard — relevance 0.60

Access Control Standard

Document ID: KD-SEC-002 · **Version:** 3.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.1, CC6.2, CC6.3 · ISO 27001:2022 A.5.15, A.5.16, A.5.18, A.8.2

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.58

SOC 2 Control Matrix

Document ID: KD-SEC-012 · **Version:** 2.1

Report period: 1 January - 31 December 2025 · **Report issued:** 14 March 2026

Auditor: Prescient Assurance LLP · **Opinion:** Unqualified, no exceptions noted

Trust Services Criteria in scope: Security, Availability, Confidentiality

Privacy and Processing Integrity are **not** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[5] risk-management-and-governance — 9. Exceptions — relevance 0.57

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[6] personnel-security-and-training — 7. How security responsibilities are communicated — relevance 0.55

7. How security responsibilities are communicated

Responsibilities are communicated four ways, deliberately overlapping: the offer pack and onboarding session; the annual policy acknowledgement; a standing item in the monthly all-hands delivered by the CISO; and the `#security` Slack channel, which is the documented route for reporting anything suspicious and is monitored during business hours

wit

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[7] physical-and-environmental-security — 7. Equipment removal — relevance 0.54

7. Equipment removal

Company equipment may be removed from the office freely, as befits a remote-first company. Every device is enrolled in Kandji, encrypted, and remotely wipeable. Loss or theft must be reported to `#security` within 4 hours; the device is wiped remotely and the event recorded as a security incident. Three devices were reported lost or stolen in 2025, all

wiped successfully, none

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[8] personnel-security-and-training — 2. Confidentiality obligations — relevance 0.53

2. Confidentiality obligations

All personnel sign a confidentiality agreement as a condition of employment or engagement. ****The confidentiality obligation survives termination indefinitely for customer data and for five years for other Kestrel confidential information.**** Contractors sign the same obligation through their engagement contract, and the obligation flows down to any of their own person

gs://attestor-505506-corporate-security/personnel-security-and-training.txt

[9] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.53

3. Acceptable use and policy acknowledgement

Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual cycle closed on 30 November 2025 at ****100%**** completion across 187 employees and 24 contractors.

gs://attestor-505506-corporate-security/personnel-security-and-training.txt

[10] physical-and-environmental-security — 1. Production infrastructure — relevance 0.51

1. Production infrastructure

Kestrel Data operates ****no owned or leased data centre****. All production infrastructure runs in AWS: `us-east-1` for the US instance and `eu-west-1` for the EU instance. Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[11] physical-and-environmental-security — 5. Home working — relevance 0.49

5. Home working

Personnel working from home are required to use a Kestrel-managed device with full-disk encryption, to avoid working on customer data in public spaces, and to use a privacy screen when travelling. Kestrel does not inspect home environments; the compensating control is that no customer data is stored locally — access is through the browser to systems inside the AWS boundary, and the

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[12] physical-and-environmental-security — Physical and Environmental Security Standard — relevance 0.49

Physical and Environmental Security Standard

****Document ID:**** KD-SEC-014 · ****Version:**** 1.6 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 12 January 2026 · ****Next review:**** 12 January 2027

****Maps to:**** SOC 2 CC6.4, CC6.5 · ISO 27001:2022 A.7.1–A.7.14

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

[13] physical-and-environmental-security — 6. Environmental controls in the office — relevance 0.46

6. Environmental controls in the office

The suite has no server room and no production equipment. Fire detection, suppression, and power continuity are provided by the building. A loss of the Austin office has no effect on service availability, which is the point of running no infrastructure there; this was exercised during the 12–14 February 2025 winter storm closure with no customer impact.

gs://attestor-505506-corporate-security/physical-and-environmental-security.txt

230. Describe your rollback capability and typical rollback time.

engineering · Q230 · Vendor Security Review row 231

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

231. Do you subscribe to threat intelligence feeds? If not, describe compensating controls.

security · Q231 · Vendor Security Review row 232

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

232. Provide your ISO 27001 certificate and its scope statement.

security · Q232 · Vendor Security Review row 233

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

233. Are passwords checked against known-breached credential lists?

security · Q233 · Vendor Security Review row 234

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

234. What is your notification window for confirmed unauthorised access to production data? If not, describe compensating controls.

legal · Q234 · Vendor Security Review row 235

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

235. Describe your multi-region architecture.

engineering · Q235 · Vendor Security Review row 236

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

236. Provide your measured availability for the last 3 years.

engineering · Q236 · Vendor Security Review row 237

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

237. Do Kestrel personnel routinely access customer production data?

security · Q237 · Vendor Security Review row 238

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

238. Do you maintain cyber liability insurance, and what are the coverage limits?

legal · Q238 · Vendor Security Review row 239

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

239. What is your scheduled maintenance window?

engineering · Q239 · Vendor Security Review row 240

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

240. Describe your vendor risk management programme and tiering approach.

security · Q240 · Vendor Security Review row 241

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

241. Are infrastructure configurations managed as code?

engineering · Q241 · Vendor Security Review row 242

Yes, Kestrel Data manages infrastructure configurations exclusively as code through Terraform in the `kestrel-infra` repository (`change-management-procedure`, Section 4, "Infrastructure changes"). Manual changes via the AWS console are strictly prohibited in production, and automated drift detection runs every six hours to raise a SEV3 alert upon discovering any unmanaged change (`change-management-procedure`, Section 4, "Infrastructure changes").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 7. Separation of duties — relevance 0.59

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] change-management-procedure — 4. Infrastructure changes — relevance 0.58

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository. Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.57

Infrastructure Architecture Overview

****Document ID:**** KD-ENG-003 · ****Version:**** 3.4 · ****Owner:**** Dana Whitfield, VP Engineering
****Last updated:**** 5 February 2026 · ****Classification:**** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 3. Compute — relevance 0.57

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones.

Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] secrets-management-standard — 4. Runtime access — relevance 0.57

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

242. Provide evidence of your most recent user access review.

security · Q242 · Vendor Security Review row 243

Quarterly user access reviews cover all production systems, including the AWS Organization, Snowflake, GitHub, and Okta itself. These reviews are conducted by system owners and formally attested in Vanta. As documented in the Access Control Standard (Section 7, "Access reviews"), the most recent Q4 2025 user access review completed on 12 January 2026. The review resulted in the removal of 23 entitlements, including 9 stale contractor accesses.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 7. Access reviews — relevance 0.64

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] pen-test-executive-summary — 3. Findings summary — relevance 0.60

3. Findings summary

Severity	Found	Remediated	Retest verified
--- --- --- ---			
Critical	0	-	-
High	1	1	18 March 2026
Medium	4	4	18 March 2026
Low	7	5	18 March 2026
Informational	9		Accepted / tracked

No cross-tenant data access was achieved. Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[3] access-control-standard — 3. Role-based access — relevance 0.60

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] pen-test-executive-summary — 6. Two accepted low findings — relevance 0.60

6. Two accepted low findings

- ****L6**** - Username enumeration remains possible through the SAML metadata endpoint for customers using IdP-initiated flows. Accepted; mitigation would break a documented integration pattern. Tracked as RISK-2026-0004.
- ****L7**** - TLS 1.2 remains enabled on the legacy SFTP endpoint. Accepted until the Q3 2026 decommission. Tracked as RISK-2025-0088.

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[5] pen-test-executive-summary — 4. The High finding — relevance 0.59

4. The High finding

****INSEC-2026-0219-H1** - Insufficient rate limiting on the password reset endpoint.

`POST /v2/auth/password-reset` was not rate limited per account, permitting user enumeration through response timing and, in combination with a slow SMTP path, a potential mail-flood against a targeted address. No authentication bypass was possible and no data was exposed.

Remediated on

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

243. Describe your key rotation policy and frequency.

engineering · Q243 · Vendor Security Review row 244

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

244. Please confirm: Do you accept SOC 2 and ISO 27001 reports in place of a customer audit?

legal · Q244 · Vendor Security Review row 245

Yes. Kestrel makes available its current SOC 2 Type II report, ISO 27001 certificate, penetration test executive summary, and completed CAIQ in the first instance, which satisfy audit requirements (including GDPR Article 28(3)(h)) for the majority of customer requests (`data-processing-agreement`, Section "9. Audit"; `master-agreement-summary`, Section "6. Audit rights"). This report-first approach serves as a starting point rather than a refusal. Where a customer has a documented, specific concern not covered by these reports, or where internal policy or a supervisory authority requires an on-site or questionnaire-based audit, Kestrel accommodates the audit (`master-agreement-summary`, Section "6. Audit rights"). Customer audits may be conducted once per twelve-month period on 30 days' written notice, during normal business hours, subject to confidentiality, and at customer expense, with additional audits permitted following a personal data breach affecting the customer or upon instruction from a supervisory authority (`data-processing-agreement`, Section "9. Audit"; `master-agreement-summary`, Section "6. Audit rights").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 9. Audit — relevance 0.73

9. Audit

Kestrel makes available its current SOC 2 Type II report and ISO 27001 certificate, which Customer accepts as satisfying Art. 28(3)(h) in the first instance. Where Customer has a documented, specific concern not addressed by those reports, Customer may conduct an audit no more than ****once per twelve months****, on 30 days written notice, during business hours, subject to confidentiality

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] master-agreement-summary — 6. Audit rights — relevance 0.70

6. Audit rights

Customers may audit Kestrel's compliance with the DPA ****once per twelve-month period on 30 days' written notice****, with additional audits permitted following a personal data breach affecting the customer or on a supervisory authority's instruction. Audits are conducted during business hours, must not unreasonably disrupt operations, and are subject to

confidentiality.

Kestrel firs

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[3] security-addendum — 1. Certifications maintained — relevance 0.65

1. Certifications maintained

Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days

gs://attestor-505506-corporus/legal/security-addendum.txt

[4] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.65

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[5] master-agreement-summary — Master Subscription Agreement — Summary of Key Terms — relevance 0.63

Master Subscription Agreement — Summary of Key Terms

Document ID: KD-LEG-014 · **Version:** 3.2 · **Owner:** Aaron Feldstein, General Counsel

Approved: 28 January 2026 · **Next review:** 28 January 2027

Maps to: SOC 2 CC2.3, CC9.1 · GDPR Article 28

*A summary for review purposes. The executed agreement governs; where this summary and an executed contract differ, the contract prevails.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

245. Provide the technical and organisational measures annexed to your DPA.

legal · Q245 · Vendor Security Review row 246

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] dpa-annex-2-technical-measures — DPA Annex 2 - Technical and Organisational Measures — relevance 0.75

DPA Annex 2 - Technical and Organisational Measures

Document ID: KD-LEG-009 · **Version:** 4.0 · **Owner:** Marcus Oyelaran, CISO

Effective: 1 February 2026 · Annex to the DPA (KD-LEG-001)

Maps to: GDPR Art. 32

Measures are described at a level that allows a controller to assess adequacy under Art. 32 without exposing information that would itself create risk.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[2] gdpr-records-of-processing — Data Protection Impact Assessments — relevance 0.66

Data Protection Impact Assessments

One DPIA is on file, covering the introduction of the anomaly detection feature

(`LEG-GOV/dpia-2025-01`, completed 8 September 2025). Conclusion: residual risk low, no prior consultation with the supervisory authority required.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[3] master-agreement-summary — 9. Subcontracting — relevance 0.65

9. Subcontracting

Sub-processing is governed by the DPA: a public list (KD-LEG-006), **30 days' notice** before adding or replacing a sub-processor, a right to object on reasonable data protection grounds, and termination without penalty if the objection cannot be resolved.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[4] dpa-annex-2-technical-measures — 4. Regular testing and evaluation (Art. 32(1)(d)) — relevance 0.64

4. Regular testing and evaluation (Art. 32(1)(d))

| Activity | Frequency | Last performed |

|---|---|---|

| Independent penetration test | Annual minimum | 3-14 February 2026 |

| SOC 2 Type II audit | Annual | Period ended 31 December 2025 |

| ISO 27001 surveillance audit | Annual | 22 September 2025 |

| Disaster recovery restore test | Quarterly | 17 January 2026 |

| User access review | Qu

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[5] dpia-register — 6. Review cadence — relevance 0.64

6. Review cadence

Each completed DPIA is reviewed annually, and immediately on a material change to the processing it covers. The 2026 review cycle for all four assessments completed on 16 January 2026, with no changes to the residual risk ratings.

gs://attestor-505506-corporus/legal/dpia-register.txt

246. What controls remain the responsibility of the customer?

security · Q246 · Vendor Security Review row 247

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

247. Which transfer mechanism do you rely on for transfers out of the EEA? Provide supporting evidence.

legal · Q247 · Vendor Security Review row 248

For transfers of personal data out of the EEA, Kestrel Data relies on the 2021 Standard Contractual Clauses (SCCs): * **Module Two (Controller-to-Processor)** applies between the customer and Kestrel. * **Module Three (Processor-to-Sub-processor)** applies between Kestrel and its US sub-processors. * For UK data exports, the **UK International Data Transfer Addendum** is incorporated. * For Swiss data exports, the SCCs apply with the adaptations issued by the Swiss Federal Data Protection and Information Commissioner (FDPIC), naming the FDPIC as the competent supervisory authority and extending protection to legal entities. Kestrel Data deliberately relies on the SCCs paired with technical and organisational supplementary measures rather than self-certifying under the EU-US Data Privacy Framework, ensuring transfer mechanisms do not rely on an adequacy decision remaining in force ('transfer-impact-assessment', Section 3, "Transfer mechanism"). In addition, EU customer-uploaded datasets and backups remain resident in `eu-west-1` ('transfer-impact-assessment', Section 2, "The transfers assessed" and Section 5, "Supplementary measures relied on").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] transfer-impact-assessment — 1. Status — relevance 0.64

1. Status

Kestrel Data has completed a Transfer Impact Assessment, most recently updated on 9 January 2026. It is refreshed annually and on any material change to the transfer chain, the receiving country's law, or the supplementary measures relied on. A copy is available to customers under NDA.

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[2] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.64

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.63

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[4] transfer-impact-assessment — 2. The transfers assessed — relevance 0.59

2. The transfers assessed

| # | Transfer | Exporter | Importer | Country | Data |

|---|---|---|---|---|

| T1 | EU tenant support access | Kestrel EU instance | Kestrel Data, Inc. | United States | Account identity data, support correspondence |

| T2 | Product telemetry aggregation | Kestrel EU instance | Kestrel Data, Inc. | United States | Pseudonymised usage events |

| T3 | Error monitoring

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[5] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.57

5. Supplementary measures relied on

Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.

2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.

3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

248. Do you offer UK-only data residency?

legal · Q248 · Vendor Security Review row 249

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] subprocessor-list — EU data residency — relevance 0.74

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[2] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.69

5. Supplementary measures relied on

Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.

2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.

3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — 2. The transfers assessed — relevance 0.65

2. The transfers assessed

| # | Transfer | Exporter | Importer | Country | Data |

|---|---|---|---|---|

| T1 | EU tenant support access | Kestrel EU instance | Kestrel Data, Inc. | United States | Account identity data, support correspondence |

| T2 | Product telemetry aggregation | Kestrel EU instance | Kestrel Data, Inc. | United States | Pseudonymised usage events |

| T3 | Error monitoring

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[4] transfer-impact-assessment — 6. Conclusion — relevance 0.64

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[5] standard-contractual-clauses-summary — 2. UK and Switzerland — relevance 0.63

2. UK and Switzerland

- **UK** - the ICO International Data Transfer Addendum (version B1.0, in force 21 March 2022) is appended to the EU SCCs. UK GDPR references replace EU GDPR references; the competent authority is the ICO.

- **Switzerland** - the Swiss Annex applies. The FDPIC is the competent authority, and references to Member State law are read as references to Swiss law. The SCC

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

249. Is tenant isolation tested continuously?

security · Q249 · Vendor Security Review row 250

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

250. Do you publish a transparency report of government data requests? If not, describe compensating controls.

legal · Q250 · Vendor Security Review row 251

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.70

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 6. Records — relevance 0.65

6. Records

The government request register is retained for ten years and is available to the auditors and, in redacted form, to a customer exercising audit rights. Retention is longer than the ordinary schedule deliberately: the value of this record is precisely that it goes back further than anyone's memory.

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

[3] government-requests-and-transparency-report — 3. Transparency report — relevance 0.65

3. Transparency report

Kestrel publishes a transparency report annually at `trust.kestreldata.com/transparency`. Figures for the calendar year 2025:

Category	Received	Data produced
--- --- ---		
US law enforcement — subpoena	2	0
US law enforcement — search warrant	0	0
US national security process (NSL, FISA)	**0**	0
Non-US government requests	1	0
Civil di		

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

[4] government-requests-and-transparency-report — 2. How a request is handled — relevance 0.63

2. How a request is handled

1. ****Log.**** The request is recorded in the government request register on the day of receipt, with the requesting authority, the legal instrument, and the data sought.
2. ****Validate.**** The General Counsel, with outside counsel where warranted, assesses whether the instrument is valid, whether it is binding on Kestrel in the jurisdiction concerned, and whether i

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

[5] data-subject-rights-procedure — 9. Records — relevance 0.61

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[6] government-requests-and-transparency-report — 1. Who may receive a request — relevance 0.60

1. Who may receive a request

All law enforcement, regulatory, and national security requests for customer data must be directed to the General Counsel at `legal@kestreldata.com`. No other person at Kestrel is authorised to accept service or to disclose customer data to a government authority. Support, sales, and engineering personnel are trained to route any such approach to the General Counsel wi

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

251. When was your Information Security Policy last reviewed and approved? If not, describe compensating controls.

security · Q251 · Vendor Security Review row 252

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

252. Do you have a documented business continuity plan?

engineering · Q252 · Vendor Security Review row 253

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

253. Provide the results of your most recent disaster recovery test.

engineering · Q253 · Vendor Security Review row 254

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] backup-restore-procedure — 4. Test results — relevance 0.66

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.60

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 3. Restore procedure — relevance 0.58

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — Backup and Restore Procedure — relevance 0.57

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.53

1. What is backed up

Asset	Method	Frequency	Retention
RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	35 days
RDS logical dump	pg_dump to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Tr		

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

254. Describe your security monitoring and alerting capability.

security · Q254 · Vendor Security Review row 255

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

255. Please confirm: Can a developer approve their own pull request?

engineering · Q255 · Vendor Security Review row 256

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

256. Are long-lived static cloud access keys permitted?

security · Q256 · Vendor Security Review row 257

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

257. Are you PCI DSS compliant, and at what level?

security · Q257 · Vendor Security Review row 258

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

258. Please confirm: Do you use a VPN for internal application access, or a zero-trust approach?

security · Q258 · Vendor Security Review row 259

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] network-security-standard — 6. Internal application access — relevance 0.73

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

[2] access-control-standard — 10. Remote access — relevance 0.57

10. Remote access

There is no traditional VPN. Access to internal applications is mediated by Cloudflare Access with device posture checks requiring disk encryption, a current OS, and an enrolled MDM profile (Kandji for macOS, 163 devices as of 1 February 2026).

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 3. Role-based access — relevance 0.54

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] network-security-standard — 10. Testing — relevance 0.54

10. Testing

Network controls are exercised annually by the external penetration test. The February 2026 test (Include Security, INSEC-2026-0219) attempted lateral movement from a compromised application container and did not achieve it; the finding raised was the rate limiting gap on the password reset endpoint, remediated on 27 February 2026.

gs://attestor-505506-corporus/security/network-security-standard.txt

[5] network-security-standard — 8. Wireless — relevance 0.54

8. Wireless

The Austin office wireless network is WPA3-Enterprise with certificate-based authentication for the corporate SSID and a fully segregated guest SSID that routes straight to the internet. Neither network grants any access to production; production is reached the same way from the office as from a coffee shop, which is deliberate.

gs://attestor-505506-corporus/security/network-security-standard.txt

259. Have you completed any Data Protection Impact Assessments?

legal · Q259 · Vendor Security Review row 260

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] dpia-register — Data Protection Impact Assessment Register — relevance 0.69

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporus/legal/dpia-register.txt

[2] dpia-register — 1. When Kestrel performs a DPIA — relevance 0.69

1. When Kestrel performs a DPIA

A DPIA is performed where processing is likely to result in a high risk to data subjects, and in every case triggered by the Article 35(3) list or the lead supervisory authority's own list. In practice Kestrel triggers an assessment for: a new machine learning feature processing customer data, a new sub-processor receiving customer content, a change to the residency

gs://attestor-505506-corporus/legal/dpia-register.txt

[3] dpia-register — 7. Availability — relevance 0.67

7. Availability

DPIA summaries are provided to customers under NDA on request through the account team. The full assessments are not distributed, because they contain architectural detail that is itself Confidential, but the DPO will walk a customer's privacy team through an assessment on a call.

gs://attestor-505506-corporus/legal/dpia-register.txt

[4] dpia-register — 2. Completed assessments — relevance 0.67

2. Completed assessments

Four DPIAs have been completed, all reviewed and signed off by the DPO:

| ID | Subject | Completed | Residual risk | Outcome |

|---|---|---|---|---|

| DPIA-2024-01 | Product telemetry collection and retention | 14 May 2024 | Low | Proceed. Event allowlist introduced; free-text fields excluded; retention set to 13 months |

| DPIA-2025-01 | EU instance and residency arc

gs://attestor-505506-corporus/legal/dpia-register.txt

[5] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.66

Transfer Impact Assessment

****Document ID:**** KD-LEG-010 · ****Version:**** 2.1 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 9 January 2026 · ****Next review:**** 9 January 2027

****Maps to:**** GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

260. Do you have a documented legal hold process?

legal · Q260 · Vendor Security Review row 261

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

261. Please confirm: Do you retain an external incident response firm?

security · Q261 · Vendor Security Review row 262

Yes, Kestrel Data retains Mandiant on a pre-negotiated incident response retainer (contract MNDT-2025-1180, effective 1 September 2025, with 40 pre-paid hours annually) providing a 4-hour response SLA for SEV1 incidents. In addition, Kestrel retains Fenwick and West LLP as outside breach counsel (`incident-response-runbook`, Section 7. External support).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 7. External support — relevance 0.66

7. External support

Kestrel retains ****Mandiant**** on a pre-negotiated incident response retainer (contract MNDT-2025-1180, effective 1 September 2025, 40 hours pre-paid annually) with a 4-hour response SLA for SEV1. Outside breach counsel is Fenwick and West LLP.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 6. Evidence handling — relevance 0.58

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — 9. 2025 incident summary — relevance 0.58

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- ****INC-2025-0044**** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.

- ****INC-2025-0071**** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — Incident Response Runbook — relevance 0.57

Incident Response Runbook

****Document ID:**** KD-SEC-005 · ****Version:**** 5.0 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 27 January 2026 · ****Last exercised:**** 3 December 2025 (tabletop)

****Maps to:**** SOC 2 CC7.3, CC7.4, CC7.5 · ISO 27001:2022 A.5.24-A.5.28 · GDPR Art. 33, 34

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 2. Roles — relevance 0.57

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

262. What is your median time to triage a security alert?

security · Q262 · Vendor Security Review row 263

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

263. For each applicable system: Do you offer a single-tenant or dedicated instance deployment?

engineering · Q263 · Vendor Security Review row 264

Kestrel Insight is a multi-tenant platform with logical isolation. We do not offer per-customer infrastructure, single-tenant deployment options, or customer-VPC deployments (`infrastructure-architecture-overview`, Section 5: "Tenant isolation"). Tenant isolation is strictly enforced across three layers: - **Database Layer:** PostgreSQL row-level security policies keyed on `tenant\_id` are applied at the connection level via authenticated session variables, preventing application queries from opting out. - **Application Layer:** Every request includes a validated tenant claim, and the data access layer automatically rejects any query lacking a tenant predicate through a repository base class. - **Storage Layer:** S3 object keys use tenant prefixes, and access is constrained via IAM policies (`infrastructure-architecture-overview`, Section 5: "Tenant isolation").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 3. Compute — relevance 0.62

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.60

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.60

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[4] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.57

1. Data flow, end to end

1. **Ingress** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.56

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. No processing occurs outside the stated regions, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

264. Do you perform background checks on all personnel before their start date?

security · Q264 · Vendor Security Review row 265

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] personnel-security-and-training — 1. Pre-employment screening — relevance 0.65

1. Pre-employment screening

Every employee and every contractor is background screened before their start date. No system access — including email — is provisioned until the check clears; Okta Lifecycle Management is gated on the Rippling "screening cleared" attribute, so this is enforced by the provisioning pipeline rather than by a checklist.

Screening is performed by Checkr and covers, to the

gs://attestor-505506-corporate-security/personnel-security-and-training.txt

[2] information-security-policy — 6. Personnel security — relevance 0.58

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporate-security/information-security-policy.txt

[3] access-control-standard — 6. Joiners, movers, leavers — relevance 0.56

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporate-security/access-control-standard.txt

[4] information-security-policy — 11. Enforcement — relevance 0.56

11. Enforcement

Violation of this policy may result in disciplinary action up to and including termination of employment or contract, and referral to law enforcement where warranted.

Kestrel Data, Inc. · 1401 Lavaca Street, Suite 210, Austin, TX 78701 · Delaware C-corporation, incorporated 2019

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] personnel-security-and-training — 2. Confidentiality obligations — relevance 0.55

2. Confidentiality obligations

All personnel sign a confidentiality agreement as a condition of employment or engagement. ****The confidentiality obligation survives termination indefinitely for customer data and for five years for other Kestrel confidential information.**** Contractors sign the same obligation through their engagement contract, and the obligation flows down to any of their own person

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

265. Can customers retrieve their own audit logs?

security · Q265 · Vendor Security Review row 266

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organization via the Audit API (`GET /v2/audit/events``), which covers the preceding 365 days (`logging-monitoring-standard``, Section 6: Customer access to logs). Kestrel does not provide direct customer access to its underlying infrastructure logs; however, relevant extracts are supplied upon request during incident response.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] logging-monitoring-standard — 6. Customer access to logs — relevance 0.73

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events``), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[2] logging-monitoring-standard — 1. What is logged — relevance 0.63

1. What is logged

- ****Authentication**** - every Okta event: sign-in success and failure, MFA challenge, factor enrolment, admin action.
- ****Authorisation**** - every JIT production elevation, approval, and expiry.
- ****Data access**** - all queries against customer data in Snowflake, captured via `ACCESS_HISTORY``, including the querying identity and the objects touched.
- ****Infrastructure**** - A

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[3] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.61

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security`` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[4] logging-monitoring-standard — 3. Tamper resistance — relevance 0.60

3. Tamper resistance

The security archive bucket uses S3 Object Lock in ****compliance mode****, which cannot be disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[5] logging-monitoring-standard — 2. Retention — relevance 0.60

2. Retention

| Log class | Hot (searchable) | Archive | Total |

|---|---|---|---|

| Security and audit (CloudTrail, Okta) | 90 days in Datadog | 7 years in S3 Glacier | **7 years** |

| Application | 30 days in Datadog | 1 year in S3 | 1 year |

| Snowflake ACCESS_HISTORY | 365 days native | 7 years in S3 | 7 years |

| VPC Flow / WAF | 30 days | 1 year | 1 year |

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

266. How do you support erasure requests?

legal · Q266 · Vendor Security Review row 267

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

267. Describe your secure development lifecycle. If not, describe compensating controls.

engineering · Q267 · Vendor Security Review row 268

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

268. Do you incorporate the UK International Data Transfer Addendum?

legal · Q268 · Vendor Security Review row 269

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

269. Provide your most recent SOC 2 Type II report.

security · Q269 · Vendor Security Review row 270

Kestrel Data's most recent SOC 2 Type II report was issued on 14 March 2026 by Prescient Assurance LLP, covering the period from 1 January 2025 through 31 December 2025 (`soc2-control-matrix`, "SOC 2 Control Matrix"; `information-security-policy`, "3. Certifications and attestations"). The auditor issued an unqualified opinion with no exceptions noted (`soc2-control-matrix`, "SOC 2 Control Matrix"). The scope of the report covers the Security, Availability, and Confidentiality Trust Services Criteria (`soc2-control-matrix`, "SOC 2 Control Matrix"). The full SOC 2 Type II report is available to customers and prospective customers under a non-disclosure agreement (NDA) upon request through the account team, typically provided within two business days (`company-and-security-programme-overview`, "8. How to obtain evidence").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.70

SOC 2 Control Matrix

****Document ID:**** KD-SEC-012 · ****Version:**** 2.1

****Report period:**** 1 January - 31 December 2025 · ****Report issued:**** 14 March 2026

****Auditor:**** Prescient Assurance LLP · ****Opinion:**** Unqualified, no exceptions noted

****Trust Services Criteria in scope:**** Security, Availability, Confidentiality

Privacy and Processing Integrity are ****not**** in scope for the current report. Ke

gs://attestor-505506-corporate/security/soc2-control-matrix.txt

[2] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.69

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporate/security/company-and-security-programme-overview.txt

[3] risk-management-and-governance — Risk Management and Security Governance — relevance 0.67

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporate/security/risk-management-and-governance.txt

[4] information-security-policy — 3. Certifications and attestations — relevance 0.66

3. Certifications and attestations

| Framework | Status | Evidence |

|---|---|---|

| SOC 2 Type II | Current | Report issued 14 March 2026 by Prescient Assurance LLP, covering 1 January – 31 December 2025. No exceptions noted. |

| ISO/IEC 27001:2022 | Certified | Certificate IS-2025-44817, issued by BSI on 22 September 2025, valid to 21 September 2028 |

| ISO/IEC 27701:2019 | Certified | Extension

gs://attestor-505506-corporate/security/information-security-policy.txt

[5] vendor-risk-management-policy — Vendor Risk Management Policy — relevance 0.66

Vendor Risk Management Policy

Document ID: KD-SEC-008 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 4 February 2026 · **Next review:** 4 February 2027

Maps to: SOC 2 CC9.2 · ISO 27001:2022 A.5.19–A.5.22 · GDPR Art. 28

gs://attestor-505506-corporate/security/vendor-risk-management-policy.txt

270. Is peer review mandatory for all code changes?

engineering · Q270 · Vendor Security Review row 271

Yes, peer review is mandatory for all code changes. Under Kestrel's SDLC policy, the `main` branch is protected, and all development occurs on short-lived branches merged exclusively through pull requests (`sdhc-policy`, Section 1: "Branching and review"). Every pull request requires at least one approving review from an engineer other than the author, with self-approval blocked at the platform level. Furthermore, two approvals are required for changes involving authentication, authorization, tenant isolation, or cryptography, enforced by `CODEOWNERS`. Administrator bypass of branch protection is disabled. Even during emergency changes to resolve incidents, code review is never bypassed (`change-management-procedure`, Section 3: "Emergency changes"). In 2025, 100% of merged pull requests carried at least one approving review (`sdhc-policy`, Section 1: "Branching and review").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdhc-policy — 1. Branching and review — relevance 0.66

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from an engineer other than the author. Self-approval is blocked at the platform level.

- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths are

gs://attestor-505506-corporate/engineering/sdhc-policy.txt

[2] change-management-procedure — 3. Emergency changes — relevance 0.66

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[3] change-management-procedure — 2. Normal change requirements — relevance 0.61

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[4] change-management-procedure — 1. Change classes — relevance 0.61

1. Change classes

Class	Definition	Approval	Example
-------	------------	----------	---------

---	---	---	---
-----	-----	-----	-----

Standard	Pre-approved, low risk, automated	PR review + CI	Application code, config change through IaC
--------------	-----------------------------------	----------------	---

Normal	Material risk or customer-visible	PR review + Change Advisory sign-off	Schema migration, dependency major version
------------	-----------------------------------	--------------------------------------	--

Emergency	Fixing an active SEV1/SEV2	Retrospective with	
---------------	----------------------------	--------------------	--

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[5] sdlc-policy — 4. Security in the pipeline — relevance 0.61

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

271. What are your support response targets by severity?

engineering · Q271 · Vendor Security Review row 272

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] availability-sla — 6. Support response targets — relevance 0.76

6. Support response targets

Support targets are separate from this SLA and are not credit-bearing.

Severity	First response	Coverage
----------	----------------	----------

---	---	---
-----	-----	-----

Urgent (production down)	1 hour	24 x 7
--------------------------	--------	--------

High (major feature impaired)	4 business hours	Business hours
-------------------------------	------------------	----------------

Normal	1 business day	Business hours
--------	----------------	----------------

Low	3 business days	Business hours
-----	-----------------	----------------

Business hours are 08:00-18:00

gs://attestor-505506-corpus/engineering/availability-sla.txt

[2] service-operations-and-support — 4. Support severity definitions and response targets — relevance 0.74

4. Support severity definitions and response targets

Severity	Definition	First response	Update cadence
----------	------------	----------------	----------------

---	---	---	---
-----	-----	-----	-----

| Sev 1 | Production down, or data loss affecting the customer | **30 minutes**, 24x7 | Hourly |
| Sev 2 | Major feature unusable, no workaround | 2 business hours | Daily |
| Sev 3 | Degraded or impaired function with a workaround | 1 business day | Every 3 business d

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[3] service-operations-and-support — 7. Incident communication to customers — relevance 0.64

7. Incident communication to customers

Customer-facing incident communication is owned by the incident commander and follows the commitments in KD-SEC-008 §4. In practice: status page inside 15 minutes, direct email to affected tenant administrators inside 60 minutes for a Sev 1, and a written post-incident review within 5 business days for any Sev 1 or Sev 2, shared with affected customers on req

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] availability-sla — 4. Service credits — relevance 0.63

4. Service credits

Monthly uptime	Credit (% of monthly fee)
Below 99.9% but at or above 99.0%	10%
Below 99.0% but at or above 95.0%	25%
Below 95.0%	50%

Credits are the sole and exclusive remedy for failure to meet this SLA. A claim must be submitted within **30 days** of the end of the affected month, with supporting detail. Credits are applied to the nex

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] availability-sla — Availability Service Level Agreement — relevance 0.61

Availability Service Level Agreement

Document ID: KD-ENG-007 · **Version:** 3.0 · **Owner:** Aaron Feldstein, General Counsel
Effective: 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporus/engineering/availability-sla.txt

272. For each applicable system: Are passwords subject to a forced rotation schedule?

security · Q272 · Vendor Security Review row 273

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.66

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 2. Multi-factor authentication — relevance 0.58

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 1. Identity provider — relevance 0.57

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 6. Joiners, movers, leavers — relevance 0.55

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 3. Role-based access — relevance 0.55

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

273. Do you address Swiss FADP requirements?

legal · Q273 · Vendor Security Review row 274

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

274. Do you conduct post-incident reviews, and are they shared with customers? Provide supporting evidence.

security · Q274 · Vendor Security Review row 275

Yes, we conduct blameless post-incident reviews for every SEV1 and SEV2 incident within five business days. These reviews are published internally, with all action items tracked to closure in Jira. Post-incident reviews are shared with affected customers upon request. ****Evidence:**** - *Incident Response Runbook*, Section 8 ("Post-incident review")

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 8. Post-incident review — relevance 0.72

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 2. Roles — relevance 0.61

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.58

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] incident-response-runbook — 9. 2025 incident summary — relevance 0.58

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- ****INC-2025-0044**** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.

- ****INC-2025-0071**** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] logging-monitoring-standard — 6. Customer access to logs — relevance 0.58

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events`), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

275. Are all company devices centrally managed and encrypted?

security · Q275 · Vendor Security Review row 276

Yes. All company devices with access to Kestrel systems are company-owned, centrally managed, and encrypted: * ****Central Management:**** Every device is centrally managed (macOS endpoints via Kandji and Linux workstations via Fleet) (*endpoint-protection-standard*, Section 1 "Managed devices"; *acceptable-use-policy*, Section 1 "Company devices"). There is no BYOD programme for laptops, and device enrolment is a mandatory precondition of access validated during posture checks at every session via Cloudflare Access (*endpoint-protection-standard*, Section 1 "Managed devices"). * ****Full-Disk Encryption:**** Disk encryption is enforced across 100% of devices using FileVault 2 on macOS (with recovery keys held in Kandji custody) and LUKS on Linux workstations (*endpoint-protection-standard*, Section 4 "Disk encryption"). Encryption compliance is continuously verified by Vanta control DE-03 (*endpoint-protection-standard*, Section 4 "Disk encryption") and checked on every Cloudflare Access authentication (*acceptable-use-policy*, Section 1 "Company devices").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] acceptable-use-policy — 1. Company devices — relevance 0.73

1. Company devices

All laptops are company-owned and managed through Kandji (macOS) or Intune (Windows). Personal devices may not access Restricted or Confidential data. BYOD is permitted only for calendar and chat through managed applications with app-level containerisation.

Required device posture, enforced continuously and checked at every Cloudflare Access authentication: full-disk encry

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[2] endpoint-protection-standard — 4. Disk encryption — relevance 0.69

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[3] endpoint-protection-standard — 1. Managed devices — relevance 0.69

1. Managed devices

Every device with access to Kestrel systems is company-owned and centrally managed. There is no bring-your-own-device programme for laptops. As of 1 February 2026 the estate is 163 macOS laptops managed by Kandji and 11 Linux workstations managed by Fleet; there are no Windows endpoints in use.

Enrolment is a precondition of access: Cloudflare Access performs a device posture c

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[4] physical-and-environmental-security — 7. Equipment removal — relevance 0.66

7. Equipment removal

Company equipment may be removed from the office freely, as befits a remote-first company. Every device is enrolled in Kandji, encrypted, and remotely wipeable. Loss or theft must be reported to `#security` within 4 hours; the device is wiped remotely and the event recorded as a security incident. Three devices were reported lost or stolen in 2025, all wiped successfully, none

gs://attestor-505506-corporus/security/physical-and-environmental-security.txt

[5] asset-management-standard — 3. Endpoint lifecycle — relevance 0.66

3. Endpoint lifecycle

Devices are procured centrally, enrolled in Kandji before issue, and issued with a recorded serial number against the person in Rippling. A device is never issued unenrolled, because an unenrolled device cannot be wiped remotely.

At offboarding the device is returned within 5 business days, remotely wiped, and either re-issued or disposed of. Where a remote contractor does n

gs://attestor-505506-corporus/security/asset-management-standard.txt

276. How many internal forks of third-party libraries do you maintain?

engineering · Q276 · Vendor Security Review row 277

Kestrel deliberately maintains zero internal forks of third-party libraries. Any proposal to fork a third-party library requires VP Engineering approval and incurs a formal obligation to manually track upstream security advisories (Third-Party Library Policy, Section 7, "Internal forks").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 7. Internal forks — relevance 0.72

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains **zero** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.62

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 5. Upgrades — relevance 0.62

5. Upgrades

Renovate opens upgrade pull requests weekly. Patch-level security upgrades auto-merge when CI is green. Minor and major upgrades are reviewed manually.

An explicit goal is to stay within one minor version of current for all direct dependencies. As of 1 February 2026, 94% of direct dependencies met that target; the 6% that did not are tracked with named owners.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.61

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — Third-Party Library Policy — relevance 0.59

Third-Party Library Policy

Document ID: KD-ENG-008 · **Version:** 1.4 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

277. Do you offer customer-managed encryption keys?

engineering · Q277 · Vendor Security Review row 278

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.59

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[2] secrets-management-standard — Secrets Management Standard — relevance 0.58

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.58

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. **No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.57

1. Data flow, end to end

Ingress: A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

Instance selection: DNS and tenant routing send the request to the instance chosen

at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[5] secrets-management-standard — 4. Runtime access — relevance 0.57

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corpus/engineering/secrets-management-standard.txt

278. Can a pull request merge with an unresolved Critical dependency finding?

engineering · Q278 · Vendor Security Review row 279

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

279. When was your Information Security Policy last reviewed and approved?

security · Q279 · Vendor Security Review row 280

Kestrel Data's Information Security Policy (KD-SEC-001, Version 4.2) was last reviewed and approved on 11 February 2026 by the Board Audit & Risk Committee, with the next annual review scheduled for 11 February 2027 ('information-security-policy', Section: "Information Security Policy").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 8. Policy management — relevance 0.73

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corpus/security/risk-management-and-governance.txt

[2] information-security-policy — Information Security Policy — relevance 0.72

Information Security Policy

****Document ID:**** KD-SEC-001

****Version:**** 4.2

****Owner:**** Marcus Oyelaran, Chief Information Security Officer

****Approved by:**** Board Audit & Risk Committee, 11 February 2026

****Last review:**** 11 February 2026 · ****Next review:**** 11 February 2027

****Classification:**** Internal — may be shared with customers under NDA

gs://attestor-505506-corpus/security/information-security-policy.txt

[3] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.67

Company and Security Programme Overview

****Document ID:**** KD-SEC-021 · ****Version:**** 4.2 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 6 February 2026 · ****Next review:**** 6 February 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[4] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.66

3. Acceptable use and policy acknowledgement

Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual

cycle closed on 30 November 2025 at **100%** completion across 187 employees and 24 contractors.

gs://attestor-505506-corporate/security/personnel-security-and-training.txt

[5] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.66

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporate/security/personnel-security-and-training.txt

280. For each applicable system: Is multi-factor authentication enforced for all personnel with production access?

security · Q280 · Vendor Security Review row 281

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

281. Is automatic email forwarding to external addresses permitted?

security · Q281 · Vendor Security Review row 282

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

282. What is your turnaround commitment for data subject request assistance?

legal · Q282 · Vendor Security Review row 283

Under Kestrel Data's standard Data Processing Agreement (KD-LEG-001, §6), where self-service functionality within the Service is insufficient, Kestrel commits to assisting the customer with data subject requests within **10 business days** of receiving a written request. Furthermore, under the internal Data Subject Rights Procedure (KD-LEG-007, §2), Kestrel operationalizes this processor assistance with a target turnaround of **5 business days** of a written request (covering self-service guidance, exporting records, or executing deletions). In 2025, Kestrel achieved a measured median turnaround of 2 business days and a maximum of 5 business days for such requests (KD-LEG-007, §2).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (10)

[1] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.81

Data Subject Rights Procedure

Document ID: KD-LEG-007 · **Version:** 2.3 · **Owner:** Priya Raghunathan, DPO

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corporate/legal/data-subject-rights-procedure.txt

[2] master-agreement-summary — 9. Subcontracting — relevance 0.76

9. Subcontracting

Sub-processing is governed by the DPA: a public list (KD-LEG-006), **30 days' notice** before adding or replacing a sub-processor, a right to object on reasonable data protection grounds, and termination without penalty if the objection cannot be resolved.

gs://attestor-505506-corporate/legal/master-agreement-summary.txt

[3] data-processing-agreement — 6. Data subject rights — relevance 0.73

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within **10

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.73

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[5] data-processing-agreement — Data Processing Agreement (Template) — relevance 0.72

Data Processing Agreement (Template)

Document ID: KD-LEG-001 · **Version:** 5.1 · **Owner:** Aaron Feldstein, General Counsel

Effective: 1 February 2026 · **Supersedes:** v4.3 of 12 May 2025

Governing law: Delaware, USA, save where the SCCs specify otherwise

This DPA forms part of the Kestrel Data Master Subscription Agreement and applies where Kestrel processes Personal Data on

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[6] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.70

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[7] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.69

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[8] privacy-policy — Privacy Policy — relevance 0.68

Privacy Policy

Document ID: KD-LEG-003 · **Version:** 4.0 · **Owner:** Priya Raghunathan, DPO

Effective: 15 January 2026 · **Published at:** `kestreldata.com/privacy`

This policy describes how Kestrel Data, Inc. handles personal data where Kestrel is the **controller**. Where Kestrel processes personal data on behalf of a business customer, that customer is the controller and its own

gs://attestor-505506-corporus/legal/privacy-policy.txt

[9] data-subject-rights-procedure — 9. Records — relevance 0.67

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[10] data-subject-rights-procedure — 2. Assisting customers as processor — relevance 0.65

2. Assisting customers as processor

****Kestrel commits to assist a customer with a data subject request within 5 business days of a written request**, which is the commitment in the DPA (KD-LEG-001 §6). Assistance means one of three things:**

1. Pointing the customer at the self-service tooling that lets them do it themselves, which is the fastest route and covers the majority of requests;
2. Pro

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

283. Have you completed a Transfer Impact Assessment? Provide supporting evidence.

legal · Q283 · Vendor Security Review row 284

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

284. Do you enforce API rate limiting?

engineering · Q284 · Vendor Security Review row 285

Yes, Kestrel Data enforces API rate limiting at Cloudflare ahead of the application code across several surfaces: *** **Public API:** 120 requests per minute, per tenant. * **Bulk export endpoint:** 6 requests per minute, per tenant. * **Authentication endpoints:** 10 attempts per 5 minutes, per source address. * **Password reset:** 5 attempts per hour, per account. When a rate limit is exceeded, the service returns an HTTP 429 status code accompanied by a `Retry-After` header. Enterprise tenants may request increased rate limits through their account team** (`api-and-integration-standard`, Section 3, "Rate limiting").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] api-and-integration-standard — 3. Rate limiting — relevance 0.71

3. Rate limiting

Rate limits are enforced at Cloudflare, ahead of application code:

Surface Limit
--- ---
Public API, per tenant 120 requests/minute
Bulk export endpoint, per tenant 6 requests/minute
Authentication endpoints, per source address 10 attempts/5 minutes
Password reset, per account 5 attempts/hour (added 27 February 2026)

Exceeding a limit returns HTTP

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[2] availability-sla — 3. Exclusions — relevance 0.58

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.
- Emergency maintenance to address a security vulnerability, notified as soon as practicable.
- Customer configuration, customer code, or customer exceeding documented rate limits.
- Failure o

gs://attestor-505506-corpus/engineering/availability-sla.txt

[3] availability-sla — 2. Definitions — relevance 0.58

2. Definitions

****Uptime**** is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

****Downtime**** is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporus/engineering/availability-sla.txt

[4] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.58

2. Customer control of API credentials

****Customers create, scope, rotate, and revoke their own API credentials**** from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

****Kestrel support cannot recover a customer API key.**** K

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[5] api-and-integration-standard — 7. Versioning and deprecation — relevance 0.57

7. Versioning and deprecation

The API is versioned in the path (`/v1`, `/v2`). Backwards-incompatible changes are made only in a new version.

****The deprecation policy is 12 months' notice**** for a whole API version and ****90 days' notice**** for an individual endpoint or field, delivered by email to tenant administrators, by a ``Deprecation`` and ``Sunset`` response header, and on the developer changelog

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

285. Are development, staging, and production environments separated?

engineering · Q285 · Vendor Security Review row 286

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] sdlc-policy — 2. Environments — relevance 0.69

2. Environments

| Environment | Purpose | Data |

|---|---|---|

| ``local`` | Developer machines | Synthetic fixtures only |

| ``ci`` | Automated testing | Synthetic fixtures only |

| ``staging`` | Pre-production verification | Synthetic and anonymised data |

| ``production`` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] infrastructure-architecture-overview — 2. Account structure — relevance 0.65

2. Account structure

AWS Organizations with 9 accounts: ``management``, ``security-tooling``, ``log-archive``, ``shared-services``, ``prod-us``, ``prod-eu``, ``staging``, ``dev``, ``sandbox``. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The ``log-archive`` account has no

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 6. Network — relevance 0.62

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 3. Compute — relevance 0.60

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] sdlc-policy — 6. Release — relevance 0.59

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[6] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.59

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering
Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[7] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.58

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[8] sdlc-policy — 7. Separation of duties — relevance 0.57

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[9] sdlc-policy — 4. Security in the pipeline — relevance 0.56

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and

secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[10] sdlc-policy — 3. Testing requirements — relevance 0.56

3. Testing requirements

- Unit test coverage gate at ****80%**** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

286. Are customer API keys recoverable by your support team?

engineering · Q286 · Vendor Security Review row 287

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

287. Please confirm: Do you offer customer-managed encryption keys?

security · Q287 · Vendor Security Review row 288

Kestrel Data offers customer-managed encryption keys (CMEK) on a limited basis. Enterprise-tier customers may supply their own key material for the Snowflake data layer through Tri-Secret Secure. However, CMEK is not currently offered for the Amazon RDS or Amazon S3 storage tiers (`encryption-standard`, Section 4. Customer-managed encryption keys; Section 1. Data at rest).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 4. Customer-managed encryption keys — relevance 0.77

4. Customer-managed encryption keys

Enterprise-tier customers may supply their own key material for the Snowflake data layer through Tri-Secret Secure. As of 1 February 2026, 3 customers use this option. CMEK is ****not**** currently offered for the RDS or S3 tiers. That limitation is stated explicitly in the Security Addendum (KD-LEG-008) rather than glossed over.

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] encryption-standard — 3. Key management — relevance 0.72

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporus/security/encryption-standard.txt

[3] encryption-standard — 1. Data at rest — relevance 0.65

1. Data at rest

All customer data at rest is encrypted using ****AES-256-GCM****. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

gs://attestor-505506-corporus/security/encryption-standard.txt

[4] encryption-standard — Encryption Standard — relevance 0.63

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

[5] information-security-policy — 8. Cryptography — relevance 0.63

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corporus/security/information-security-policy.txt

288. Describe your change management process.

engineering · Q288 · Vendor Security Review row 289

Kestrel Data manages changes through a formal change management procedure that classifies changes into three categories: * **Standard Changes:** Pre-approved, low-risk changes (such as application code and configuration changes via Infrastructure as Code) require peer pull request (PR) review and passing continuous integration (CI) test suites (`change-management-procedure`, Section 1 "Change classes"). Under the branch protection rules, PRs require at least one approving review (with self-approval blocked) or two approvals for security-sensitive paths (such as authentication, authorization, tenant isolation, or cryptography) via `CODEOWNERS`, alongside passing all automated CI checks (`sdlc-policy`, Section 1 "Branching and review"). * **Normal Changes:** Changes with material risk or customer visibility (such as schema migrations or major dependency upgrades) require a PR review, a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group consisting of the VP of Engineering plus one Site Reliability Engineer (SRE). Schema migrations must maintain backward compatibility for at least one release to enable rollbacks without data migrations (`change-management-procedure`, Section 1 "Change classes" and Section 2 "Normal change requirements"). * **Emergency Changes:** Used to fix active SEV1/SEV2 incidents, emergency changes may bypass the Change Advisory step but must still pass peer code review and CI. They are authorized by the Incident Commander, and a retrospective record detailing the change, justification for bypassing the normal path, and rework assessment must be filed within one business day (`change-management-procedure`, Section 1 "Change classes" and Section 3 "Emergency changes"). Releases are deployed continuously following a merge to `main`. The deployment pipeline utilizes a canary-based progressive rollout (5% of traffic for 15 minutes, then 25%, then 100%) with automatic rollbacks triggered upon error-rate or latency regressions (`sdlc-policy`, Section 6 "Release"). Direct human deployments to production are prohibited; all deployments are executed strictly through automated CI service identities (`sdlc-policy`, Section 7 "Separation of duties"). Additionally, change freezes are enforced from December 20 to January 2 and during any active SEV1, during which only emergency changes are permitted (`change-management-procedure`, Section 7 "Change freeze").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (10)

[1] change-management-procedure — no section recorded — relevance 0.71

Change Management Procedure **Document ID:** KD-ENG-002 ... PR review + CI | Application code, config change ... changes are Standard. In 2025 there were 3,847 ...

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] change-management-procedure — Change Management Procedure — relevance 0.64

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] change-management-procedure — 2. Normal change requirements — relevance 0.60

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[4] change-management-procedure — 3. Emergency changes — relevance 0.59

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[5] change-management-procedure — 1. Change classes — relevance 0.59

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[6] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.58

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[7] sdlc-policy — 6. Release — relevance 0.57

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[8] sdlc-policy — 7. Separation of duties — relevance 0.56

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[9] sdlc-policy — 1. Branching and review — relevance 0.56

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from an engineer other than the author. Self-approval is blocked at the platform level.

- Two approvals for changes touching authentication, authorisation, tenant isolation, or

cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[10] change-management-procedure — 7. Change freeze — relevance 0.54

7. Change freeze

A change freeze applies from 20 December to 2 January, and during any active SEV1. Only Emergency changes are permitted during a freeze.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

289. Please confirm: What is the export window available after termination?

legal · Q289 · Vendor Security Review row 290

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

290. What is the lawful basis for your product telemetry processing?

legal · Q290 · Vendor Security Review row 291

Kestrel acts as a data controller for product telemetry processing, and the lawful basis relied upon under GDPR is ****Article 6(1)(f) legitimate interests**** (GDPR Records of Processing Activities (Art. 30), Part B - Kestrel as Controller (Art. 30(1)); Data Processing Agreement, Section 1). This processing applies to pseudonymous usage events from platform users and has a retention period of 24 months (GDPR Records of Processing Activities (Art. 30), Part B - Kestrel as Controller (Art. 30(1))).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (8)

[1] transfer-impact-assessment — 4. Assessment of US law — relevance 0.70

4. Assessment of US law

The assessment considers FISA §702 and Executive Order 12333, and reaches these conclusions:

* Kestrel is ****not**** an "electronic communications service provider" as defined in 50 USC §1881(b)(4). It provides an analytics platform, not communications services, and has never received a directive under §702.

* Executive Order 14086 and the Data Protection Review Court mat

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[2] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.70

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

|---|---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

| C3 | Pro

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[3] data-processing-agreement — 1. Roles — relevance 0.69

1. Roles

Customer is ****Controller****. Kestrel Data, Inc. is ****Processor****. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is ****Controller**** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] data-subject-rights-procedure — 7. Objection, restriction, and automated decision-making — relevance 0.68

7. Objection, restriction, and automated decision-making

Objection and restriction requests concerning customer content are directed to the controller. Kestrel performs no automated decision-making producing legal or similarly significant effects, so Article 22 is not engaged; the machine learning features in the product are described in KD-SEC-019 §2.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[5] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.68

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[6] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.65

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[7] dpia-register — 5. Automated decision-making — relevance 0.65

5. Automated decision-making

Kestrel performs **no automated decision-making** producing legal effects or similarly significant effects concerning data subjects, within the meaning of Article 22. The two machine learning features described in KD-SEC-019 §2 surface information to the customer's own analysts; the decisions that follow are made by people at the customer, using the customer's own data

gs://attestor-505506-corpus/legal/dpia-register.txt

[8] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.65

5. Supplementary measures relied on

Technical:

- Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
- Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
- Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

291. Do you operate active-active failover between regions?

engineering · Q291 · Vendor Security Review row 292

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

292. Have you ever received a national security request or National Security Letter?

legal · Q292 · Vendor Security Review row 293

As of February 2, 2026, Kestrel Data has never received a National Security Letter, a FISA order, or any other national security process, and has never provided any government with direct, bulk, or unfettered access to customer data (*Government Requests Policy and Transparency Report*, Section 4; *Transfer Impact Assessment*, Section 4). Kestrel operates no government-facing interception capability and has deposited no encryption keys with any authority (*Government Requests Policy and Transparency Report*, Section 4).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] government-requests-and-transparency-report — 4. Statement on national security process — relevance 0.63

4. Statement on national security process

As of 2 February 2026, **Kestrel Data has never received a National Security Letter, a FISA order, or any other national security process, and has never provided any government with direct, bulk, or unfettered access to customer data.** Kestrel operates no government-facing interception capability and has deposited no encryption keys with any authority.

K

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 1. Who may receive a request — relevance 0.62

1. Who may receive a request

All law enforcement, regulatory, and national security requests for customer data must be directed to the General Counsel at `legal@kestreldata.com`. No other person at Kestrel is authorised to accept service or to disclose customer data to a government authority. Support, sales, and engineering personnel are trained to route any such approach to the General Counsel wi

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

[3] transfer-impact-assessment — 4. Assessment of US law — relevance 0.61

4. Assessment of US law

The assessment considers FISA §702 and Executive Order 12333, and reaches these conclusions:

* Kestrel is **not** an "electronic communications service provider" as defined in 50 USC §1881(b)(4). It provides an analytics platform, not communications services, and has never received a directive under §702.

* Executive Order 14086 and the Data Protection Review Court mat

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[4] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.60

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

[5] government-requests-and-transparency-report — 5. Emergency disclosure requests — relevance 0.58

5. Emergency disclosure requests

An emergency request citing an imminent risk to life is escalated to the General Counsel immediately, at any hour, through the `legal-oncall` PagerDuty rotation. Disclosure in those circumstances is limited to what is necessary to address the emergency, is documented in the register, and the customer is notified afterwards unless prohibited. No emergency request ha

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

293. What service credits apply if the availability commitment is missed?

legal · Q293 · Vendor Security Review row 294

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] master-agreement-summary — 10. Service levels — relevance 0.74

10. Service levels

The availability commitment, service credits, and support response targets are in the Availability SLA (KD-ENG-001). Service credits are the sole remedy for missed availability, with a termination right if the monthly commitment is missed in three consecutive months.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[2] security-addendum — 6. Availability commitment — relevance 0.68

6. Availability commitment

99.9% monthly uptime for Enterprise and Growth tiers, with service credits as set out in the Availability SLA (KD-ENG-007). No availability SLA applies to the Starter tier.

gs://attestor-505506-corporus/legal/security-addendum.txt

[3] security-addendum — 8. Changes — relevance 0.61

8. Changes

Kestrel may update this addendum, provided that no update materially reduces the commitments during a paid term. Material changes are notified 30 days in advance.

gs://attestor-505506-corporus/legal/security-addendum.txt

[4] security-addendum — 1. Certifications maintained — relevance 0.61

1. Certifications maintained

Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days

gs://attestor-505506-corporus/legal/security-addendum.txt

[5] security-addendum — 3. Access commitments — relevance 0.61

3. Access commitments

- Multi-factor authentication mandatory for all Kestrel personnel with production access.
- Production access on a least-privilege, just-in-time basis, expiring within 8 hours.
- No routine Kestrel access to customer production data; support access requires per-incident customer authorisation.
- Access revoked within 24 hours of personnel departure. Measured median in 2

gs://attestor-505506-corporus/legal/security-addendum.txt

294. What open source licences are prohibited in your codebase?

engineering · Q294 · Vendor Security Review row 295

Under our Third-Party Library Policy, the following open source licences are strictly prohibited in Kestrel Data's codebase: * GPL-2.0 * GPL-3.0 * AGPL-1.0 * AGPL-3.0 * SSPL * BUSL * Commons Clause * Any licence lacking a clear grant AGPL and SSPL are specifically prohibited because Kestrel distributes a network service. Licence compliance is enforced automatically in CI using FOSSA on every pull request, and the presence of a prohibited licence causes the build to fail (`third-party-library-policy`, Section 2).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 2. Licence policy — relevance 0.69

2. Licence policy

Allowed: MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

****Requires legal review:**** MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.63

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 7. Internal forks — relevance 0.63

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains ****zero**** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.60

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — Third-Party Library Policy — relevance 0.57

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

295. Do you conduct post-incident reviews, and are they shared with customers?

security · Q295 · Vendor Security Review row 296

Yes. Kestrel Data conducts a blameless post-incident review within five business days for every SEV1 and SEV2 incident, publishes the review internally, and tracks all action items to closure in Jira. Post-incident reviews are shared with affected customers on request (Incident Response Runbook, Section 8. Post-incident review).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 8. Post-incident review — relevance 0.68

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 2. Roles — relevance 0.59

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — 6. Evidence handling — relevance 0.56

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — 9. 2025 incident summary — relevance 0.56

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- **INC-2025-0044** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.
- **INC-2025-0071** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — Incident Response Runbook — relevance 0.56

Incident Response Runbook

Document ID: KD-SEC-005 · **Version:** 5.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 27 January 2026 · **Last exercised:** 3 December 2025 (tabletop)

Maps to: SOC 2 CC7.3, CC7.4, CC7.5 · ISO 27001:2022 A.5.24-A.5.28 · GDPR Art. 33, 34

gs://attestor-505506-corporus/security/incident-response-runbook.txt

296. Please confirm: How are security responsibilities communicated to personnel?

security · Q296 · Vendor Security Review row 297

Security responsibilities are communicated to personnel through four deliberately overlapping channels: 1. **Offer Pack and Onboarding Session:** Initial expectations and responsibilities are provided in the offer pack and during the onboarding session. 2. **Annual Policy Acknowledgement:** All personnel complete an annual policy acknowledgement. 3. **Monthly All-Hands Meeting:** A standing security update is delivered directly by the CISO at the monthly all-hands meeting. 4. **Dedicated #security Slack Channel:** The #security Slack channel serves as the documented channel for reporting suspicious activity; it is monitored during business hours and escalates via PagerDuty outside of business hours. *(Source: `personnel-security-and-training`, Section 7: "How security responsibilities are communicated")*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] personnel-security-and-training — 7. How security responsibilities are communicated — relevance 0.71

7. How security responsibilities are communicated

Responsibilities are communicated four ways, deliberately overlapping: the offer pack and onboarding session; the annual policy acknowledgement; a standing item in the monthly all-hands delivered by the CISO; and the #security Slack channel, which is the documented route for reporting anything suspicious and is monitored during business hours wit

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — 4. Security awareness training — relevance 0.64

4. Security awareness training

Security awareness training is **mandatory** for all personnel, annually, plus at

onboarding within the first 14 days**. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[3] risk-management-and-governance — 8. Policy management — relevance 0.64

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.63

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] incident-response-runbook — 2. Roles — relevance 0.61

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

297. Is multi-factor authentication enforced for all personnel with production access?

security · Q297 · Vendor Security Review row 298

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

298. When does your ISO 27001 certification expire?

security · Q298 · Vendor Security Review row 299

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

299. How many secrets have been committed to your repositories in the last year?

engineering · Q299 · Vendor Security Review row 300

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

300. Do you generate a Software Bill of Materials for production builds?

engineering · Q300 · Vendor Security Review row 301

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

301. For each applicable system: Can an engineer deploy directly to production, bypassing the pipeline?

engineering · Q301 · Vendor Security Review row 302

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] sdlc-policy — 7. Separation of duties — relevance 0.68

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] change-management-procedure — 3. Emergency changes — relevance 0.64

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] sdlc-policy — 4. Security in the pipeline — relevance 0.61

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 6. Release — relevance 0.57

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 1. Branching and review — relevance 0.57

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[6] sdlc-policy — 2. Environments — relevance 0.56

2. Environments
| Environment | Purpose | Data |
|---|---|---|
| `local` | Developer machines | Synthetic fixtures only |
| `ci` | Automated testing | Synthetic fixtures only |
| `staging` | Pre-production verification | Synthetic and anonymised data |
| `production` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

302. Is the platform accessible from the public internet without authentication?

security · Q302 · Vendor Security Review row 303

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (16)

[1] network-security-standard — 6. Internal application access — relevance 0.68

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

[2] pen-test-executive-summary — 2. Methodology — relevance 0.62

2. Methodology

Grey-box testing against OWASP ASVS 4.0 Level 2 and the OWASP API Security Top 10. Testers were given standard-tier and admin-tier credentials for each seeded tenant plus API documentation. 74 person-hours across two testers.

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[3] network-security-standard — 2. Web application firewall — relevance 0.62

2. Web application firewall

****Cloudflare WAF is enabled on all production hostnames**, running the Cloudflare Managed Ruleset, the OWASP Core Ruleset at paranoia level 2, and 14 Kestrel-authored rules. Rules are deployed in log mode for 7 days before enforcement so that a false positive is found before it blocks a customer. Blocked request volume averaged 41,000 per day during 2025, of which the l**

gs://attestor-505506-corporus/security/network-security-standard.txt

[4] network-security-standard — 4. Inbound rules — relevance 0.62

4. Inbound rules

****There are no unrestricted inbound rules (`0.0.0.0/0`) in any production security group other than ports 80 and 443 on the load balancer security group, which are themselves restricted to Cloudflare ranges.**** SSH ingress is closed entirely; administrative access is through AWS Systems Manager Session Manager, which requires an IAM identity and produces a recorded session.

Config

gs://attestor-505506-corporus/security/network-security-standard.txt

[5] access-control-standard — 3. Role-based access — relevance 0.60

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is

just-in-time.

gs://attestor-505506-corpus/security/access-control-standard.txt

[6] pen-test-executive-summary — 3. Findings summary — relevance 0.59

3. Findings summary

| Severity | Found | Remediated | Retest verified |

|---|---|---|---|

| Critical | 0 | - | - |

| High | 1 | 1 | 18 March 2026 |

| Medium | 4 | 4 | 18 March 2026 |

| Low | 7 | 5 | 18 March 2026 |

| Informational | 9 | Accepted / tracked | - |

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[7] network-security-standard — 1. Perimeter — relevance 0.59

1. Perimeter

All customer traffic enters through Cloudflare. The AWS Application Load Balancers accept connections only from Cloudflare IP ranges, enforced by security group rules and verified by a synthetic check that attempts a direct origin connection hourly and alerts if it succeeds. The origin has not been reachable directly since 4 September 2024.

gs://attestor-505506-corpus/security/network-security-standard.txt

[8] information-security-policy — 7. Access control — relevance 0.58

7. Access control

Access follows least privilege and is governed by the Access Control Standard (KD-SEC-002). Identity is federated through Okta with SAML 2.0. Hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff; SMS and TOTP were retired as authentication factors on 30 June 2025.

Production access requires a documented business justification, e

gs://attestor-505506-corpus/security/information-security-policy.txt

[9] access-control-standard — 10. Remote access — relevance 0.58

10. Remote access

There is no traditional VPN. Access to internal applications is mediated by Cloudflare Access with device posture checks requiring disk encryption, a current OS, and an enrolled MDM profile (Kandji for macOS, 163 devices as of 1 February 2026).

gs://attestor-505506-corpus/security/access-control-standard.txt

[10] pen-test-executive-summary — 1. Scope — relevance 0.57

1. Scope

- Kestrel Insight web application (`app.kestreldata.com`), authenticated and unauthenticated surfaces
- Public REST API v2 (`api.kestreldata.com`), 89 endpoints
- Multi-tenant isolation testing across 3 seeded tenant accounts
- AWS cloud configuration review (IAM, S3, VPC, EKS)
- Authentication and session management, including the Okta SAML integration

Out of scope: physical se

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[11] access-control-standard — 2. Multi-factor authentication — relevance 0.57

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporate/security/access-control-standard.txt

[12] access-control-standard — 9. Password requirements — relevance 0.57

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporate/security/access-control-standard.txt

[13] access-control-standard — 5. Customer data access — relevance 0.57

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corporate/security/access-control-standard.txt

[14] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.55

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporate/security/company-and-security-programme-overview.txt

[15] pen-test-executive-summary — Penetration Test Executive Summary — relevance 0.50

Penetration Test Executive Summary

Document ID: KD-SEC-007 · **Engagement:** INSEC-2026-0219

Tester: Include Security, Inc. · **Dates:** 3-14 February 2026

Report issued: 24 February 2026 · **Retest completed:** 18 March 2026

Classification: Confidential - shareable with customers under NDA

gs://attestor-505506-corporate/security/pen-test-executive-summary.txt

[16] pen-test-executive-summary — 6. Two accepted low findings — relevance 0.49

6. Two accepted low findings

- **L6** - Username enumeration remains possible through the SAML metadata endpoint for customers using IdP-initiated flows. Accepted; mitigation would break a documented integration pattern. Tracked as RISK-2026-0004.

- **L7** - TLS 1.2 remains enabled on the legacy SFTP endpoint. Accepted until the Q3 2026 decommission. Tracked as RISK-2025-0088.

gs://attestor-505506-corporate/security/pen-test-executive-summary.txt

303. Is security awareness training mandatory, and at what frequency?

security · Q303 · Vendor Security Review row 304

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

304. Is automatic email forwarding to external addresses permitted? If not, describe compensating controls.

security · Q304 · Vendor Security Review row 305

Automatic forwarding of Kestrel email to external addresses is strictly prohibited and technically blocked at the Google Workspace tenant level for all users, with no exceptions permitted (Acceptable Use Policy §5; Endpoint Protection Standard §6). Because forwarding rules created post-compromise represent a primary exfiltration vector, this restriction is enforced through technical policy rather than policy guidance alone and is continuously monitored via Vanta control

EM-02 (Endpoint Protection Standard §6). To further prevent unauthorized data exfiltration and safeguard email communications, Kestrel implements the following compensating and complementary controls: * **Email Data Loss Prevention (DLP):** Google Workspace DLP inspects outbound messages for tenant identifiers, bulk personal data patterns, and credential-shaped strings, automatically quarantining matches for administrative review by the Head of IT (Endpoint Protection Standard §5). * **Authentication and External Tagging:** DMARC is enforced with `p=reject`, alongside SPF and DKIM across all sending domains, and incoming external messages are banner-tagged (Acceptable Use Policy §5).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] endpoint-protection-standard — 6. Automatic email forwarding — relevance 0.73

6. Automatic email forwarding

Automatic forwarding of Kestrel email to external addresses is blocked by Google Workspace policy for all users. There are no exceptions, and the setting is monitored by Vanta control EM-02. Forwarding rules created by an attacker after a mailbox compromise are the standard exfiltration route, so this is enforced technically rather than by policy text.

gs://attestor-505506-corpus/security/endpoint-protection-standard.txt

[2] acceptable-use-policy — 5. Email and communications — relevance 0.64

5. Email and communications

Kestrel uses Google Workspace with DMARC set to `p=reject`, SPF, and DKIM enforced on all sending domains. External email is banner-tagged. Automatic forwarding to external addresses is disabled at the tenant level and cannot be enabled by end users.

gs://attestor-505506-corpus/security/acceptable-use-policy.txt

[3] acceptable-use-policy — 4. Data handling — relevance 0.58

4. Data handling

Restricted data may not be copied to personal cloud storage, personal email, USB media, or unmanaged devices. USB mass storage is blocked at the OS level on all managed devices.

Screen sharing during customer calls must use a dedicated demo tenant, never production.

gs://attestor-505506-corpus/security/acceptable-use-policy.txt

[4] endpoint-protection-standard — 5. Data loss prevention — relevance 0.57

5. Data loss prevention

DLP controls operate at three points rather than relying on a single agent:

* **Endpoint** — Kandji policy blocks USB mass storage write access on all laptops. AirDrop to non-Kestrel devices is disabled.

* **Email** — Google Workspace DLP inspects outbound mail for tenant identifiers, bulk personal data patterns, and credential-shaped strings, quarantining matches for

gs://attestor-505506-corpus/security/endpoint-protection-standard.txt

[5] acceptable-use-policy — 6. Monitoring — relevance 0.56

6. Monitoring

Kestrel monitors use of its systems for security purposes as described in the Logging and Monitoring Standard. Monitoring is proportionate, is not used for productivity surveillance, and is disclosed to staff at onboarding.

gs://attestor-505506-corpus/security/acceptable-use-policy.txt

305. Describe the data flow for customer data through your platform.

engineering · Q305 · Vendor Security Review row 306

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.68

1. Data flow, end to end

1. **Ingress** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[2] data-flow-and-shared-responsibility — 5. Categories of customer data — relevance 0.67

5. Categories of customer data

The four categories the platform processes are defined in KD-SEC-004 §2 and mirrored in the Records of Processing Activities (KD-LEG-004). Kestrel does not process payment card data: Stripe collects card details directly and Kestrel holds a token and the last four digits.

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[3] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.63

Data Flow and Shared Responsibility Model

Document ID: KD-ENG-011 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] data-flow-and-shared-responsibility — 2. What crosses a boundary, and what does not — relevance 0.62

2. What crosses a boundary, and what does not

| Data | Leaves the tenant's region? |

|---|

| Customer-uploaded analytics datasets | **No** |

| Backups of customer content | **No** |

| Account identity data (EU tenants) | Only for support access, under §4 of KD-SEC-002 |

| Pseudonymised product telemetry | Yes — aggregated to the US, assessed in KD-LEG-010 |

| Operational logs (content-redacted

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.61

- * deciding what data they upload, and its lawfulness — Kestrel does not inspect it;
- * configuring SSO, and enforcing MFA at their own identity provider;
- * managing their own users, roles, and permissions, including timely removal of leavers;
- * the scope, storage, and rotation of the API credentials they create;
- * reviewing their own audit log, which Kestrel makes available for 13 months;
- * acting

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

306. Are audit logs tamper-resistant? Describe the mechanism.

security · Q306 · Vendor Security Review row 307

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

307. Provide your measured median access revocation time for the last 12 months. Provide supporting evidence.

security · Q307 · Vendor Security Review row 308

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

308. Are backups replicated across regions? Do they leave the residency boundary? Provide supporting evidence.

legal · Q308 · Vendor Security Review row 309

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

309. Provide your measured SLA compliance rate for the last 12 months.

engineering · Q309 · Vendor Security Review row 310

For the most recent full calendar year (2025), Kestrel Data achieved a measured availability rate of 99.97%, with zero months falling below the 99.9% uptime threshold and zero service credits issued (availability-sla, Section 5 "Historical performance"). Measurement is performed independently via third-party monitoring (Checkly across 7 global locations at 30-second intervals) (availability-sla, Section 2 "Definitions").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (7)

[1] availability-sla — 2. Definitions — relevance 0.73

2. Definitions

****Uptime**** is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

****Downtime**** is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corpus/engineering/availability-sla.txt

[2] availability-sla — 5. Historical performance — relevance 0.70

5. Historical performance

| Year | Measured availability | Months below 99.9% | Credits issued |

|---|---|---|---|

| 2025 | 99.97% | 0 | 0 |

| 2024 | 99.94% | 1 (March, 99.87%) | 1 customer, 10% |

| 2023 | 99.91% | 1 (August, 99.82%) | 3 customers, 10% |

gs://attestor-505506-corpus/engineering/availability-sla.txt

[3] availability-sla — 4. Service credits — relevance 0.69

4. Service credits

| Monthly uptime | Credit (% of monthly fee) |

|---|---|

| Below 99.9% but at or above 99.0% | 10% |

| Below 99.0% but at or above 95.0% | 25% |

| Below 95.0% | 50% |

Credits are the sole and exclusive remedy for failure to meet this SLA. A claim must be submitted within ****30 days**** of the end of the affected month, with supporting detail. Credits are applied to the nex

gs://attestor-505506-corpus/engineering/availability-sla.txt

[4] availability-sla — Availability Service Level Agreement — relevance 0.67

Availability Service Level Agreement

****Document ID:**** KD-ENG-007 · ****Version:**** 3.0 · ****Owner:**** Aaron Feldstein, General Counsel

****Effective:**** 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corpus/engineering/availability-sla.txt

[5] availability-sla — 6. Support response targets — relevance 0.67

6. Support response targets
Support targets are separate from this SLA and are not credit-bearing.

Severity	First response	Coverage
Urgent (production down)	1 hour	24 x 7
High (major feature impaired)	4 business hours	Business hours
Normal	1 business day	Business hours
Low	3 business days	Business hours

Business hours are 08:00-18:00

gs://attestor-505506-corporus/engineering/availability-sla.txt

[6] service-operations-and-support — 8. Capacity and performance — relevance 0.65

8. Capacity and performance
Capacity is reviewed monthly against a 90-day forecast. Autoscaling handles ordinary variation; the review exists for the changes autoscaling cannot absorb, such as a large tenant onboarding. Two capacity increases were made ahead of demand in 2025, neither triggered by a saturation alert.

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[7] service-operations-and-support — 6. Monitoring and alerting — relevance 0.64

6. Monitoring and alerting
Datadog holds infrastructure metrics, application performance monitoring, and synthetic checks running every 60 seconds from five geographic locations against both instances. Alerts are symptom-based — error rate, latency percentile, saturation, and synthetic failure — rather than cause-based, so a novel failure still pages someone.

Uptime is measured from the synthetic

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

310. Have you completed any Data Protection Impact Assessments? If not, describe compensating controls.

legal · Q310 · Vendor Security Review row 311

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

311. How frequently may a customer audit, and on what notice?

legal · Q311 · Vendor Security Review row 312

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

312. What is your scheduled maintenance window? Provide supporting evidence.

engineering · Q312 · Vendor Security Review row 313

Our standard scheduled maintenance window is Sundays from 06:00 to 10:00 UTC (KD-ENG-009, Service Operations, Maintenance and Support, Section 2; see also Availability Service Level Agreement, KD-ENG-007, Section 3). Most changes do not require using this window, as deployments follow a rolling, zero-downtime process. When scheduled maintenance is expected to be customer-affecting, customers receive at least 7 days' advance notice via email to tenant administrators and on our status page, or 30 days' advance notice if the change requires customer action (KD-ENG-009, Section 2). Emergency maintenance required to address critical security fixes may be conducted on shorter notice under our emergency change procedure, with customer notifications distributed as soon as the change is scheduled (KD-ENG-009, Section 2).

Evidence (5)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.73

2. Scheduled maintenance

The standard maintenance window is ****Sundays 06:00–10:00 UTC****. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

****Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting**, and 30 days' notice where the change requires customer a**

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] availability-sla — 3. Exclusions — relevance 0.67

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.
- Emergency maintenance to address a security vulnerability, notified as soon as practicable.
- Customer configuration, customer code, or customer exceeding documented rate limits.
- Failure o

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.63

Service Operations, Maintenance and Support

****Document ID:** KD-ENG-009 · ****Version:** 2.2 · ****Owner:** Dana Whitfield, VP Engineering******

****Approved:** 23 January 2026 · ****Next review:** 23 January 2027****

****Maps to:** SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32**

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] availability-sla — 6. Support response targets — relevance 0.61

6. Support response targets

Support targets are separate from this SLA and are not credit-bearing.

Severity	First response	Coverage
--- --- ---		
Urgent (production down)	1 hour	24 x 7
High (major feature impaired)	4 business hours	Business hours
Normal	1 business day	Business hours
Low	3 business days	Business hours

Business hours are 08:00-18:00

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] availability-sla — Availability Service Level Agreement — relevance 0.58

Availability Service Level Agreement

****Document ID:** KD-ENG-007 · ****Version:** 3.0 · ****Owner:** Aaron Feldstein, General Counsel******

****Effective:** 1 January 2026 · Forms part of the Master Subscription Agreement**

gs://attestor-505506-corporus/engineering/availability-sla.txt